Київський столичний університет імені Бориса Грінченка

Володимир Соколов

ПРИКЛАДНІ АСПЕКТИ ТЕСТУВАНЬ НА ПРОНИКНЕННЯ ТА ЕТИЧНОГО ХАКІНГУ

Навчальний посібник

для здобувачів другого (освітнього) рівня вищої освіти
спеціальності 125/F5 «Кібербезпека та захист інформації»
галузі знань 12/F «Інформаційні технології»

Київ — 2027

УДК 004.056.5:004.492(075.8)
ББК 32.973.26-018.2
С594

Препринт

Соколов В. Ю. Прикладні аспекти тестувань на проникнення та етичного хакінгу : навчальний посібник для здобувачів другого (освітнього) рівня вищої освіти. Київ, КСУБГ, 2027, 136 с. — 17 розділів.

Навчальний посібник присвячено методології та прикладним аспектам авторизованого тестування на проникнення й етичного хакінгу як засобів оцінювання та підвищення захищеності інформаційних систем. Систематично розглянуто понятєвий апарат і види тестування, правові та етичні засади (авторизація, законодавство України, відповідальне розкриття), провідні методології та стандарти (PTES, OSSTMM, NIST SP 800-115, OWASP, MITRE ATT&CK), планування й визначення обсягу робіт. Докладно висвітлено етапи тестування: розвідку й збір інформації (OSINT), сканування та ідентифікацію, аналіз і оцінювання вразливостей, контрольовану експлуатацію, постексплуатацію, підвищення привілеїв і бокове переміщення. Окремо розглянуто тестування вебзастосунків, безпроводових і мобільних систем, мережевої інфраструктури та хмари, соціальну інженерію, red/purple teaming, звітування й комунікацію результатів, а також професійний розвиток і управління програмою тестування. Матеріал спирається на актуальні міжнародні стандарти й наукові джерела та враховує вітчизняний контекст.

Кожен розділ завершується висновками та питаннями для самоперевірки, серед яких — дослідницькі завдання, придатні як відправна точка для наукової статті чи фрагмента дисертаційного дослідження. Посібник призначено для магістрантів галузі знань 12/F «Інформаційні технології» спеціальності 125/F5 «Кібербезпека та захист інформації», а також буде корисним науковим і науково-педагогічним працівникам, фахівцям із захисту інформації та кібербезпеки.

© Володимир Соколов, 2027
© Київський столичний університет імені Бориса Грінченка, 2027

Зміст

Перелік умовних скорочень **1**

Вступ **3**

1 Етичний хакінг і тестування на проникнення: поняття та місце **5**
1.1 Понятєвий апарат . . . 5
1.2 Відмінність від суміжних видів оцінювання . . . 6
1.3 Види та класифікація тестування . . . 6
1.4 Місце в системі управління безпекою . . . 7
1.5 Обмеження методу . . . 8
1.6 Визначальна роль етики . . . 9
1.7 Кейс: вибір типу тестування . . . 9
Висновки до розділу . . . 10
Питання для самоперевірки . . . 10

2 Правові та етичні засади **13**
2.1 Авторизація як фундамент . . . 13
2.2 Законодавство України та міжнародний контекст . . . 14
2.3 Договірне оформлення та межі . . . 14
2.4 Поводження з даними та мінімізація шкоди . . . 15
2.5 Відповідальне розкриття вразливостей . . . 16
2.6 Професійна етика . . . 17
2.7 Кейс: правове оформлення тестування . . . 17
Висновки до розділу . . . 18
Питання для самоперевірки . . . 18

3 Методології та стандарти тестування на проникнення **21**
3.1 Значення методологій . . . 21
3.2 Провідні стандарти й методології . . . 22
3.3 Концептуальні моделі . . . 24
3.4 Узагальнена фазова модель . . . 24
3.5 Вибір і комбінування методологій . . . 25
3.6 Кейс: добір методології . . . 26
Висновки до розділу . . . 26
Питання для самоперевірки . . . 27

4 Планування, визначення обсягу та правил взаємодії **29**
4.1 Попередня взаємодія та збір вимог 29
4.2 Моделювання загроз як основа планування 29
4.3 Визначення обсягу 30
4.4 Правила взаємодії 31
4.5 Управління ризиками проєкту та комунікація 32
4.6 Кейс: планування тестування 33
Висновки до розділу 33
Питання для самоперевірки 34

5 Розвідка та збір інформації **35**
5.1 Роль і типи розвідки 35
5.2 Пасивний збір та OSINT 36
5.3 Активна розвідка 37
5.4 Побудова карти поверхні атаки 37
5.5 Захисні висновки: зменшення цифрового сліду 39
5.6 Кейс: розвідка в межах тестування 39
Висновки до розділу 40
Питання для самоперевірки 40

6 Сканування та ідентифікація **43**
6.1 Виявлення вузлів 43
6.2 Сканування портів 43
6.3 Ідентифікація сервісів та ОС 44
6.4 Точність та час сканування 45
6.5 Виявлення сканування стороною захисту 46
6.6 Кейс: сканування в межах тестування 47
Висновки до розділу 47
Питання для самоперевірки 48

7 Аналіз та оцінювання вразливостей **49**
7.1 Джерела знань про вразливості 49
7.2 Автоматизоване та ручне виявлення 50
7.3 Оцінювання критичності та ризику 50
7.4 Валідація та хибнопозитивні спрацювання 51
7.5 Пріоритезація 51
7.6 Кейс: аналіз вразливостей цілі 52
Висновки до розділу 53
Питання для самоперевірки 53

8 Контрольована експлуатація вразливостей 55
8.1 Принципи та мета експлуатації . . . 55
8.2 Інструментарій . . . 55
8.3 Контрольованість та мінімізація шкоди . . . 56
8.4 Надійність та ризики експлуатації . . . 57
8.5 Демонстраційні сценарії та захисні висновки . . . 58
8.6 Кейс: контрольована експлуатація . . . 58
Висновки до розділу . . . 59
Питання для самоперевірки . . . 59

9 Постексплуатація та підвищення привілеїв 61
9.1 Мета та принципи . . . 61
9.2 Ситуаційна обізнаність . . . 61
9.3 Підвищення привілеїв . . . 62
9.4 Доступ до облікових даних та закріплення . . . 64
9.5 Прибирання та відновлення . . . 64
9.6 Кейс: постексплуатація та оцінка впливу . . . 65
Висновки до розділу . . . 66
Питання для самоперевірки . . . 66

10 Бокове переміщення та закріплення в мережі 69
10.1 Сутність та цілі . . . 69
10.2 Механізми переміщення . . . 69
10.3 Графи атак та аналіз шляхів . . . 70
10.4 Виявлення бокового переміщення . . . 71
10.5 Захисні заходи . . . 72
10.6 Кейс: тестування бокового переміщення . . . 73
Висновки до розділу . . . 73
Питання для самоперевірки . . . 74

11 Тестування захищеності вебзастосунків 75
11.1 Специфіка вебзастосунків як цілі . . . 75
11.2 Класифікація ризиків . . . 75
11.3 Ін'єкційні вразливості . . . 76
11.4 Автентифікація, сесії та контроль доступу . . . 77
11.5 Бізнес-логіка та API . . . 78
11.6 Кейс: тестування вебзастосунку . . . 79
Висновки до розділу . . . 79
Питання для самоперевірки . . . 80

12 Тестування безпроводових та мобільних систем 81
12.1 Специфіка безпроводового середовища 81
12.2 Тестування Wi-Fi 81
12.3 Інші безпроводові технології 82
12.4 Безпека мобільних платформ 83
12.5 Тестування мобільних застосунків 83
12.6 Кейс: тестування безпроводової та мобільної систем 84
Висновки до розділу 85
Питання для самоперевірки 85

13 Тестування мережевої інфраструктури та хмари 87
13.1 Внутрішня мережа та служби каталогів 87
13.2 Мережеві пристрої та периметр 87
13.3 Специфіка хмарних середовищ 88
13.4 Помилки конфігурації як домінантний клас 89
13.5 Спеціалізовані середовища 90
13.6 Кейс: тестування інфраструктури та хмари 90
Висновки до розділу 91
Питання для самоперевірки 91

14 Соціальна інженерія та фізичне тестування 93
14.1 Людський чинник 93
14.2 Принципи впливу 93
14.3 Види соціальної інженерії 94
14.4 Фізичне тестування 95
14.5 Етичні межі цього виду тестування 96
14.6 Захисні висновки: обізнаність та процедури 96
14.7 Кейс: тестування соціальної інженерії 97
Висновки до розділу 98
Питання для самоперевірки 98

15 Red teaming, purple teaming та емуляція супротивника 101
15.1 Red teaming проти тестування на проникнення 101
15.2 Емуляція супротивника на основі ATT&CK 102
15.3 Прихованість та OPSEC 102
15.4 Purple teaming 103
15.5 Метрики спроможності виявлення 104
15.6 Кейс: емуляція супротивника 105
Висновки до розділу 105
Питання для самоперевірки 106

16 Звітування, документування та комунікація результатів 107
16.1 Роль і призначення звіту 107
16.2 Структура та аудиторії 107
16.3 Опис знахідок і доказів 108
16.4 Оцінювання та пріоритезація 109
16.5 Рекомендації, комунікація та повторне тестування 109
16.6 Кейс: звітування за результатами тестування 110
Висновки до розділу 111
Питання для самоперевірки 111

17 Професійний розвиток та управління програмою тестування 113
17.1 Професійні компетентності 113
17.2 Сертифікація та навчання 114
17.3 Кар'єрні шляхи та етична зрілість 114
17.4 Побудова програми тестування 115
17.5 Зрілість програми та національний вимір 116
17.6 Кейс: побудова програми тестування 116
Висновки до розділу 117
Питання для самоперевірки 118

Список використаних джерел 119

Додатки 127
Додаток А. Короткий словник ключових термінів 127
Додаток Б. Етапи тестування на проникнення 128
Додаток В. Чек-лист етичної та правової готовності 128

Перелік умовних скорочень

ЗВ	звіт про тестування
КК	Кримінальний кодекс України
ОС	операційна система
ПЗ	програмне забезпечення
ТнП	тестування на проникнення
ATT&CK	Adversarial Tactics, Techniques, and Common Knowledge (MITRE)
C2	Command and Control (сервер керування)
CVE	Common Vulnerabilities and Exposures
CVSS	Common Vulnerability Scoring System
CTF	Capture the Flag
DNS	Domain Name System
IoC	Indicator of Compromise (індикатор компрометації)
MITM	Man-in-the-Middle
NIST	National Institute of Standards and Technology
OSINT	Open-Source Intelligence (розвідка з відкритих джерел)
OSSTMM	Open Source Security Testing Methodology Manual
OWASP	Open Worldwide Application Security Project
PTES	Penetration Testing Execution Standard
RoE	Rules of Engagement (правила взаємодії)
SIEM	Security Information and Event Management
SOC	Security Operations Center (центр безпеки)
SQLi	SQL Injection
TTP	Tactics, Techniques, and Procedures
VPN	Virtual Private Network
WSTG	Web Security Testing Guide (OWASP)
XSS	Cross-Site Scripting

Вступ

Тестування на проникнення та етичний хакінг — авторизована, контрольована імітація дій зловмисника з метою виявити й усунути слабкості захисту *до* того, як ними скористаються справжні атакувальники. Це один із найдієвіших способів перевірити реальну, а не задекларовану захищеність інформаційної системи: він показує не те, що *має* працювати згідно з документацією, а те, що насправді витримає цілеспрямовану атаку. У сучасному ландшафті загроз, де кібератаки стали інструментом злочинності, конкуренції й навіть ведення бойових дій, здатність професійно й етично оцінювати захищеність перетворилася з вузької спеціалізації на стратегічну компетентність, критичну для національної безпеки.

Ключове слово в назві цієї діяльності — *етичний*. Техніки, що їх застосовує фахівець із тестування на проникнення, і техніки зловмисника багато в чому збігаються; відрізняє їх *авторизація*, *мета* й *відповідальність*. Етичний хакер діє за явним письмовим дозволом власника системи, у погоджених межах, з метою посилити захист, і відповідально повідомляє про знайдене, не завдаючи шкоди. Ці межі — не формальність, а сама суть професії: без них та сама дія перетворюється з цінної послуги на кримінальний злочин. Тому правові та етичні засади проходять крізь увесь посібник як наскрізна лінія, а не як окремий розділ.

Цей навчальний посібник призначено для здобувачів другого (освітнього) рівня вищої освіти , а також для науковців і фахівців-практиків. Його мета — сформувати цілісне, системне розуміння методології авторизованого тестування на проникнення: не набору «трюків», а структурованого, повторюваного, етичного й науково обґрунтованого процесу оцінювання захищеності. Виклад свідомо зосереджено на *методології*, *захисних висновках* і *професійній практиці*; посібник не є збіркою готових засобів атаки й не навчає протиправних дій, натомість формує компетентність, потрібну для легітимного зміцнення захисту.

Структурно посібник побудовано за логікою реального процесу тестування. Перші розділи закладають фундамент: поняття й види тестування (розділ 1), правові та етичні засади (розділ 2), методології та стандарти (розділ 3), планування й визначення обсягу робіт (розділ 4). Центральна частина відтворює етапи тестування: розвідку й збір інформації (розділ 5), сканування та ідентифікацію (розділ 6), аналіз і оцінювання вразливостей (розділ 7), контрольовану експлуатацію (розділ 8), постексплуатацію й підвищення привілеїв (розділ 9), бокове переміщення та закріплення (розділ 10).

Наступні розділи розглядають тестування специфічних середовищ: вебзастосунків (розділ 11), безпроводових і мобільних систем (розділ 12), мережевої інфраструктури та хмари (розділ 13), а також соціальну інженерію й фізичне тестування (розділ 14). Завершальні розділи піднімаються на рівень організації й професії: red/purple teaming та емуляцію супротивника (розділ 15), звітування й комунікацію результатів (розділ 16), професійний розвиток і управління програмою тестування (розділ 17).

Крізь увесь посібник проходить кілька наскрізних ідей. Перша — верховенство *авторизації та етики*: жодна техніка не застосовується поза погодженими межами. Друга — тестування як *структурований процес*, а не хаотичний «злом»: цінність дає методологія, повторюваність і документованість. Третя — кінцева мета тестування не «зламати», а *посилити захист*: найцінніший продукт — не факт проникнення, а звіт із придатними до дії рекомендаціями. Четверта — тестування як складова ширшого циклу безпеки, що взаємодіє з розробкою, моніторингом і реагуванням. П'ята — відповідальність фахівця, подвійна за своєю природою: технічна (компетентно виявити ризики) та етико-правова (діяти в межах закону й дозволу).

Кожен розділ супроводжується теоретичним викладом, ілюстраціями, таблицями, формалізованими моделями, практичним кейсом і переліком запитань для самоперевірки, зокрема дослідницьких завдань для самостійної наукової роботи. Практичні навички слід відпрацьовувати виключно на спеціальних навчальних полігонах, у лабораторіях і середовищах CTF або з явного письмового дозволу власника системи. Наприкінці наведено єдиний список використаних джерел.

Автор висловлює сподівання, що цей посібник стане надійною основою для підготовки висококваліфікованих, етичних і відповідальних фахівців з оцінювання захищеності, здатних зміцнювати кіберстійкість організацій і держави легітимними, професійними засобами.

РОЗДІЛ 1

Етичний хакінг і тестування на проникнення: поняття та місце

Тестування на проникнення (penetration testing) та **етичний хакінг** — авторизована, контрольована імітація дій зловмисника з метою виявити й усунути слабкості захисту до їх реального використання. Це емпіричний спосіб перевірити *фактичну*, а не задекларовану захищеність: він показує, що система насправді витримає цілеспрямовану атаку, а не лише те, що передбачено документацією. Визначальна риса — не технічний арсенал, що багато в чому збігається з інструментарієм зловмисника, а *авторизація*, *мета* й *відповідальність*, які перетворюють потенційно протиправну дію на цінну професійну послугу. Розділ розглядає понятєвий апарат, відмінність від суміжних видів оцінювання, види та класифікацію тестування, його місце в системі управління безпекою, обмеження методу й визначальну роль етики, і завершується кейсом визначення доцільного типу тестування. Матеріал закладає фундамент для правових засад (розділ 2) й методологій (розділ 3).

1.1 Поняттєвий апарат

Етичний хакінг [116] — застосування технік, тактик і процедур зловмисника з *дозволу* власника й з *метою* посилити захист. **Тестування на проникнення** [53] — структурований процес такої діяльності з визначеними етапами, обсягом і результатом. Ці поняття близькі: етичний хакінг — ширша категорія (спосіб мислення й підхід), тестування на проникнення — його формалізована, договірна реалізація. Спільне ядро — *наступальний* (offensive) погляд: оцінювати захист *очима атакувальника*, шукаючи не відповідність вимогам, а реальні шляхи компрометації.

Цей наступальний погляд — принципова цінність методу. Захисник мусить закрити *всі* шляхи, атакувальникові достатньо знайти *один*; ця асиметрія означає, що формальна відповідність вимогам не гарантує захищеності. Тестування на проникнення моделює саме мислення атакувальника, виявляючи той єдиний шлях, який пропустили захисні заходи, і тим доповнює аудити й оцінювання відповідності (розділ 3), що перевіряють наявність контролів, а не їх реальну стійкість [26].

1.2 Відмінність від суміжних видів оцінювання

Тестування на проникнення часто плутають із суміжними видами (табл. 1.1). *Сканування вразливостей* — автоматичне виявлення відомих слабкостей (широке, поверхневе, без підтвердження). *Оцінювання вразливостей* — систематичний пошук і аналіз слабкостей без їх використання. *Аудит відповідності* — перевірка наявності контролів проти стандарту. *Тестування на проникнення* — активне *підтвердження* експлуатовності й виявлення *ланцюгів* слабкостей. *Red teaming* (розділ 15) — прихована емуляція реального супротивника з перевіркою виявлення й реагування.

Таблиця 1.1 — Види оцінювання захищеності

Вид	Суть	Глибина
Сканування вразливостей	автоматичний пошук відомого	низька
Оцінювання вразливостей	аналіз без експлуатації	помірна
Аудит відповідності	наявність контролів	формальна
Тестування на проникнення	підтвердження експлуатовності	висока
Red teaming	емуляція супротивника	максимальна

Ключова відмінність тестування на проникнення — *підтвердження реального ризику*: не «тут є потенційна слабкість», а «цю слабкість можна використати, і ось наслідки». Це усуває невизначеність сканування (багато теоретичних знахідок без підтвердження) і дає пріоритезацію за доведеним, а не припущеним ризиком. Водночас тестування дорожче й вужче за обсягом, тому види оцінювання не конкурують, а доповнюють один одного в програмі безпеки.

1.3 Види та класифікація тестування

Тестування класифікують за кількома ознаками (табл. 1.2). За *обсягом знань* про ціль: **чорна скринька** (мінімум інформації — моделює зовнішнього зловмисника), **біла скринька** (повний доступ до інформації — максимальне покриття), **сіра скринька** (часткова інформація — баланс реалізму й ефективності). За *позицією*: зовнішнє (з-поза периметра) й внутрішнє (зсередини, моделює інсайдера чи вже скомпрометований вузол). За *ціллю*: мережеве, вебзастосунків, безпроводове, мобільне, соціальної інженерії, фізичне. За *обізнаністю* сторони захисту: з повідомленням чи приховане.

Таблиця 1.2 — Класифікація за обсягом знань

Тип	Знання про ціль	Що моделює
Чорна скринька	мінімальні	зовнішнього зловмисника
Сіра скринька	часткові	інсайдера з обмеженим доступом
Біла скринька	повні	максимальне покриття

Вибір типу — не технічна, а *стратегічна* ухвала, що залежить від мети. Чорна скринька реалістично моделює зовнішню загрозу, але за обмежений час досягає лише доступного ззовні; біла скринька за той самий бюджет дає повніше покриття, але менш реалістична. Співвідношення ефективності зручно виразити через покриття поверхні атаки за одиницю зусиль:

$$\eta = \frac{C_{\text{покрито}}}{E}, \tag{1.1}$$

де $C_{\text{покрито}}$ — частка перевіреної поверхні атаки, E — витрачені зусилля. Формула (1.1) формалізує компроміс: біла скринька максимізує η (знання спрямовує зусилля), чорна — реалізм ціною нижчого η. Тому для вичерпної перевірки обирають білу чи сіру скриньку, а для оцінки реальної зовнішньої загрози — чорну.

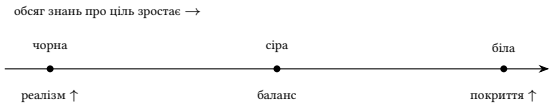


Рис. 1.1 — Спектр типів за обсягом знань: від реалізму (чорна) до покриття (біла)

1.4 Місце в системі управління безпекою

Тестування на проникнення — не самоціль, а складова ширшого циклу безпеки [47, 26]. Воно взаємодіє з *моделюванням загроз* (розділ 4), що спрямовує тестування на релевантні сценарії; з *розробкою* (виявлені вразливості живлять виправлення); з *моніторингом і реагуванням* (тестування перевіряє їх спроможність, особливо red teaming, розділ 15); з *управлінням ризиками* (підтверджений ризик пріоритезує заходи). Регулярне тестування — частина зрілого управління безпекою (ISO/IEC 27001 [80], PCI DSS [118] прямо вимагають його).



Рис. 1.2 — Місце тестування на проникнення в циклі безпеки

Кінцева мета тестування — *не* сам факт проникнення, а *посилення захисту*: найцінніший продукт — звіт із підтвердженими ризиками й придатними до дії рекомендаціями (розділ 16). Тестування, що «зламало» систему, але не привело до покращення захисту, не виконало призначення. Тому професійне тестування орієнтоване на результат для захисту, а не на демонстрацію майстерності.

Корисно розрізняти два способи мислення, що відповідають двом ролям. *Захисна* (blue) логіка мислить категоріями повноти: перекрити всі шляхи, виконати всі вимоги, покрити всі активи. *Наступальна* (red) логіка мислить категоріями достатності для атаки: знайти один робочий шлях, обійти, а не перемогти контроль, скористатися найслабшою ланкою. Цінність етичного хакера в тому, що він привносить наступальну логіку на службу захисту: дивиться на систему не як її будівельник (який знає, як вона *має* працювати), а як атакувальник (який шукає, як її *можна* зламати). Саме ця зміна перспективи виявляє припущення, які захисник вважав самоочевидними, — і які атакувальник радо спростує. Тому тестування на проникнення не замінює захисних заходів, а дає їм незамінний зовнішній, ворожий погляд, без якого сліпі плями лишаються непоміченими до реальної атаки.

1.5 Обмеження методу

Тестування на проникнення має принципові обмеження, які слід усвідомлювати. *Неповнота*: воно виявляє *наявність* шляхів компрометації, але не доводить їх *відсутності* — ненайдена вразливість не означає, що її немає (аналог обмеження Дейкстри для тестування ПЗ). *Миттєвість*: результат відображає стан на момент тестування; нові зміни й загрози можуть створити нові слабкості. *Залежність від виконавця*: глибина й повнота значною мірою визначаються кваліфікацією й часом. *Обмеженість обсягом*: поза погодженим обсягом слабкості лишаються неперевіреними.

Ці обмеження означають, що тестування — *необхідний, але не достатній* захід, який доповнює, а не замінює інші (безпечну розробку, моніторинг, навчання). Переоцінка результату («пройшли тест — отже захищені») небезпечна: відсутність знахідок може означати як високу захищеність, так і недостатню глибину тестування. Тому зрілий підхід трактує тестування як одне з джерел свідчень про захищеність, а не як вирок.

Цінність тестування зручно виразити через *підтверджений* ризик. Якщо сканування дає оцінку потенційного ризику слабкості з великою невизначеністю, то тестування на проникнення замінює ймовірність експлуатації на бінарно підтверджений факт. Очікувану цінність знахідки можна подати як

$$V = (I \cdot P_{\text{дов}}) - C_{\text{хиб}}\,(1 - P_{\text{дов}}), \tag{1.2}$$

де I — вплив у разі експлуатації, $P_{\text{дов}}$ — упевненість у реальності слабкості, $C_{\text{хиб}}$ — вартість реагування на хибну знахідку. Формула (1.2) пояснює, чому тестування на проникнення цінніше за саме сканування: воно підвищує $P_{\text{дов}}$ майже до одиниці (підтверджена експлуатація), усуваючи витрати на реагування на хибні знахідки й даючи достовірну пріоритезацію. Саме це перетворення невизначеного потенційного ризику на підтверджений і є головним економічним обґрунтуванням методу.

1.6 Визначальна роль етики

Те, що відрізняє етичний хакінг від злочину, — не техніка, а *авторизація, межі й відповідальність* [10]. Фахівець діє за явним письмовим дозволом, у погоджених межах, мінімізуючи шкоду, зберігаючи конфіденційність і відповідально повідомляючи про знайдене (розділи 2, 16). Ця дисципліна — не обмеження свободи, а сама суть професії: без неї та сама дія стає кримінальним правопорушенням (розділ 2). Професійна етика — наскрізна лінія всього посібника, а не окрема тема.

Важливий практичний наслідок: навички тестування відпрацьовують *виключно* на власних системах, спеціальних навчальних полігонах, у лабораторіях і середовищах CTF або з явного дозволу власника. Застосування тих самих технік поза авторизацією є протиправним незалежно від «добрих намірів». Відповідальність фахівця подвійна: технічна (компетентно виявити ризики, не завдавши шкоди) та етико-правова (діяти суворо в межах закону й дозволу).

1.7 Кейс: вибір типу тестування

Розглянемо вибір доцільного типу тестування для організації (відкриває наскрізний приклад посібника).

Крок 1. Визначення мети. З'ясовуємо, що саме треба оцінити: стійкість до зовнішньої атаки, ризик інсайдера, захищеність конкретного застосунку чи спроможність виявлення й реагування.

Крок 2. Вибір обсягу знань. Для оцінки реальної зовнішньої загрози обираємо чорну скриньку; для вичерпної перевірки критичного застосунку — білу чи сіру (1.1).

Крок 3. Вибір позиції й цілі. Визначаємо зовнішнє чи внутрішнє тестування, цільові системи (мережа, веб, безпроводове) за моделлю загроз (розділ 4).

Крок 4. Рівень прихованості. Для перевірки лише захищеності — відкрите тестування; для перевірки й спроможності виявлення — приховане (red teaming, розділ 15).

Крок 5. Узгодження з циклом безпеки. Погоджуємо, як результати живитимуть усунення вразливостей, моніторинг і управління ризиками (рис. 1.2), щоб тестування привело до реального посилення захисту.

Кейс демонструє, що вибір типу тестування — стратегічне рішення, похідне від мети й моделі загроз, а не від технічних уподобань; правильний вибір визначає цінність усієї подальшої роботи.

Висновки до розділу

Тестування на проникнення та етичний хакінг — авторизована імітація дій зловмисника для виявлення й усунення слабкостей, що перевіряє фактичну захищеність очима атакувальника. Їх визначальна риса — не техніка, а авторизація, мета й відповідальність. Наступальний погляд цінний через асиметрію захисту й атаки: формальна відповідність не гарантує стійкості. Тестування відрізняється від суміжних видів оцінювання (табл. 1.1) підтвердженням реального ризику, а класифікують його за обсягом знань (табл. 1.2), позицією, ціллю й прихованістю, причому вибір типу (1.1) є стратегічним рішенням. Тестування — складова циклу безпеки (рис. 1.2), що взаємодіє з моделюванням загроз, розробкою, моніторингом і управлінням ризиками, а його кінцева мета — посилення захисту, а не сам факт проникнення. Метод має принципові обмеження (неповнота, миттєвість, залежність від виконавця), тому є необхідним, але не достатнім. Головний висновок: тестування на проникнення — цінний емпіричний метод оцінювання захищеності, невіддільний від авторизації та етики й орієнтований на посилення захисту, що доповнює, а не замінює інші заходи безпеки.

Питання для самоперевірки

1. Що таке тестування на проникнення й етичний хакінг? Що відрізняє їх від дій зловмисника?
2. Чому наступальний погляд цінний? Поясніть асиметрію захисту й атаки.
3. Порівняйте види оцінювання захищеності (табл. 1.1). У чому ключова відмінність тестування на проникнення?
4. Чому підтвердження реального ризику важливіше за перелік потенційних слабкостей?

5. Класифікуйте тестування за обсягом знань (табл. 1.2), позицією, ціллю та прихованістю.
6. Поясніть формулу ефективності (1.1). Коли обирають чорну, а коли білу скриньку?
7. Яке місце посідає тестування в циклі безпеки (рис. 1.2)? З чим воно взаємодіє?
8. Чому кінцева мета тестування — посилення захисту, а не факт проникнення?
9. Назвіть принципові обмеження методу. Чому тестування є необхідним, але не достатнім?
10. Чому переоцінка результату тестування («пройшли — отже захищені») небезпечна?
11. У чому полягає визначальна роль етики? Чому межі — це суть, а не обмеження професії?
12. Де допустимо відпрацьовувати навички тестування? У чому подвійна відповідальність фахівця?
13. Опишіть вибір типу тестування (кейс підрозділу 1.7). Чому це стратегічне рішення?
14. Дослідницьке: обґрунтуйте вибір типу тестування для трьох різних організацій із різними моделями загроз і порівняйте очікувану ефективність (1.1).
15. Дослідницьке: проаналізуйте місце тестування на проникнення у вимогах обраного стандарту (ISO/IEC 27001, PCI DSS) та його зв’язок з іншими процесами безпеки.

РОЗДІЛ 2

Правові та етичні засади

Правові та етичні засади — не формальний додаток до технічної роботи, а її *передумова*: саме вони відрізняють етичний хакінг від кримінального правопорушення (розділ 1). Фахівець, який застосовує техніки тестування без належної авторизації й поза межами закону, вчиняє злочин незалежно від намірів. Тому компетентність у цих питаннях — обов'язкова частина професії, а не бажане доповнення. Розділ розглядає принцип авторизації як фундамент, законодавство України та міжнародний контекст, договірне оформлення й визначення меж, поводження з даними й мінімізацію шкоди, відповідальне розкриття вразливостей, професійну етику, і завершується кейсом правового оформлення тестування. Матеріал наскрізний для всього посібника: жодна техніка з наступних розділів не застосовується поза цими межами.

2.1 Авторизація як фундамент

Авторизація — явний, інформований, документований дозвіл власника системи на проведення тестування у визначених межах — є абсолютною передумовою будь-якої діяльності. Без неї дії фахівця юридично тотожні діям зловмисника. Авторизацію надає *власник* ресурсу (або належно уповноважена особа); дозвіл від третьої сторони, що не має прав на систему, недійсний. Для систем у хмарі чи в оренді може знадобитися окремий дозвіл провайдера, бо тестування зачіпає його інфраструктуру.

Авторизація має бути *письмовою*, *конкретною* (які системи, які дії, коли) і *попередньою* (до початку робіт). Усна згода чи «загальне розуміння» юридично ненадійні. Принцип простий і безкомпромісний: *немає письмової авторизації — немає тестування*. Це перше й найважливіше правило, порушення якого не виправдовується жодними технічними чи благими мотивами й веде до кримінальної відповідальності (розділ 2.2).

Легітимність конкретної дії зручно подати як логічну кон'юнкцію умов: дія етична й законна лише тоді, коли виконано *всі* передумови одночасно:

$$L = A \wedge S \wedge H \wedge D, \tag{2.1}$$

де A — наявність авторизації, S — перебування в межах погодженого обсягу, H — дотримання мінімізації шкоди, D — належне поводження з даними. Формула (2.1) підкреслює, що це *кон'юнкція*, а не диз'юнкція: хибність *будь-якої* умови робить усю дію нелегітимною ($L = 0$), скільки б ін-

ших умов не було виконано. Авторизована, але деструктивна поза згодою дія ($H = 0$) так само неприйнятна, як дія в межах обсягу без авторизації ($A = 0$). Ця проста модель — практичний орієнтир: перед кожною значущою дією фахівець подумки перевіряє всі чотири умови.

2.2 Законодавство України та міжнародний контекст

В Україні несанкціоноване втручання в роботу інформаційних систем є кримінальним правопорушенням за розділом XVI Кримінального кодексу [20, 45]: несанкціоноване втручання в роботу інформаційних (автоматизованих), електронних комунікаційних систем (ст. 361), несанкціоновані дії з інформацією (ст. 362), порушення правил експлуатації (ст. 363), перешкоджання роботі (ст. 363-1). Ключове слово — *несанкціоноване*: саме авторизація (розділ 2.1) переводить дію з-під дії цих статей. Діяльність регулюють також закони про кібербезпеку [12] та інформацію [11], а взаємодію з державними системами — вимоги технічного захисту інформації.

Міжнародний контекст важливий, бо тестування часто транскордонне (сісьлі в різних юрисдикціях). *Будапештська конвенція* [56] гармонізує кримінальне законодавство щодо кіберзлочинів; у США діє CFAA [139], у ЄС — відповідні директиви. Практичний наслідок: тестування системи, розташованої чи зареєстрованої в іншій юрисдикції, підпорядковане і її праву, тому обсяг і дозвіл мають це враховувати. Крім того, оброблення персональних даних під час тестування підпадає під законодавство про їх захист (в ЄС — GDPR [125]), що накладає окремі вимоги (розділ 2.4). Відповідні статті КК України узагальнено в табл. 2.1.

Таблиця 2.1 — Релевантні статті розділу XVI КК України (узагальнено)

Стаття	Предмет (узагальнено)
361	несанкціоноване втручання в роботу інформаційних систем
362	несанкціоновані дії з інформацією (заволодіння, зміна, знищення)
363	порушення правил експлуатації систем
363-1	перешкоджання роботі систем шляхом масового поширення повідомлень

2.3 Договірне оформлення та межі

Авторизація втілюється в *договорі* [8], що юридично фіксує умови (табл. 2.2): сторони й повноваження, *обсяг* (конкретні системи, адреси, застосунки — і що *поза* обсягом), дозволені й заборонені дії, часові вікна, канали екстреного зв'язку, поводження з даними, конфіденційність, відповідальність і обмеження, порядок передачі результатів. Окремо погоджують **правила взаємодії** (RoE, розділ 4) — технічні деталі проведення.

Таблиця 2.2 — Ключові елементи договору на тестування

Елемент	Призначення
Сторони й повноваження	хто авторизує, хто виконує
Обсяг (scope)	що дозволено й що поза межами
Дозволені/заборонені дії	межі технічних дій
Часові вікна	коли можна тестувати
Поводження з даними	захист виявленої інформації
Конфіденційність	нерозголошення результатів
Відповідальність	розподіл ризиків і обмежень

Чітке визначення *меж* критичне: дія в межах обсягу — легітимна послуга, та сама дія поза ним — правопорушення. Поширені пастки — «перехід» на суміжні системи, що не входять в обсяг (навіть ненавмисний), тестування систем третіх сторін (постачальників хмари), дії, що виходять за дозволене (деструктивні тести без згоди). Тому фахівець постійно звіряється з обсягом, а за виявлення, що ціль виходить за межі дозволеного, зупиняється й узгоджує подальші дії.

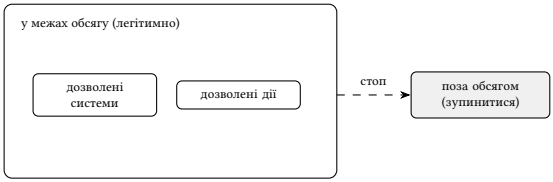


Рис. 2.1 — Межа обсягу: усередині — легітимні дії, назовні — зупинка й узгодження

2.4 Поводження з даними та мінімізація шкоди

Під час тестування фахівець неминуче отримує доступ до чутливої інформації (персональних даних, комерційних таємниць, облікових даних). Це накладає обов'язки [125]: *мінімізація* (отримувати лише необхідне для доведення ризику, не ексфільтрувати більше), *захист* (безпечне зберігання зібраного), *конфіденційність* (нерозголошення), *знищення* після завершення. Доводячи доступ до бази даних, етичний фахівець фіксує *факт* доступу й мінімальний доказ, а не викачує весь її вміст.

Принцип **мінімізації шкоди** — наскрізний: тестування не має порушувати роботу, знищувати дані чи створювати нові ризики. Деструктивні чи високоризикові дії (тести на відмову, зміна даних) виконують лише за явної окремої згоди й зазвичай у непродуктивному середовищі. Рівень

прийнятного ризику погоджують заздалегідь. Баланс між *реалістичністю* тестування й *безпечністю* для робочих систем — предмет окремого узгодження, а за сумніву перевагу віддають обережності.

Принцип мінімізації даних можна формалізувати як вимогу не перевищувати обсягу, необхідного для доведення ризику. Якщо $d_{\text{зібр}}$ — обсяг зібраних чутливих даних, а $d_{\text{дов}}$ — мінімальний обсяг, достатній для підтвердження вразливості, то етична вимога

$$d_{\text{зібр}} \leq d_{\text{дов}}, \tag{2.2}$$

вимагає зупинятися на мінімальному доказі. Формула (2.2) має практичний сенс: довівши доступ до бази персональних даних, фахівець фіксує кілька записів як доказ, а не викачує всю базу, бо кожен зайвий запис понад $d_{\text{дов}}$ — це непотрібний ризик для суб'єктів даних і для самого фахівця. Надмірний збір не підвищує цінності звіту, але різко підвищує правову та етичну відповідальність.

2.5 Відповідальне розкриття вразливостей

Виявлені вразливості підлягають **відповідальному** (скоординованому) розкриттю [81, 82]: приватне повідомлення власнику, узгоджений час на виправлення, і лише потім (за потреби й згодою) публічне розкриття. Це баланс між правом знати про ризик і потребою часу на усунення. Стандарти ISO/IEC 29147 (розкриття) та 30111 (оброблення) формалізують ці процеси. У контексті замовленого тестування розкриття зазвичай обмежене замовником (конфіденційність), а публічне — лише за його згодою.

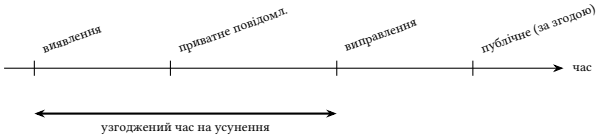


Рис. 2.2 — Часова шкала відповідального (скоординованого) розкриття

Окремий випадок — *несподівана* знахідка поза обсягом чи ознаки *стороннього* втручання (система вже скомпрометована). Етичний фахівець має заздалегідь погоджений порядок дій: негайно повідомити замовника, не поширювати інформацію, за потреби — сприяти реагуванню. Програми винагород за вразливості (bug bounty) інституціоналізують відповідальне розкриття з чіткими правилами, але участь у них так само вимагає дотримання оголошених меж — вихід за них позбавляє «етичного» статусу.

2.6 Професійна етика

Поза законом діяльність регулюють *професійні кодекси* [62, 10]: діяти лише в межах авторизації, не завдавати шкоди, зберігати конфіденційність, бути чесним щодо компетентності й результатів, не використовувати доступ у власних інтересах, сприяти підвищенню захищеності. Сертифікаційні органи (розділ 17) вимагають дотримання кодексів етики, а порушення веде до втрати сертифікації й репутації.

Етична зрілість — це здатність діяти правильно й *поза* чіткими правилами, у сірих зонах. Наприклад: виявлено критичну вразливість, що загрожує третім особам, але замовник не поспішає виправляти; знайдено докази протиправної діяльності самого замовника; технічна можливість перевищити обсяг заради «повнішого» результату. Такі ситуації не завжди мають однозначне правове рішення, і саме тут проявляється професійна зрілість: пріоритет — не технічний результат, а відповідальність, безпека людей і дотримання узгоджених меж. Довіра — головний капітал фахівця з тестування, і її втрата незворотна.

Практичним захистом у сірих зонах є *прозорість* і *документування*. Кожну значущу дію, особливо ту, що наближається до меж дозволеного, фахівець документує: що робив, коли, на підставі якого пункту авторизації. Такий журнал виконує подвійну функцію: технічну (відтворюваність результатів для звіту, розділ 16) і правову (доказ того, що дії були авторизованими й у межах обсягу). За спору чи інциденту саме документування відрізняє відповідального професіонала від недбалого виконавця. Тому дисципліна ведення журналу дій — не бюрократія, а елемент професійного самозахисту й доброчесності, що прямо випливає з кон'юнктивної природи легітимності (2.1): щоб довести, що всі умови виконано, їх виконання треба фіксувати.

2.7 Кейс: правове оформлення тестування

Розглянемо правове оформлення тестування для організації (продовження наскрізного прикладу).

Крок 1. Перевірка повноважень. Пересвідчуємося, що замовник є власником (або уповноваженим) усіх систем в обсязі; для орендованої/хмарної інфраструктури отримуємо згоду провайдера.

Крок 2. Договір і авторизація. Укладаємо договір (табл. 2.2) із письмовою авторизацією, обсягом, дозволеними й забороненими діями, відповідальністю й конфіденційністю [8].

Крок 3. Поводження з даними. Погоджуємо мінімізацію доступу до чутливих даних, їх захист, нерозголошення й знищення після завершення [125]; враховуємо юрисдикцію систем.

Крок 4. Розкриття й непередбачені ситуації. Узгоджуємо порядок відповідального розкриття (рис. 2.2), дії за знахідок поза обсягом і за ознак стороннього втручання.

Крок 5. Готовність. Проходимо чек-лист етичної та правової готовності (додаток В), переконуючись, що все узгоджено *до* початку технічних робіт.

Кейс демонструє, що правове оформлення передує будь-якій технічній дії: ретельно підготовлена авторизація захищає і замовника, і виконавця та є фундаментом усієї подальшої роботи.

Висновки до розділу

Правові та етичні засади — передумова, а не додаток до тестування: саме авторизація відрізняє етичний хакінг від злочину. Авторизація має бути письмовою, конкретною, попередньою й наданою власником; принцип безкомпромісний — немає авторизації, немає тестування. В Україні несанкціоноване втручання є кримінальним правопорушенням (ст. 361–363-1 КК), і лише авторизація виводить дію з-під цих статей; транскордонне тестування підпорядковане праву всіх відповідних юрисдикцій. Авторизація втілюється в договорі (табл. 2.2) з чітким визначенням обсягу й меж, вихід за які перетворює послугу на правопорушення. Поводження з даними вимагає мінімізації, захисту, конфіденційності й знищення, а наскрізний принцип мінімізації шкоди обмежує ризиковані дії. Вразливості підлягають відповідальному розкриттю (рис. 2.2), а професійна етика регулює діяльність поза чіткими правилами, у сірих зонах. Головний висновок: компетентність у правових та етичних питаннях є обов'язковою частиною професії, авторизація й межі — її фундамент, а довіра — головний і незворотний капітал фахівця з тестування на проникнення.

Питання для самоперевірки

1. Чому правові та етичні засади є передумовою, а не додатком до тестування?
2. Що таке авторизація? Якими мають бути її форма, конкретність і час? Хто її надає?
3. Сформулюйте безкомпромісний принцип авторизації. Чому усна згода ненадійна?
4. Як регулюється несанкціоноване втручання в Україні (ст. 361–363-1 КК)? Яке слово є ключовим?
5. Чому важливий міжнародний контекст? Як транскордонність впливає на тестування?
6. Назвіть ключові елементи договору на тестування (табл. 2.2). Чому критичне чітке визначення меж?

7. Які поширені пастки виходу за обсяг? Як діє фахівець за виявлення виходу цілі за межі?
8. Які обов'язки накладає доступ до чутливих даних? Поясніть принцип мінімізації.
9. Що таке мінімізація шкоди? Як узгоджують реалістичність і безпечність тестування?
10. Що таке відповідальне розкриття (рис. 2.2)? Як воно обмежене в замовленому тестуванні?
11. Як діяти за знахідок поза обсягом чи ознак стороннього втручання?
12. Що регулює професійна етика? У чому проявляється етична зрілість у сірих зонах?
13. Опишіть правове оформлення тестування (кейс підрозділу 2.7). Чому воно передує технічним роботам?
14. Дослідницьке: проаналізуйте правові вимоги до тестування на проникнення в Україні та порівняйте їх з однією іноземною юрисдикцією; визначте наслідки для транскордонних робіт.
15. Дослідницьке: розробіть шаблон договору й авторизації на тестування з повним переліком меж, обов'язків щодо даних і порядку розкриття для модельної організації.

РОЗДІЛ 3

Методології та стандарти тестування на проникнення

Професійне тестування — не хаотичний «злом», а *структурований, повторюваний, документований* процес (розділ 1). Цю структуру задають **методології** та **стандарти**, що визначають етапи, обсяг діяльності й критерії повноти. Вони перетворюють залежний від особи «мистецький» підхід на інженерну дисципліну з передбачуваною якістю, уможливлюють порівняння й повторюваність результатів і дають спільну мову для замовника й виконавця. Розділ розглядає значення методологій, провідні стандарти (PTES, OSSTMM, NIST SP 800-115, OWASP, ISSAF), концептуальні моделі (кіл-чейн, MITRE ATT&CK), узагальнену фазову модель процесу, вибір і комбінування методологій, і завершується кейсом добору методології. Матеріал спирається на поняття (розділ 1) та етику (розділ 2) й задає каркас для етапних розділів (5–10).

3.1 Значення методологій

Методологія розв'язує кілька проблем нестандартизованого тестування [32, 40]. *Повнота*: без структури легко пропустити цілі класи перевірок; методологія гарантує систематичне покриття. *Повторюваність*: різні виконавці за тією самою методологією дають порівнянні результати. *Якість*: етапи й критерії роблять глибину передбачуваною, а не випадковою. *Комунікація*: спільна термінологія й структура полегшують узгодження обсягу й розуміння звіту. *Довіра*: дотримання визнаного стандарту підвищує довіру замовника й може бути вимогою (PCI DSS [118]).

Водночас методологія — *каркас*, а не припис на кшталт покрокового рецепта. Вона задає *що* перевірити й у *якій* послідовності, лишаючи *як* на професійне судження. Сліпе дотримання методології без розуміння перетворює тестування на формальність; її цінність розкривається лише в поєднанні з компетентністю й адаптацією до конкретної цілі. Тому методології вивчають не щоб копіювати, а щоб мати перевірений каркас, який наповнюють експертизою.

Варто розрізняти методології *процесу* й методології *покриття*. Методології процесу (PTES, NIST) відповідають на питання «у якій послідовності й за якими правилами діяти» — вони структурують роботу від узгодження до звіту. Методології покриття (OWASP WSTG, MASTG) відповідають на питання «що саме перевірити в конкретному класі цілей» — вони дають вичерпні переліки перевірок для вебу чи мобільних застосунків. Концептуальні моделі (ATT&CK, кіл-чейн) відповідають на питання «проти чого за-

хищатися» — вони описують реальну поведінку супротивника. Ці три рівні ортогональні й доповнюють один одного: процес без покриття дає структуру без глибини, покриття без процесу — переліки без організації, а модель загроз без обох — розуміння без дії. Зрілий фахівець свідомо поєднує всі три рівні.

3.2 Провідні стандарти й методології

Існує кілька визнаних методологій із різним акцентом (табл. 3.1). **PTES** [138] — комплексний стандарт із семи фаз (від попередньої взаємодії до звітування), найпоширеніший загальний каркас. **OSSTMM** [75] — наукоподібна методологія з акцентом на вимірюваність і метрики безпеки. **NIST SP 800-115** [130] — державна настанова США, що структурує технічне оцінювання. **OWASP** [115, 110] — детальні настанови для вебзастосунків (WSTG) і мобільних (MASTG). **ISSAF** [108] — широкий, хоч і менш актуальний, каркас. Для фінансового сектору — TIBER-EU [64] (розвідувально-кероване red teaming).

Таблиця 3.1 — Провідні методології тестування

Методологія	Акцент	Застосування
PTES	повний процес, 7 фаз	загальне тестування
OSSTMM	вимірюваність, метрики	наукове оцінювання
NIST SP 800-115	технічне оцінювання	держсектор, основа
OWASP WSTG/MASTG	веб/мобільні деталі	застосунки
TIBER-EU	розвідувальне red team	фінансовий сектор

Методології не конкурують, а *доповнюють* одна одну за рівнем і сферою: PTES чи NIST дають загальний каркас процесу, OWASP — детальні технічні перевірки для вебу, OSSTMM — підхід до вимірювання. На практиці зрілий фахівець комбінує: загальний каркас для структури процесу плюс предметні настанови для конкретних цілей. Вибір залежить від сфери, вимог замовника й регуляторних зобов'язань.

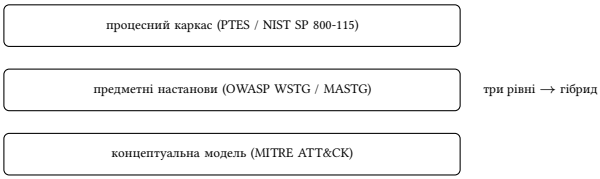


Рис. 3.1 — Пошарове комбінування методологій: процес, предметні настанови, концептуальна модель

Внесок методології у якість можна осмислити через *повноту покриття*. Якщо кожен застосований шар (процесний, предметний, концептуальний) незалежно покриває частку релевантних перевірок c_j, то частка *непокритих* перевірок

$$U = \prod_j (1 - c_j), \tag{3.1}$$

спадає з додаванням кожного незалежного шару. Формула (3.1) обґрунтовує пошаровий (гібридний) підхід: жоден окремий стандарт не покриває всього, але їх поєднання, що охоплює різні аспекти (процес, предметну специфіку, реальні техніки), різко зменшує прогалину. Це той самий принцип сукупності незалежних джерел, що проходить крізь усі посібники серії.

3.3 Концептуальні моделі

Поза процесними методологіями існують *концептуальні* моделі, що описують логіку атаки. **Ланцюг ураження** (cyber kill chain) [78] описує атаку як послідовність фаз (розвідка, озброєння, доставлення, експлуатація, встановлення, керування, дії на цілі); він допомагає структурувати як атаку, так і виявлення (розрив ланцюга на будь-якій фазі зупиняє атаку). **MITRE ATT&CK** [137, 14] — детальна матриця реальних тактик (навіщо) і технік (як) супротивників, що стала спільною мовою галузі.

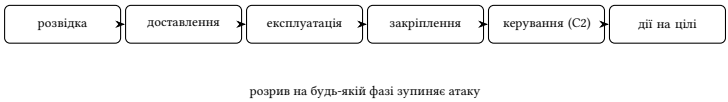


Рис. 3.2 — Ланцюг ураження: фази атаки й принцип розриву

ATT&CK особливо цінний для тестування: він дозволяє *планувати* тестування за релевантними техніками реальних угруповань, *вимірювати* покриття (які техніки перевірено) і *зіставляти* результати з виявленням сторони захисту (особливо в purple teaming, розділ 15). Покриття технік зручно оцінити часткою перевірених:

$$\mathrm{Cov}_{\text{ATT\&CK}} = \frac{|T_{\text{перевірено}}|}{|T_{\text{релевантні}}|} \in [0;1], \tag{3.2}$$

де $T_{\text{релевантні}}$ — техніки, актуальні для моделі загроз організації, $T_{\text{перевірено}}$ — перевірені під час тестування. Формула (3.2) робить повноту вимірюваною й спрямовує планування: пріоритет — техніки, що їх застосовують угруповання, релевантні саме цій організації, а не абстрактне «повне» покриття.

3.4 Узагальнена фазова модель

Попри відмінності, методології поділяють спільну *фазову* структуру (табл. 3.2), що відображає логіку реальної атаки: планування й узгодження → розвідка → сканування й ідентифікація → аналіз вразливостей → експлуатація → постексплуатація → звітування. Ця модель — каркас посібника: розділи 4–10 послідовно розкривають кожну фазу, а розділ 16 — звітування.

Таблиця 3.2 — Узагальнені фази тестування на проникнення

Фаза	Мета	Розділ
Планування	обсяг, правила, авторизація	4
Розвідка	збір інформації про ціль	5
Сканування	ідентифікація сервісів	6
Аналіз вразливостей	виявлення слабкостей	7
Експлуатація	підтвердження доступу	8
Постексплуатація	оцінка впливу	9, 10
Звітування	документування, рекомендації	16

Важлива властивість фазової моделі — *ітеративність*: вона не строго лінійна. Постексплуатація (отримання доступу до нового вузла) часто повертає до розвідки й сканування вже з нової позиції (бокове переміщення, розділ 10). Тому реальне тестування — це цикли фаз, що розгортаються в міру проникнення, а не одноразовий лінійний прохід. Фазова модель задає логіку, а не жорсткий порядок.

Корисно зіставити фазову модель тестування з моделями *захисту*. Фази атаки (а отже й авторизованого тестування) дзеркальні до можливостей сторони захисту: розвідку супротивника захисник прагне ускладнити й виявити, доставлення — заблокувати, експлуатацію — запобігти (гартування, патчі), закріплення й керування — виявити (моніторинг, розділ про виявлення), дії на цілі — стримати. Це дзеркало — основа *purple teaming* (розділ 15): кожну техніку, що її застосовує тестувальник, зіставляють із тим, чи виявив і чи зупинив її захист. Тому фазова модель корисна не лише для організації атаки, а й як каркас для оцінювання зрілості захисту: повнота покриття фаз тестуванням прямо показує, на яких етапах ланцюга захист сліпий. Саме це перетворює тестування з демонстрації вразливостей на діагностику стану оборони.

3.5 Вибір і комбінування методологій

Вибір методології залежить від кількох чинників: *сфери* (веб — OWASP, загальна мережа — PTES/NIST, фінанси — TIBER-EU), *вимог* замовника й регуляторів (PCI DSS, галузеві стандарти), *мети* (оцінювання захищеності — PTES; перевірка виявлення — ATT&CK-кероване red teaming), *зрілості* організації. Часто застосовують *гібридний* підхід: загальний процесний каркас (PTES) плюс предметні настанови (OWASP) плюс концептуальна модель для планування й вимірювання (ATT&CK).

Ключовий принцип: методологія служить *меті*, а не навпаки. Формальне дотримання стандарту без розуміння мети дає «галочки», а не цінність. Зрілий фахівець обирає й адаптує методологію під конкретне завдання, по-

єднуючи структуру (повнота, повторюваність) із гнучкістю (адаптація до цілі) та експертизою (професійне судження там, де методологія лишає свободу). Саме цей баланс структури й майстерності відрізняє професійне тестування від механічного.

3.6 Кейс: добір методології

Розглянемо добір методології для тестування (продовження наскрізного прикладу).

Крок 1. Визначення сфери й мети. З'ясовуємо об'єкт (мережа, вебзастосунок, уся організація) і мету (оцінювання захищеності чи перевірка виявлення), що визначає базовий вибір.

Крок 2. Процесний каркас. Обираємо загальний каркас (PTES чи NIST SP 800-115 [130]) для структури процесу й звітування.

Крок 3. Предметні настанови. Додаємо детальні настанови під цілі: OWASP WSTG для вебу, MASTG для мобільних, спеціалізовані — для безпроводового (розділи 11, 12).

Крок 4. Концептуальна модель. Для планування й вимірювання застосовуємо MITRE ATT&CK, визначаючи релевантні техніки й цільове покриття (3.2).

Крок 5. Адаптація. Налаштовуємо обраний гібрид під конкретну ціль і вимоги замовника, лишаючи простір для професійного судження в межах фаз (табл. 3.2).

Кейс демонструє, що методологія — це усвідомлено дібраний і адаптований каркас, а не механічно застосований шаблон: правильний добір забезпечує повноту й повторюваність, зберігаючи гнучкість для експертизи.

Висновки до розділу

Методології та стандарти перетворюють тестування з хаотичного «злому» на структурований, повторюваний, документований процес, забезпечуючи повноту, повторюваність, якість, комунікацію й довіру. Провідні методології (PTES, OSSTMM, NIST SP 800-115, OWASP, ISSAF, TIBER-EU; табл. 3.1) різняться акцентом і сферою та доповнюють одна одну. Концептуальні моделі — ланцюг ураження (рис. 3.2) і MITRE ATT&CK — описують логіку атаки; ATT&CK дає спільну мову, планування за релевантними техніками й вимірюване покриття (3.2). Методології поділяють спільну фазову структуру (табл. 3.2), що є каркасом посібника й ітеративна, а не строго лінійна. Вибір і комбінування залежать від сфери, вимог, мети й зрілості, причому методологія служить меті, а не навпаки. Головний висновок: методологія — це перевірений каркас, що його наповнюють компетентністю й адаптацією; професійне тестування поєднує структуру (повнота, повторюваність)

із майстерністю (судження, гнучкість), і саме цей баланс відрізняє його від механічного.

Питання для самоперевірки

1. Які проблеми нестандартизованого тестування розв'язує методологія?
2. Чому методологія — каркас, а не покроковий рецепт? Що дає сліпе її дотримання?
3. Порівняйте провідні методології (табл. 3.1) за акцентом і сферою. Чому вони доповнюють одна одну?
4. Що таке ланцюг ураження (рис. 3.2)? Як принцип розриву застосовують у захисті?
5. Що таке MITRE ATT&CK? Чому він цінний для планування й вимірювання тестування?
6. Поясніть покриття технік (3.2). Чому пріоритет — релевантні техніки, а не абстрактна повнота?
7. Опишіть узагальнену фазову модель (табл. 3.2). Чому вона ітеративна, а не лінійна?
8. Як постексплуатація повертає процес до ранніх фаз? Наведіть приклад.
9. Від чого залежить вибір методології? Що таке гібридний підхід?
10. Поясніть принцип «методологія служить меті». Чим небезпечне формальне дотримання стандарту?
11. Що відрізняє професійне тестування від механічного застосування методології?
12. Опишіть добір методології (кейс підрозділу 3.6). Як поєднують каркас, настанови й модель?
13. Яку роль відіграють методології у підвищенні довіри замовника й відповідності вимогам?
14. Дослідницьке: порівняйте дві методології (наприклад, PTES та OSSTMM) за структурою, повнотою й застосовністю до обраної цілі та обґрунтуйте вибір.
15. Дослідницьке: побудуйте карту покриття MITRE ATT&CK для модельної організації, визначивши релевантні техніки та цільове покриття (3.2).

РОЗДІЛ 4

Планування, визначення обсягу та правил взаємодії

Якість тестування визначається ще *до* першої технічної дії — на етапі планування. Невизначений обсяг, нечіткі правила чи хибна мета знецінюють навіть бездоганне технічне виконання: тестування може перевірити не те, що потрібно, вийти за дозволені межі (розділ 2) або не дати придатного до дії результату. **Планування** перетворює загальний запит замовника на конкретний, вимірюваний, авторизований і безпечний план робіт. Розділ розглядає попередню взаємодію й збір вимог, моделювання загроз як основу планування, визначення обсягу, правила взаємодії, управління ризиками проєкту й комунікацію, і завершується кейсом планування тестування. Матеріал спирається на правові засади (розділ 2) й методології (розділ 3) та передує технічним етапам (розділи 5–10).

4.1 Попередня взаємодія та збір вимог

Попередня взаємодія (pre-engagement) — узгодження з замовником *до* робіт [138, 128]. Ключові питання: *навіщо* тестування (мета — оцінити захищеність, виконати вимогу, перевірити виявлення), *що* тестувати (цілі), *як* (тип, глибина, прихованість), *коли* (вікна), *які обмеження* (недопустимі дії, критичні системи). Відповіді формують вимоги, що лягають в основу обсягу, правил і договору (розділ 2).

Критична частина — *узгодження очікувань*. Замовник часто має неявні припущення (наприклад, очікує «злому всього» за кілька днів або, навпаки, боїться будь-якого впливу на робочі системи). Фахівець з'ясовує реальну мету за запитом, пояснює можливості й обмеження методу (розділ 1), і узгоджує реалістичні очікування. Нечітко сформульована мета — головна причина незадоволення результатом, тому її проясненню приділяють особливу увагу: тестування задля «галочки» й тестування задля реального посилення захисту потребують різних підходів.

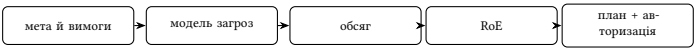


Рис. 4.1 — Конвеєр планування: від мети через модель загроз до авторизованого плану

4.2 Моделювання загроз як основа планування

Ефективне планування спирається на **моделювання загроз** [132, 27] — систематичне визначення того, *хто* й *навіщо* може атакувати організацію та

як. Воно відповідає на питання: які активи цінні, хто ймовірний супротивник (зовнішній зловмисник, інсайдер, конкурент, державне угруповання), які його можливості й мотиви, якими шляхами він діятиме. Методики — STRIDE [77] (категорії загроз), дерева атак [131] (декомпозиція цілі атаки на кроки).

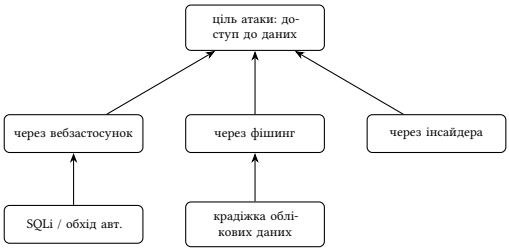


Рис. 4.2 — Дерево атак: декомпозиція цілі на альтернативні шляхи та кроки

Модель загроз спрямовує тестування на *релевантні* сценарії: немає сенсу вичерпно перевіряти малоймовірні вектори, нехтуючи ймовірними для цієї організації. Вона визначає, яких супротивників моделювати (а отже тип і техніки тестування, розділ 3), які активи й шляхи пріоритетні. Без моделі загроз тестування ризикує бути або надто широким (розпорошення зусиль), або нерелевантним (перевірка не тих загроз). Тому моделювання загроз — місток між бізнес-контекстом замовника й технічним планом тестування.

Практично модель загроз визначає й *профіль* тестувальника. Якщо релевантний супротивник — зовнішній опортуністичний зловмисник, тестування моделює зовнішню чорну скриньку з типовими техніками; якщо це досвідчене цілеспрямоване угруповання — потрібна глибша емуляція з прихованістю (red teaming, розділ 15); якщо головна загроза — інсайдер, тестування починають із позиції всередині (сіра скринька з обліковим записом рядового користувача). Невідповідність профілю тестувальника реальній моделі загроз знецінює результат: перевірка стійкості до зовнішнього сканера нічого не скаже про ризик кваліфікованого інсайдера. Тому модель загроз — не формальність на початку, а те, що визначає сам характер усієї подальшої роботи, від вибору типу (розділ 1) до технік кожного етапу.

4.3 Визначення обсягу

Обсяг (scope) [2] точно визначає, *що* входить у тестування: конкретні системи, мережі, адреси, домени, застосунки, облікові записи — і що *поза* межами. Чіткий обсяг критичний юридично (вихід за межі — правопорушення, розділ 2) і практично (фокус зусиль). Визначення обсягу балансує *повноту*

(ширший обсяг — повніша картина) і *ресурси* (час, бюджет обмежені): вузький обсяг дає глибину, широкий — охоплення, але поверхневе.

Таблиця 4.1 — Елементи визначення обсягу

Елемент	Зміст
Цілі (in-scope)	конкретні системи, адреси, домени, застосунки
Виключення (out-of-scope)	що тестувати заборонено
Типи дій	дозволені й заборонені техніки
Глибина	до якого рівня проникати (напр., без деструкції)
Дані третіх сторін	системи провайдерів, суміжні сервіси

Поширена складність — *розмитий периметр*: хмарні сервіси, спільна інфраструктура, інтеграції з третіми сторонами, тіньові активи (невраховані системи). Фахівець допомагає замовнику коректно окреслити межі, враховуючи, що деякі системи потребують окремого дозволу провайдера (розділ 2). Обсяг фіксують письмово з однозначними ідентифікаторами (адреси, домени), а не описово, щоб уникнути неоднозначності. За виявлення під час робіт активів, не врахованих в обсязі, їх *не* тестують без узгодження, а повідомляють замовнику.

Обсяг прямо впливає на потрібні *зусилля* й, отже, на реалістичність плану. Орієнтовно трудомісткість зростає з розміром обсягу та глибиною перевірки:

$$E \approx \sum_{k} n_k \cdot t_k \cdot d, \tag{4.1}$$

де n_k — кількість цілей k-го типу, t_k — типові витрати часу на одну ціль цього типу, d — множник глибини (поверхневе сканування проти глибокої ручної перевірки). Формула (4.1) допомагає узгодити обсяг із бюджетом: якщо оцінені зусилля перевищують доступний час, обсяг звужують або зменшують глибину *свідомо*, фіксуючи це в плані, а не мовчки залишають частину цілей недоперевіреними. Прозоре співвідношення обсягу, глибини й ресурсів захищає від головної пастки — нереалістичних очікувань, коли від кількох днів роботи чекають вичерпної перевірки великої інфраструктури.

4.4 Правила взаємодії

Правила взаємодії (RoE) [128] — технічні й організаційні умови проведення, що доповнюють обсяг (табл. 4.2): часові вікна (коли тестувати, щоб мінімізувати вплив на роботу), дозволені й заборонені техніки (наприклад, заборона тестів на відмову в продуктиві), обмеження інтенсивності, канали

екстреного зв'язку (щоб швидко зупинити роботи за інциденту), порядок дій за виявлення критичних проблем чи стороннього втручання, вимоги до прихованості (для red teaming), поводження з даними (розділ 2).

Таблиця 4.2 — Складові правил взаємодії (RoE)

Складова	Призначення
Часові вікна	мінімізація впливу на роботу
Дозволені техніки	межі допустимих дій
Обмеження інтенсивності	уникнення перевантаження
Канали зв'язку	швидка зупинка за інциденту
Порядок за критичних знахідок	дії за серйозних чи небезпечних знахідок
Прихованість	рівень обізнаності сторони захисту

RoE — запобіжник проти шкоди й непорозумінь. Наприклад, узгоджений канал екстреного зв'язку дозволяє негайно зупинити тестування, якщо воно ненавмисно впливає на критичний сервіс; погоджений порядок за критичних знахідок визначає, чи продовжувати експлуатацію чи негайно повідомити. Добре складені RoE захищають обидві сторони й роблять тестування передбачуваним, тому їх узгодженню приділяють не менше уваги, ніж технічній підготовці.

4.5 Управління ризиками проєкту та комунікація

Тестування саме несе *ризики* [43]: ненавмисний вплив на системи, витік чутливих даних, помилкове спрацювання засобів захисту, юридичні ризики. Управління ними [121, 67] передбачає ідентифікацію, оцінювання, пом'якшення (обмеження інтенсивності, тестування реплік замість продуктиву, резервні копії) і план реагування. Рівень прийнятного ризику погоджують із замовником заздалегідь.

Сукупний ризик проєкту зручно оцінити як суму за ідентифікованими ризиками:

$$R_{\text{проєкт}} = \sum_{i} P_i \cdot I_i, \tag{4.2}$$

де P_i — імовірність i-го ризику (наприклад, збою системи під навантаженням), I_i — його вплив. Формула (4.2) спрямовує пом'якшення на ризики з найбільшим добутком: наприклад, високий ризик збою критичної системи під час активного сканування виправдовує тестування репліки чи обмеження інтенсивності. *Комунікація* — наскрізна складова планування: визначають, хто, кого, як і коли інформує (регулярні статуси, негайні сповіщення про критичне, фінальний звіт), що робить проєкт прозорим і керованим.

4.6 Кейс: планування тестування

Розглянемо планування тестування для організації (продовження наскрізного прикладу).

Крок 1. Попередня взаємодія. З'ясовуємо реальну мету (оцінити стійкість до зовнішньої атаки), узгоджуємо очікування, пояснюємо можливості й обмеження методу.

Крок 2. Модель загроз. Будуємо модель загроз (рис. 4.2): ймовірний супротивник, цінні активи, ймовірні шляхи — що визначає релевантні сценарії й техніки (розділ 3).

Крок 3. Обсяг. Фіксуємо обсяг (табл. 4.1): конкретні зовнішні системи й домени, виключення, дозволені дії, глибину (без деструкції), враховуючи хмарні сервіси й потребу дозволу провайдера.

Крок 4. Правила взаємодії. Узгоджуємо RoE (табл. 4.2): вікна, обмеження інтенсивності, канали екстреного зв'язку, порядок за критичних знахідок, поводження з даними.

Крок 5. Ризики й комунікація. Оцінюємо ризики проєкту (4.2), плануємо пом'якшення (обмеження інтенсивності, резервні копії), визначаємо план комунікації й формат звіту (розділ 16).

Кейс демонструє, що ретельне планування перетворює загальний запит на конкретний, безпечний, релевантний і вимірюваний план, від якості якого залежить цінність усієї подальшої технічної роботи.

Висновки до розділу

Якість тестування визначається на етапі планування: невизначений обсяг чи хибна мета знецінюють бездоганне технічне виконання. Попередня взаємодія з'ясовує мету, цілі, глибину й обмеження та узгоджує реалістичні очікування, бо нечітка мета — головна причина незадоволення результатом. Моделювання загроз (рис. 4.2) є основою планування: воно спрямовує тестування на релевантні сценарії й пріоритетні активи, слугуючи містком між бізнес-контекстом і технічним планом. Обсяг (табл. 4.1) точно й письмово визначає цілі та виключення, балансуючи повноту й ресурси; розмитий периметр і тіньові активи потребують особливої уваги. Правила взаємодії (табл. 4.2) задають умови проведення й слугують запобіжником проти шкоди. Тестування несе ризики, якими управляють (4.2) через ідентифікацію, пом'якшення й план реагування, а наскрізна комунікація робить проєкт прозорим. Головний висновок: ретельне планування — визначення мети, моделі загроз, обсягу, правил і управління ризиками — є фундаментом цінного тестування, бо воно гарантує, що робота буде релевантною, безпечною, авторизованою й придатною до дії.

Питання для самоперевірки

1. Чому якість тестування визначається ще до першої технічної дії?
2. Що з'ясовують під час попередньої взаємодії? Чому узгодження очікувань критичне?
3. Що таке моделювання загроз? Як воно спрямовує планування тестування?
4. Поясніть дерево атак (рис. 4.2). Як модель загроз визначає релевантні сценарії?
5. Що таке обсяг (табл. 4.1)? Чому його чітке визначення критичне юридично й практично?
6. Як балансують повноту й ресурси при визначенні обсягу? Що таке розмитий периметр?
7. Що робить фахівець за виявлення активів поза обсягом? Чому обсяг фіксують однозначними ідентифікаторами?
8. Що таке правила взаємодії (табл. 4.2)? Як вони слугують запобіжником проти шкоди?
9. Наведіть приклад, як канал екстреного зв'язку й порядок за критичних знахідок захищають сторони.
10. Які ризики несе саме тестування? Поясніть оцінювання ризику проєкту (4.2).
11. Яку роль відіграє комунікація в проєкті тестування?
12. Опишіть планування тестування (кейс підрозділу 4.6). Як модель загроз пов'язує мету з технічним планом?
13. Чому нечітко сформульована мета є головною причиною незадоволення результатом?
14. Дослідницьке: побудуйте модель загроз і дерево атак для обраної організації та на їх основі сформуйте обсяг і пріоритетні сценарії тестування.
15. Дослідницьке: розробіть повний документ правил взаємодії (RoE) для модельного проєкту з оцінюванням ризиків (4.2) та планом їх пом'якшення.

РОЗДІЛ 5

Розвідка та збір інформації

Розвідка (reconnaissance) — перша технічна фаза тестування (розділ 3): збір інформації про ціль, що формує картину поверхні атаки й спрямовує всі подальші дії. Якість розвідки значною мірою визначає успіх тестування: ретельно зібрана інформація виявляє точки входу, яких не видно поверхнево, тоді як поспішна розвідка лишає сліпі зони. Водночас розвідка — найтихіша фаза: значну її частину (пасивну) можна провести, взагалі не торкаючись цілі. Розділ розглядає роль і типи розвідки, пасивний збір і OSINT, активну розвідку, побудову карти поверхні атаки, захисні висновки (зменшення сліду), і завершується кейсом розвідки в межах авторизованого тестування. Усі техніки застосовують виключно в межах погодженого обсягу (розділ 4) та авторизації (розділ 2).

5.1 Роль і типи розвідки

Розвідка переслідує мету — побудувати якомога повнішу картину цілі: які системи, сервіси, технології, люди, процеси утворюють її поверхню атаки. Розрізняють **пасивну** розвідку (збір без прямої взаємодії з ціллю — через відкриті джерела, сторонні сервіси) і **активну** (безпосередня взаємодія — запити до систем цілі). Пасивна непомітна для цілі й не несе юридичного ризику взаємодії, але обмежена доступним ззовні; активна дає точніші дані, але взаємодіє з ціллю (а отже входить в обсяг і може бути помічена).

Розвідка — це не разова фаза, а наскрізна діяльність: вона триває протягом усього тестування, збагачуючись із кожним новим доступом (постексплуатаційна розвідка, розділ 9). Принцип «розвідка перед дією» — фундаментальний: кожна подальша дія спирається на зібрану інформацію, і час, вкладений у розвідку, окупається ефективністю наступних фаз. Поспіх на цьому етапі — типова помилка початківця, що веде до розпорошення зусиль на хибних напрямах. Порівняння двох типів розвідки наведено в табл. 5.1.

Таблиця 5.1 — Пасивна та активна розвідка

Ознака	Пасивна	Активна
Взаємодія з ціллю	немає	є
Помітність	непомітна	лишає сліди
Юридичний ризик	мінімальний	входить в обсяг
Точність даних	обмежена	висока
Коли застосовують	завжди першою	для уточнення

5.2 Пасивний збір та OSINT

OSINT (open-source intelligence) [52, 24] — розвідка з відкритих, легально доступних джерел — є основою пасивного збору. Джерела (табл. 5.1): реєстраційні дані доменів та IP, DNS-записи, сертифікати, пошукові системи, вебсайти й кеші, соціальні мережі й професійні платформи (інформація про працівників, технології), витоки даних, метадані документів [54], репозиторії коду (випадково опубліковані секрети), новини й публічні реєстри. Інструменти агрегації й візуалізації зв'язків (на кшталт Maltego [117]) допомагають систематизувати зібране.

Таблиця 5.1 — Джерела OSINT

Джерело	Що дає
Реєстрація доменів/IP	власники, діапазони, контакти
DNS-записи	піддомени, сервіси, інфраструктура
Сертифікати	імена хостів, піддомени
Соцмережі, платформи	працівники, технології, процеси
Метадані документів	імена, ПЗ, внутрішні шляхи
Репозиторії коду	випадкові секрети, конфігурації

Цінність OSINT часто недооцінюють: значну частину інформації, потрібної для атаки, можна зібрати *легально й непомітно*, не торкаючись цілі. Випадково опублікований у репозиторії ключ, метадані з іменами працівників і внутрішнім ПЗ, перелік піддоменів із сертифікатів — усе це звужує простір пошуку й часто дає готові точки входу. Саме тому OSINT — не допоміжна, а ключова фаза, і саме тому її захисний бік (контроль власного цифрового сліду, розділ 5.5) такий важливий.

5.3 Активна розвідка

Активна розвідка взаємодіє з ціллю для уточнення картини: визначення «живих» вузлів, відкритих портів, доступних сервісів, базова ідентифікація технологій. Вона межує зі скануванням (розділ 6) — різниця радше в меті (розвідка будує карту, сканування деталізує сервіси) та інтенсивності. Ключові об'єкти: DNS (перелік піддоменів, типи записів [103]), діапазони адрес, базова доступність сервісів.

Активна розвідка *помітна*: взаємодія з ціллю лишає сліди в журналах і може спрацювати на засобах виявлення. Це має подвійне значення. Для *звичайного* тестування помітність зазвичай прийнятна (мета — знайти слабкості, а не лишитися непоміченим). Для *прихованого* (red teaming, розділ 15) активну розвідку проводять обережно, мінімізуючи сліди й розтягуючи в часі, бо її виявлення розкриває всю операцію. Тому рівень активності узгоджують із метою й правилами взаємодії (розділ 4).

5.4 Побудова карти поверхні атаки

Зібрану інформацію синтезують у **карту поверхні атаки** — структуроване подання всіх точок можливої взаємодії із ціллю: зовнішні сервіси, застосунки, домени, облікові записи, люди, технології. Ця карта — головний продукт розвідки, що спрямовує наступні фази: кожна точка — потенційний напрям для сканування (розділ 6) й аналізу (розділ 7).

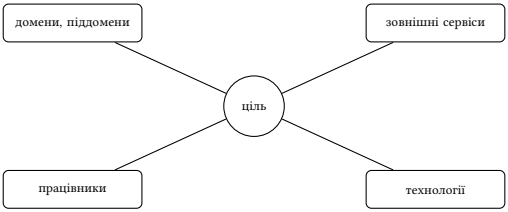


Рис. 5.1 — Карта поверхні атаки як синтез зібраної інформації

Повноту карти зручно характеризувати часткою виявленої поверхні від справжньої. Якщо позначити справжню поверхню атаки $A_{\text{повна}}$, а виявлену розвідкою — $A_{\text{вияв}}$, то повнота

$$\text{Recon} = \frac{A_{\text{вияв}}}{A_{\text{повна}}} \in [0;1], \tag{5.1}$$

визначає верхню межу покриття тестування: неможливо перевірити те, чого не виявлено. Формула (5.1) пояснює, чому ретельна розвідка критична: пропущений під час розвідки актив (забутий піддомен, тіньовий сервіс) лишається неперевіреним і стає саме тим шляхом, яким скористається справжній зловмисник. Тому розвідку ведуть систематично, прагнучи максимального $A_{\text{вияв}}$.

Водночас розвідка підпорядкована *спадній граничній віддачі*: перші зусилля дають багато (основні домени, очевидні сервіси), подальші — дедалі менше нового. Приріст виявленої поверхні за додаткові зусилля e наближено

$$\frac{dA_{\text{вияв}}}{de} \approx \alpha\, e^{-\beta e}, \tag{5.2}$$

де α, β — параметри, що залежать від цілі й методів. Формула (5.2) має практичний сенс: розвідку не можна вести нескінченно, і фахівець визначає момент достатності — коли подальший збір дає мало нового, а час доцільніше вкласти в наступні фази. Проте «мало нового» не означає «нічого важливого»: саме рідкісні, важкознаходжувані артефакти (забутий піддомен, прихований у метаданих слід) часто виявляються ключовими, тому баланс між повнотою й часом — предмет професійного судження, а не механічного ліміту.



Рис. 5.2 — Спадна гранична віддача розвідки й момент достатності

5.5 Захисні висновки: зменшення цифрового сліду

Розуміння розвідки дає прямі *захисні* висновки [17]: організація може й має *зменшувати* інформацію, доступну зловмиснику. Заходи: контроль публічних даних (мінімум зайвого в реєстрах, DNS, сертифікатах), гігієна репозиторіїв (жодних секретів у коді), очищення метадокументів, навчання працівників щодо публікацій у соцмережах, інвентаризація й усунення тіньових активів, моніторинг власного цифрового сліду (що про організацію можна дізнатися ззовні).

Цей захисний бік — приклад наскрізного принципу посібника: розуміння наступальних технік безпосередньо служить захисту. Фахівець, який знає, що й як збирає зловмисник, здатен порадити, що приховати чи усунути. Зменшення цифрового сліду не робить організацію невразливою, але *підвищує вартість* розвідки для зловмисника й зменшує поверхню атаки (5.1), звужуючи його можливості ще до активних дій. Тому звіт про тестування (розділ 16) типово містить рекомендації саме щодо надмірно відкритої інформації.

5.6 Кейс: розвідка в межах тестування

Розглянемо розвідку в межах авторизованого тестування (продовження наскрізного прикладу).

Крок 1. Пасивний збір. У межах обсягу (розділ 4) збираємо OSINT (табл. 5.1): домени й піддомени, DNS, сертифікати, публічну інформацію про технології та працівників — не торкаючись цілі.

Крок 2. Систематизація. Агрегуємо й візуалізуємо зв'язки, формуючи попередню карту поверхні атаки (рис. 5.1).

Крок 3. Активна розвідка. У межах дозволеного уточнюємо: живі вузли, доступні сервіси, базова ідентифікація — з рівнем активності за правилами взаємодії (прихованість за потреби).

Крок 4. Карта поверхні атаки. Синтезуємо повну карту, оцінюємо повноту розвідки (5.1), визначаємо пріоритетні напрями для сканування (розділ 6).

Крок 5. Захисні нотатки. Фіксуємо надмірно відкриту інформацію (випадкові секрети, зайві метадані, тіньові активи) для рекомендацій у звіті (розділ 16).

Кейс демонструє, що розвідка — фундамент тестування: вона будує карту поверхні атаки, що спрямовує всі подальші фази, і водночас одразу дає цінні захисні висновки щодо зменшення цифрового сліду.

Висновки до розділу

Розвідка — перша й наскрізна технічна фаза тестування, що будує картину поверхні атаки й спрямовує всі подальші дії; її якість значною мірою визначає успіх. Розрізняють пасивну розвідку (без взаємодії з ціллю, через відкриті джерела) та активну (взаємодія, помітна й така, що входить в обсяг). OSINT (табл. 5.1) — основа пасивного збору — дозволяє легально й непомітно зібрати значну частину потрібної інформації, тому є ключовою, а не допоміжною фазою. Активна розвідка уточнює картину ціною помітності, рівень якої узгоджують із метою й прихованістю. Зібране синтезують у карту поверхні атаки (рис. 5.1), повнота якої (5.1) визначає верхню межу покриття тестування, бо неперевіреним лишається невиявлене. Розуміння розвідки дає прямі захисні висновки — зменшення цифрового сліду, що підвищує вартість розвідки для зловмисника. Головний висновок: ретельна, систематична розвідка — фундамент ефективного тестування, бо час, вкладений у побудову повної карти поверхні атаки, окупається на всіх подальших фазах, а її захисний бік безпосередньо служить зміцненню оборони.

Питання для самоперевірки

1. Що таке розвідка й чому її якість визначає успіх тестування?
2. Порівняйте пасивну й активну розвідку за помітністю, юридичним ризиком і точністю даних.
3. Чому розвідка є наскрізною, а не разовою фазою? Поясніть принцип «розвідка перед дією».
4. Що таке OSINT? Назвіть основні джерела (табл. 5.1) та що дає кожне.
5. Чому цінність OSINT часто недооцінюють? Наведіть приклади легально й непомітно зібраної критичної інформації.
6. Чим активна розвідка відрізняється від сканування? Чому вона помітна й що це означає для прихованого тестування?

7. Що таке карта поверхні атаки (рис. 5.1)? Чому вона є головним продуктом розвідки?
8. Поясніть повноту розвідки (5.1). Чому пропущений актив стає шляхом для зловмисника?
9. Які захисні висновки випливають із розуміння розвідки? Назвіть заходи зменшення цифрового сліду.
10. Чому зменшення цифрового сліду підвищує вартість розвідки, хоч і не робить організацію невразливою?
11. Як розвідка пов'язана з наступними фазами (сканування, аналіз)?
12. Опишіть розвідку в межах тестування (кейс підрозділу 5.6). Як дотримують обсягу й правил взаємодії?
13. Чому поспіх на етапі розвідки є типовою помилкою?
14. Дослідницьке: проведіть пасивну OSINT-розвідку власної (навчальної) інфраструктури, побудуйте карту поверхні атаки та оцініть повноту (5.1) і надмірно відкриту інформацію.
15. Дослідницьке: розробіть програму зменшення цифрового сліду для модельної організації та оцініть, наскільки вона звужує доступну зловмиснику поверхню.

РОЗДІЛ 6

Сканування та ідентифікація

Після розвідки (розділ 5), що окреслила поверхню атаки, настає фаза **сканування** — активного дослідження цілей для точної ідентифікації живих вузлів, відкритих портів, доступних сервісів, їх версій та операційних систем. Сканування перетворює загальну карту на детальний технічний профіль, що безпосередньо живить аналіз вразливостей (розділ 7). Це активна, помітна фаза, тому її проводять суворо в межах обсягу (розділ 4) з урахуванням вимог прихованості. Розділ розглядає виявлення вузлів, сканування портів, ідентифікацію сервісів і ОС, точність і час сканування, виявлення сканування стороною захисту, і завершується кейсом. Усі дії — виключно в межах авторизації (розділ 2).

6.1 Виявлення вузлів

Перший крок — **виявлення вузлів** (host discovery): визначення, які адреси в діапазоні цілі «живі» (відповідають). Методи спираються на різні протоколи й типи запитів, бо вузли можуть по-різному реагувати (деякі не відповідають на одні типи запитів, але відповідають на інші). Мета — скласти перелік активних цілей, щоб зосередити подальше сканування на них, а не витрачати час на неіснуючі адреси. Інструменти (на кшталт Nmap [90]) автоматизують це різними техніками.

Виявлення вузлів балансує *повноту* (не пропустити живий вузол) і *помітність* (кожен запит лишає слід). Фаєрволи й фільтри можуть приховувати вузли (блокуючи певні запити), тому єдиний метод дає неповну картину; комбінування методів підвищує повноту ціною помітності. Для прихованого тестування виявлення ведуть обережно, для звичайного — повніше. Результат — уточнений перелік живих цілей, що звужує подальшу роботу.

6.2 Сканування портів

Сканування портів визначає, які мережеві порти (а отже сервіси) відкриті на вузлі. Воно спирається на поведінку транспортних протоколів [120]: відкритий, закритий і фільтрований порти по-різному реагують на запити. Розрізняють повне встановлення з'єднання (надійне, але помітне й повільніше) та напіввідкрите сканування (швидше, тихіше). UDP-сканування складніше через природу протоколу (відсутність підтвердження). Масштабні сканери (на кшталт Masscan [69]) працюють на високій швидкості для великих діапазонів.

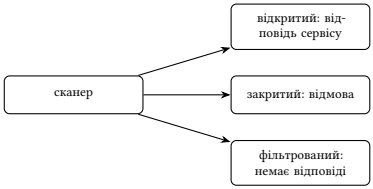


Рис. 6.1 — Три типові реакції порту на запит сканера

Інтерпретація результатів потребує розуміння: *фільтрований* порт (немає відповіді) неоднозначний — він може бути закритий фаєрволом, або вузол недоступний. Тому сканування дає картину з невизначеністю, яку уточнюють повторними й різними запитами. Ключовий продукт — перелік відкритих портів на кожному вузлі, що вказує на доступні сервіси — наступні цілі для ідентифікації та аналізу. Основні методи сканування портів зіставлено в табл. 6.1.

Таблиця 6.1 — Методи сканування портів

Метод	Принцип	Властивість
Повне з'єднання	встановлення повного з'єднання	надійне, помітне
Напіввідкрите	без завершення з'єднання	швидше, тихіше
UDP-сканування	запити без підтвердження	повільне, неоднозначне
Масове	висока швидкість, великі діапазони	охоплення ціною точності

6.3 Ідентифікація сервісів та ОС

Відкритий порт сам по собі мало говорить — важливо, *який сервіс* і *якої версії* за ним. **Ідентифікація сервісів** (service/version detection) визначає це за відповідями сервісу (банери, характерні реакції). **Ідентифікація ОС** (OS fingerprinting) [88, 18] визначає операційну систему за непрямими ознаками реалізації стеку протоколів (особливості відповідей, що різняться між ОС). Точна ідентифікація критична, бо саме версія сервісу зіставляється з відомими вразливостями (розділ 7).

Ідентифікацію можна вести *активно* (надсилання запитів і аналіз відповідей — точніше, помітніше) або *пасивно* (аналіз трафіку без запитів — тихіше, обмеженіше). Окремо існують сервіси пошуку вже просканованих у глобальному масштабі систем (на кшталт Shodan [92]), що дозволяють пасивно отримати інформацію про доступні ззовні сервіси цілі. Точність

ідентифікації не абсолютна: сервіси можуть маскувати версії, а ознаки — збігатися, тому результат трактують як ймовірний, а не достовірний.

Практична важливість точної ідентифікації випливає з того, що вона є *містком* до аналізу вразливостей (розділ 7). Твердження «відкритий порт 443» саме по собі не дає нічого; твердження «вебсервер конкретного продукту версії X на цьому порту» дозволяє зіставити його з базами відомих вразливостей (CVE) саме для цієї версії. Тому помилка ідентифікації дорого коштує: хибно визначена версія веде до перевірки нерелевантних вразливостей (хибнопозитивні напрями) або до пропуску реальних (хибнонегативні). Звідси випливає професійна дисципліна: ідентифікацію *підтверджують* кількома незалежними ознаками, а за неоднозначності фіксують невизначеність, а не видають здогад за факт. Ця обережність прямо впливає на якість подальшого аналізу й достовірність звіту, бо вся наступна робота будується на припущенні про те, *що* саме перед нами.

6.4 Точність та час сканування

Сканування — компроміс між *повнотою*, *точністю*, *швидкістю* й *помітністю*. Повне сканування всіх портів усіх вузлів усіма методами найповніше, але повільне й помітне; вибіркове — швидше, але ризикує пропустити. Точність обмежена хибними результатами: *хибнопозитивні* (порт здається відкритим, а сервіс недоступний) і *хибнонегативні* (відкритий порт не виявлено через фільтрацію чи втрату пакета).

Надійність виявлення відкритого порту зручно підвищити повторними спробами. Якщо одна спроба виявляє відкритий порт з імовірністю p (через можливі втрати пакетів), то за k незалежних спроб імовірність виявлення

$$P_{\text{вияв}} = 1 - (1 - p)^k, \tag{6.1}$$

зростає з кількістю спроб. Формула (6.1) обґрунтовує повторне сканування ненадійних цілей: за $p = 0{,}8$ одна спроба пропускає 20% випадків, а три спроби — менш як 1%. Водночас кожна додаткова спроба підвищує помітність, тому кількість спроб балансують із вимогою прихованості. *Час* сканування регулюють шаблонами інтенсивності: швидше — помітніше й ризикує перевантажити ціль; повільніше — тихіше, але довше. Тривалість сканування оцінюють як

$$T_{\text{скан}} \approx \frac{N_{\text{вузл}} \cdot N_{\text{порт}} \cdot k}{r}, \tag{6.2}$$

де $N_{\text{вузл}}$ — кількість вузлів, $N_{\text{порт}}$ — портів на вузол, k — кількість спроб (6.1), r — швидкість (запитів за одиницю часу). Формула (6.2) показує прямий компроміс: підвищення надійності (більше k) чи охоплення (більше портів) збільшує час, а підвищення швидкості r скорочує його ціною

помітності й ризику перевантаження. Планування сканування — це усвідомлений вибір точки в цьому просторі за метою й правилами взаємодії (розділ 4). Компроміс чинників узагальнено в табл. 6.2.

Таблиця 6.2 — Компроміси інтенсивності сканування

Чинник	Швидке сканування	Повільне сканування
Час	малий	великий
Помітність	висока	низька
Ризик перевантаження	вищий	нижчий
Застосування	звичайне тестування	приховане (red team)

6.5 Виявлення сканування стороною захисту

Сканування — помітна активність, яку сторона захисту може *виявити* [84, 5]: численні запити до різних портів/вузлів з одного джерела за короткий час є характерним патерном. Засоби виявлення (IDS, аналіз аномалій) розпізнають сканування за інтенсивністю, послідовністю звернень, нетиповими запитами. Методи виявлення (наприклад, послідовне перевіряння гіпотез [84]) розрізняють сканування й легітимну активність за статистикою звернень.

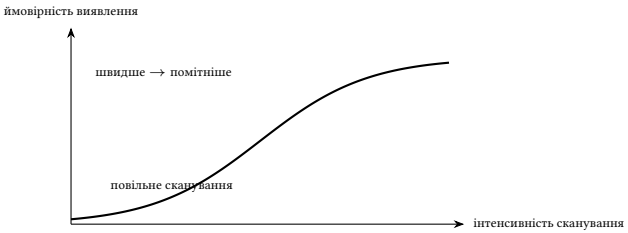


Рис. 6.2 — Зростання ймовірності виявлення сканування з його інтенсивністю

Це має подвійне значення. Для *тестувальника*: розуміння виявлення дозволяє керувати помітністю — розтягувати сканування в часі, розподіляти джерела, уникати нетипових запитів (для прихованого тестування). Для *захисту*: сканування — рання ознака підготовки атаки, тому його виявлення цінне для раннього реагування. Фахівець, який розуміє обидва боки, у звіті (розділ 16) оцінює не лише вразливості, а й *спроможність виявлення*: чи помітила сторона захисту сканування, і якщо ні — це само є висновком про сліпу зону моніторингу.

6.6 Кейс: сканування в межах тестування

Розглянемо сканування цілей, виявлених розвідкою (продовження наскрізного прикладу).

Крок 1. Виявлення вузлів. У межах обсягу визначаємо живі вузли серед діапазонів цілі, комбінуючи методи для повноти з урахуванням можливої фільтрації.

Крок 2. Сканування портів. Визначаємо відкриті порти на живих вузлах (рис. 6.1), інтерпретуючи фільтровані стани, з рівнем інтенсивності за правилами взаємодії.

Крок 3. Ідентифікація. Визначаємо сервіси, їх версії та ОС, уточнюючи ненадійні результати повторними спробами (6.1).

Крок 4. Профіль цілі. Синтезуємо детальний технічний профіль (вузли, порти, сервіси, версії, ОС), що живить аналіз вразливостей (розділ 7).

Крок 5. Оцінка помітності. Фіксуємо, чи виявила сторона захисту сканування (за погодженням із замовником), оцінюючи спроможність моніторингу для звіту (розділ 16).

Кейс демонструє, що сканування деталізує карту поверхні атаки до технічного профілю, придатного для аналізу вразливостей, і водночас перевіряє спроможність виявлення, даючи цінний висновок про зрілість моніторингу.

Висновки до розділу

Сканування — активна фаза, що перетворює загальну карту поверхні атаки на детальний технічний профіль: живі вузли, відкриті порти, сервіси, версії, ОС. Виявлення вузлів балансує повноту й помітність, комбінуючи методи через різну реакцію вузлів. Сканування портів спирається на поведінку протоколів (рис. 6.1) і дає картину з невизначеністю (фільтровані стани), яку уточнюють. Ідентифікація сервісів та ОС критична, бо версія зіставляється з відомими вразливостями, але її точність не абсолютна. Сканування — компроміс повноти, точності, швидкості й помітності; надійність виявлення підвищують повторними спробами (6.1) ціною помітності. Сторона захисту може виявити сканування, що має подвійне значення: керування помітністю для тестувальника й рання ознака атаки для захисту, а невиявлення сканування само є висновком про сліпу зону моніторингу. Головний висновок: сканування деталізує поверхню атаки до технічного профілю для аналізу вразливостей і водночас перевіряє спроможність виявлення, причому рівень активності й помітності узгоджують із метою та правилами взаємодії.

Питання для самоперевірки

1. Що таке сканування й чим воно відрізняється від розвідки? Що є його продуктом?
2. Що таке виявлення вузлів? Як воно балансує повноту й помітність і чому комбінують методи?
3. Що визначає сканування портів? На чому воно спирається? Що означає фільтрований стан (рис. 6.1)?
4. Чому результат сканування портів містить невизначеність? Як її уточнюють?
5. Що таке ідентифікація сервісів та ОС? Чому точна версія критична для аналізу вразливостей?
6. Порівняйте активну й пасивну ідентифікацію. Чому точність ідентифікації не абсолютна?
7. Якими чотирма чинниками є компроміс сканування? Як вони пов'язані?
8. Поясніть формулу виявлення порту (6.1). Чому повторне сканування підвищує надійність?
9. Як сторона захисту виявляє сканування? За якими ознаками?
10. Яке подвійне значення має виявлення сканування для тестувальника й для захисту?
11. Чому невиявлення сканування стороною захисту саме є висновком тестування?
12. Опишіть сканування в межах тестування (кейс підрозділу 6.6). Як узгоджують інтенсивність із правилами взаємодії?
13. Як сканування пов'язане з попередньою (розвідка) та наступною (аналіз вразливостей) фазами?
14. Дослідницьке: порівняйте повноту й помітність різних методів сканування на навчальному полігоні та оцініть, які виявляються засобами моніторингу.
15. Дослідницьке: дослідіть вплив кількості спроб (6.1) та інтенсивності сканування на надійність виявлення портів і ймовірність виявлення сканування стороною захисту.

РОЗДІЛ 7

Аналіз та оцінювання вразливостей

Детальний технічний профіль цілі (розділ 6) дозволяє перейти до **аналізу вразливостей** — виявлення й оцінювання конкретних слабкостей, що можуть бути використані. Ця фаза — місток між знанням *що* є в системі та знанням *як* це можна атакувати (розділ 8). Її якість визначає цінність тестування: пропущена вразливість лишає реальний ризик, а хибна знахідка витрачає ресурси й підриває довіру до звіту. Розділ розглядає джерела знань про вразливості, автоматизоване й ручне виявлення, оцінювання критичності (CVSS) та ризику, валідацію й усунення хибнопозитивних спрацювань, пріоритезацію, і завершується кейсом. Усі дії — у межах обсягу (розділ 4) та авторизації (розділ 2).

7.1 Джерела знань про вразливості

Аналіз спирається на систематизовані знання про вразливості. **CVE** [101] — єдиний каталог відомих вразливостей з унікальними ідентифікаторами. **CWE** [102] — класифікація типів слабкостей (переповнення, ін'єкції тощо). **NVD** [104] та інші бази збагачують CVE оцінками й деталями. **CVSS** [66] — стандарт оцінювання серйозності. Додаткові джерела: бюлетені виробників, бази експлойтів, каталог активно експлуатованих вразливостей (KEV [57]), оцінки ймовірності експлуатації (EPSS [83]).

Ці джерела дозволяють зіставити ідентифіковані сервіси та версії (розділ 6) з *відомими* вразливостями. Проте знання відомих вразливостей — лише частина аналізу: багато слабкостей специфічні для конкретної конфігурації, логіки застосунку чи їх поєднання і не мають CVE. Тому аналіз поєднує зіставлення з базами (широке, швидке) та експертне дослідження (глибоке, здатне виявити невідоме й специфічне). Опора лише на бази пропускає саме ті вразливості, що найцінніші для атаки, — унікальні для цілі. Основні джерела знань зведено в табл. 7.1.

Таблиця 7.1 — Джерела знань про вразливості

Джерело	Що дає
CVE	унікальні ідентифікатори відомих вразливостей
CWE	класифікація типів слабкостей
NVD	збагачені деталі та оцінки
CVSS	стандартна оцінка серйозності
KEV	вразливості, що активно експлуатуються
EPSS	оцінка ймовірності експлуатації

7.2 Автоматизоване та ручне виявлення

Сканери вразливостей [70] автоматизують зіставлення з базами: вони перевіряють сервіси на відомі вразливості за ознаками (версія, конфігурація, реакція). Їх перевага — *широта* й швидкість: за короткий час перевіряють тисячі відомих вразливостей. Недолік — *хибнопозитивні* спрацювання [59, 34] (повідомлення про неіснуючу вразливість) і *хибнонегативні* пропуски (невиявлення специфічних чи логічних вад). Сканери бачать відоме й типове, але не розуміють контексту.

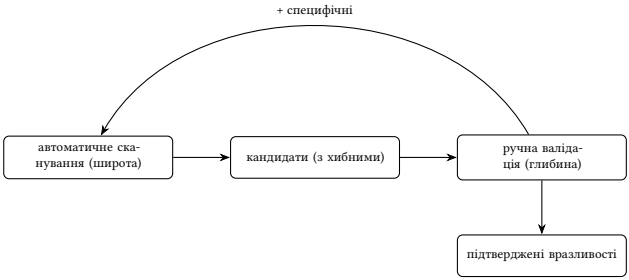


Рис. 7.1 — Поєднання автоматичного сканування (широта) й ручного аналізу (глибина)

Ручний аналіз доповнює автоматичний: експерт досліджує логіку, конфігурацію, специфічні для цілі слабкості, перевіряє (валідує) знахідки сканера, виявляє ланцюги. Він глибокий, але повільний. Оптимальний підхід — *поєднання* (рис. 7.1): сканер дає широке покриття відомого, експерт валідує й додає глибину. Опора лише на сканер дає «звіт сканера», а не тестування на проникнення; опора лише на ручний аналіз неефективна для широкого покриття. Професійне тестування використовує автоматизацію як інструмент, а не заміну експертизи.

7.3 Оцінювання критичності та ризику

Виявлені вразливості оцінюють за *критичністю*. **CVSS** [66, 15] дає стандартну числову оцінку (0–10) за базовими метриками (вектор доступу, складність, потрібні привілеї, взаємодія користувача, вплив на конфіденційність/цілісність/доступність). Це дозволяє порівнювати й пріоритезувати вразливості єдиною шкалою. Проте CVSS оцінює *серйозність* у відриві від контексту, а не *ризик* для конкретної організації.

Практична пріоритезація враховує ризик — добуток імовірності експлуатації та впливу на конкретний актив:

$$R = P_{\text{експл}} \cdot I_{\text{актив}}, \tag{7.1}$$

де $P_{\text{експл}}$ залежить від доступності, складності, наявності експлойтів (EPSS [83], KEV [57]), а $I_{\text{актив}}$ — від цінності активу для організації. Формула (7.1) пояснює, чому «критична» за CVSS вразливість на неважливому ізольованому активі може бути менш пріоритетною за «середню», але легко експлуатовну на критичному активі. Пріоритезація за ризиком, а не лише за CVSS, — ознака зрілого аналізу, що спрямовує обмежені ресурси усунення на справді важливе.

7.4 Валідація та хибнопозитивні спрацювання

Валідація — підтвердження реальності вразливості — критична складова аналізу. Автоматичні сканери дають багато *хибнопозитивних* спрацювань [34]: повідомлення про вразливість, якої насправді немає (через неточну ідентифікацію версії, наявність компенсаційних заходів, специфіку конфігурації). Невалідований звіт сканера знецінює тестування: замовник витрачає ресурси на неіснуючі проблеми й втрачає довіру.

Валідація підвищує достовірність звіту до того рівня, що відрізняє тестування на проникнення від сканування (розділ 1). Частку істинних серед повідомлених оцінюють показником:

$$\text{PPV} = \frac{V_{\text{істин}}}{V_{\text{істин}} + V_{\text{хибн}}}, \tag{7.2}$$

де $V_{\text{істин}}$ — підтверджені, $V_{\text{хибн}}$ — хибнопозитивні. Формула (7.2) підкреслює мету валідації: максимізувати частку істинних у звіті, бо кожна хибна знахідка підриває довіру й витрачає ресурси. Валідація не завжди означає повну експлуатацію — часто достатньо безпечного підтвердження наявності вразливості без деструктивних дій (розділ 2); спосіб валідації обирають за принципом мінімізації шкоди.

7.5 Пріоритезація

Виявлені й валідовані вразливості *пріоритезують* для усунення (табл. 7.2), бо ресурси замовника обмежені, і виправити все одразу неможливо. Пріоритет визначає ризик (7.1) з урахуванням контексту: критичність (CVSS), ймовірність експлуатації (EPSS, KEV), цінність активу, наявність компенсаційних заходів, вартість усунення. Ланцюги вразливостей (кілька дрібних, що разом дають компрометацію) оцінюють за сукупним впливом, а не окремо.

Таблиця 7.2 — Чинники пріоритезації вразливостей

Чинник	Вплив на пріоритет
Критичність (CVSS)	базова серйозність
Ймовірність експлуатації	активна експлуатація (KEV), EPSS
Цінність активу	важливість для організації
Компенсаційні заходи	знижують фактичний ризик
Вартість усунення	впливає на черговість, не на ризик

Якісна пріоритезація — головна цінність аналізу для замовника: вона перетворює перелік вразливостей на *план дій*, що спрямовує усунення на найважливіше. Звіт (розділ 16), що подає сотні знахідок без пріоритезації, малокорисний: замовник не знає, з чого почати. Тому зрілий аналіз завершується не переліком, а обґрунтованим ранжуванням за ризиком із рекомендаціями.

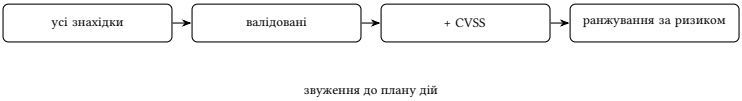


Рис. 7.2 — Від переліку знахідок через валідацію й оцінювання до плану дій за ризиком

Окремо наголосимо на ролі *контексту*, який автоматика принципово не бачить. Сканер не знає, що ця «критична» вразливість — на тестовому стенді без доступу до реальних даних, а ота «середня» — на шлюзі, через який проходить усе. Саме внесення контексту (цінність активу, досяжність, компенсаційні заходи, бізнес-наслідки) — внесок людини-аналітика, що перетворює стандартну оцінку серйозності на релевантну для цієї організації оцінку ризику (7.1). Тому пріоритезація не делегується інструменту: вона вимагає розуміння як технічної суті вразливості, так і бізнес-контексту замовника, і саме це поєднання робить аналітика незамінним.

7.6 Кейс: аналіз вразливостей цілі

Розглянемо аналіз вразливостей за результатами сканування (продовження наскрізного прикладу).

Крок 1. Зіставлення з базами. За ідентифікованими сервісами й версіями (розділ 6) зіставляємо з CVE/NVD [104], визначаючи кандидатів на відомі вразливості.

Крок 2. Автоматичне сканування. Запускаємо сканер вразливостей для широкого покриття відомого, отримуючи перелік кандидатів (із хибними) (рис. 7.1).

Крок 3. Ручний аналіз. Експертно досліджуємо специфічні для цілі слабкості (конфігурація, логіка), яких не бачить сканер, і виявляємо потенційні ланцюги.

Крок 4. Валідація. Безпечно підтверджуємо реальність знахідок, усуваючи хибнопозитивні (7.2), дотримуючись мінімізації шкоди.

Крок 5. Пріоритезація. Ранжуємо підтверджені вразливості за ризиком (7.1) з урахуванням контексту (табл. 7.2), формуючи обґрунтований план для звіту (розділ 16) та основу для експлуатації (розділ 8).

Кейс демонструє, що аналіз вразливостей — не механічне сканування, а поєднання автоматизації, експертизи, валідації й пріоритезації, що перетворює технічний профіль на достовірний, ранжований перелік реальних ризиків.

Висновки до розділу

Аналіз вразливостей — місток між знанням складу системи та знанням шляхів її атаки, а його якість визначає цінність тестування. Аналіз спирається на систематизовані знання (CVE, CWE, NVD, CVSS, KEV, EPSS), але опора лише на бази пропускає специфічні для цілі слабкості, тому поєднує зіставлення з базами й експертне дослідження. Автоматичні сканери дають широту ціною хибнопозитивних і хибнонегативних результатів, а ручний аналіз — глибину; оптимальним є їх поєднання (рис. 7.1), де автоматизація — інструмент, а не заміна експертизи. Критичність оцінюють за CVSS, але пріоритезують за ризиком (7.1) з урахуванням контексту. Валідація усуває хибнопозитивні спрацювання, підвищуючи достовірність звіту (7.2) до рівня, що відрізняє тестування від сканування, і здійснюється за принципом мінімізації шкоди. Пріоритезація (табл. 7.2) перетворює перелік на план дій — головну цінність для замовника. Головний висновок: якісний аналіз вразливостей поєднує автоматизацію, експертизу, валідацію й пріоритезацію за ризиком, даючи достовірний, ранжований перелік реальних ризиків, а не механічний звіт сканера.

Питання для самоперевірки

1. Чому аналіз вразливостей є містком між скануванням та експлуатацією? Чому його якість визначає цінність тестування?
2. Назвіть джерела знань про вразливості (CVE, CWE, NVD, CVSS, KEV, EPSS) та роль кожного.
3. Чому опора лише на бази відомих вразливостей недостатня?

4. Порівняйте автоматичне й ручне виявлення. Чому оптимальним є їх поєднання (рис. 7.1)?
5. Чому опора лише на сканер дає «звіт сканера», а не тестування на проникнення?
6. Що таке CVSS? Чому серйозність (CVSS) не дорівнює ризику?
7. Поясніть пріоритезацію за ризиком (7.1). Наведіть приклад, коли «критична» вразливість менш пріоритетна за «середню».
8. Що таке валідація? Чому невалідований звіт сканера знецінює тестування?
9. Поясніть показник PPV (7.2). Як валідація пов'язана з мінімізацією шкоди?
10. Які чинники визначають пріоритет вразливості (табл. 7.2)? Як оцінюють ланцюги?
11. Чому якісна пріоритезація — головна цінність аналізу для замовника?
12. Опишіть аналіз вразливостей (кейс підрозділу 7.6). Як поєднують автоматизацію та експертизу?
13. Чому звіт із сотнями знахідок без пріоритезації малокорисний?
14. Дослідницьке: порівняйте повноту й частку хибнопозитивних (7.2) результатів двох сканерів вразливостей на навчальному стенді та оцініть роль ручної валідації.
15. Дослідницьке: розробіть схему пріоритезації вразливостей за ризиком (7.1) з урахуванням CVSS, EPSS/KEV і цінності активу та застосуйте її до модельного переліку знахідок.

РОЗДІЛ 8

Контрольована експлуатація вразливостей

Експлуатація — використання виявленої вразливості для отримання доступу чи впливу — є фазою, що *підтверджує реальний ризик*: вона перетворює «тут є вразливість» на «цю вразливість справді можна використати з такими наслідками». Саме це підтвердження відрізняє тестування на проникнення від оцінювання вразливостей (розділ 1). Водночас експлуатація — найризикованіша фаза щодо можливої шкоди, тому її проводять *контрольовано*, з наголосом на мінімізації впливу (розділ 2). Розділ розглядає принципи й мету експлуатації, інструментарій, контрольованість і мінімізацію шкоди, надійність і ризики, демонстраційні сценарії (proof-of-concept), захисні висновки, і завершується кейсом. Виклад зосереджено на *методології* та *відповідальності*, а не на готових засобах атаки; усі дії — суворо в межах авторизації (розділ 2) й обсягу (розділ 4).

8.1 Принципи та мета експлуатації

Мета експлуатації в авторизованому тестуванні — *довести* ризик, а не завдати шкоди. Успішна експлуатація підтверджує, що вразливість (розділ 7) реальна й експлуатовна, і демонструє її наслідки (який доступ чи вплив вона дає). Це усуває невизначеність: замовник бачить не теоретичний ризик, а підтверджений факт із конкретними наслідками, що робить пріоритезацію (розділ 7) й усунення обґрунтованими.

Принципово важливо: *достатньо мінімального доведення*. Щоб підтвердити вразливість, не потрібно завдавати реальної шкоди — достатньо продемонструвати *можливість*. Якщо вразливість дає доступ до даних, доводять факт доступу мінімальним прикладом (розділ 2), а не викачують усе; якщо дає виконання коду — демонструють контрольований нешкідливий ефект, а не деструкцію. Цей принцип — наслідок мінімізації шкоди (8.1) й відрізняє професійну експлуатацію від вандалізму: мета — переконливий доказ за мінімального впливу.

8.2 Інструментарій

Експлуатацію підтримує інструментарій різного рівня. *Фреймворки* (на кшталт Metasploit [85]) надають структуроване середовище з модулями для відомих вразливостей, засобами доставлення й керування — вони стандартизують і прискорюють рутинну експлуатацію відомого. *Бази публічних експлойтів* [106] містять демонстраційний код для відомих вразливостей.

Спеціалізовані засоби й ручне розроблення застосовують для специфічних, складних чи нових вразливостей, де готових модулів немає.

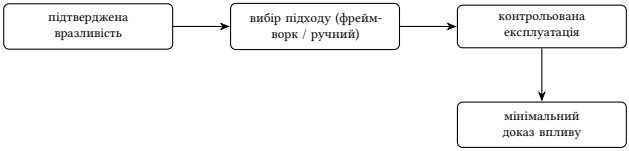


Рис. 8.1 — Від підтвердженої вразливості до контрольованого доказу впливу

Важливо розуміти: інструмент — не заміна розуміння. Запуск готового модуля без розуміння того, що він робить, небезпечний (може спричинити непередбачену шкоду) і непрофесійний. Публічні експлойти, завантажені з ненадійних джерел, можуть містити приховану шкідливу функцію, тому їх застосовують обережно, з розумінням коду, у контрольованому середовищі. Професійна експлуатація спирається на розуміння механізму вразливості (розділ 7), а інструмент лише автоматизує відоме — відповідальність за наслідки лежить на фахівцеві, а не на інструменті. Підходи до експлуатації зіставлено в табл. 8.1.

Таблиця 8.1 — Підходи до експлуатації

Підхід	Коли застосовують	Ризик
Фреймворк	відомі вразливості, рутина	контрольований
Публічний експлойт	відоме, за відсутності модуля	потребує перевірки
Ручне розроблення	специфічне, складне, нове	високий, потребує експертизи
Безпечне часткове	доведення без повної експлуатації	мінімальний

8.3 Контрольованість та мінімізація шкоди

Контрольованість — наскрізна вимога експлуатації [25]: фахівець має *передбачати* й *обмежувати* наслідки кожної дії. Перед експлуатацією оцінюють ризик впливу (чи може дія порушити роботу, пошкодити дані), обирають найменш ризиковані підходи, за потреби працюють у непродуктивному середовищі (репліці), мають план відкату. Деструктивні чи високоризикові дії виконують лише за явної окремої згоди (розділ 4).

Ризик шкоди від експлуатації зручно подати як добуток:

$$H = P_{\text{збою}} \cdot I_{\text{збою}}, \tag{8.1}$$

де $P_{\text{збою}}$ — імовірність негативного впливу дії (наприклад, падіння сервісу), $I_{\text{збою}}$ — його наслідки для замовника. Формула (8.1) спрямовує вибір: за високого H (ризикована експлуатація критичного сервісу) обирають безпечніший спосіб доведення, працюють з реплікою або узгоджують дію окремо. Мінімізація шкоди — не обмеження майстерності, а її ознака: майстерність полягає в тому, щоб довести ризик, нічого не зламавши. За сумніву щодо наслідків дію не виконують без узгодження — це практичне втілення принципу «не нашкодь» (розділ 2).

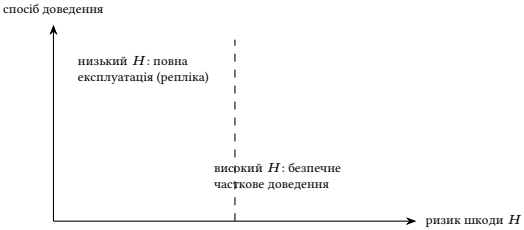


Рис. 8.2 — Вибір способу доведення залежно від ризику шкоди

8.4 Надійність та ризики експлуатації

Експлуатація не завжди *надійна*: та сама вразливість може експлуатуватися стабільно або лише за певних умов [135, 48]. Деякі експлойти ризикують порушити роботу цілі (особливо ті, що впливають на пам'ять). Надійність залежить від типу вразливості, захисних механізмів (розділ про пом'якшення в суміжних дисциплінах), конфігурації цілі. Ненадійний експлойт, застосований до робочої системи, — джерело ризику (може спричинити збій замість контрольованого доступу).

Тому перед застосуванням оцінюють *надійність* і *ризик* експлойта. Ненадійні чи ризиковані експлойти або не застосовують до робочих систем, або тестують спершу в репліці, або замінюють безпечнішим доведенням наявності вразливості без повної експлуатації. Це знову повертає до принципу: мета — *довести* ризик, а не будь-що «зламати». Часто безпечне часткове доведення (демонстрація можливості без повної експлуатації) цінніше за ризиковану повну експлуатацію, що загрожує роботі цілі.

Вибір між способами доведення можна формалізувати через співвідношення цінності й ризику. Якщо спосіб дає доказову цінність V (переконливість підтвердження) за ризику шкоди H (8.1), то раціональним є спосіб з найбільшою *чистою* цінністю:

$$U = V - \lambda H, \tag{8.2}$$

де λ — коефіцієнт несприйняття ризику, високий для робочих систем. Формула (8.2) пояснює, чому для критичних робочих систем (велике λ) часткове безпечне доведення часто перевершує повну експлуатацію: невеликий програш у доказовості V з лишком компенсується різким зниженням ризику H. І навпаки, у репліці чи ізольованому середовищі λ мале, тому допустима повніша експлуатація. Цей розрахунок — формальне відображення професійного судження, що завжди зважує доказову цінність проти потенційної шкоди.

8.5 Демонстраційні сценарії та захисні висновки

Результат експлуатації оформлюють як **демонстраційний сценарій** (proof-of-concept, PoC) [76, 37] — відтворюваний опис того, як вразливість було використано й з яким результатом. PoC має бути достатнім для *підтвердження й відтворення* (щоб замовник переконався й перевірив усунення), але не має бути готовою зброєю: демонструють *можливість* і *наслідки*, мінімізуючи деструктивний потенціал. Якісний PoC — основа переконливого звіту (розділ 16).

Кожна успішна експлуатація дає прямі *захисні* висновки (табл. 8.2): які заходи запобігли б їй (патч, конфігурація, сегментація, пом'якшення), які виявили б її (моніторинг). Фахівець не лише демонструє проникнення, а й пояснює, як його зупинити, — бо кінцева мета тестування — посилення захисту (розділ 1). Тому для кожної експлуатованої вразливості звіт містить не лише доказ, а й конкретні рекомендації з усунення та виявлення.

Таблиця 8.2 — Захисні висновки з експлуатації

Аспект	Захисний висновок
Запобігання	патч, безпечна конфігурація, пом'якшення
Обмеження впливу	сегментація, найменші привілеї
Виявлення	чи помітив моніторинг експлуатацію
Відновлення	спроможність відкотити наслідки

8.6 Кейс: контрольована експлуатація

Розглянемо контрольовану експлуатацію підтвердженої вразливості (продовження наскрізного прикладу).

Крок 1. Оцінка ризику дії. Для пріоритетної вразливості (розділ 7) оцінюємо ризик шкоди (8.1): чи може експлуатація порушити роботу, пошкодити дані.

Крок 2. Вибір підходу. Обираємо найменш ризикований спосіб доведення (рис. 8.1): безпечне часткове підтвердження за високого H, повну експлуатацію — лише за прийнятного ризику чи в репліці.

Крок 3. Контрольоване виконання. Виконуємо експлуатацію з розумінням механізму, передбачаючи наслідки, з планом відкату; за сумніву — узгоджуємо з замовником (розділ 4).

Крок 4. Мінімальний доказ. Демонструємо можливість і наслідки мінімальним прикладом (розділ 2), не завдаючи реальної шкоди, оформлюємо відтворюваний PoC.

Крок 5. Захисні висновки. Для кожної експлуатованої вразливості фіксуємо, що запобігло б їй і виявило б її (табл. 8.2), для рекомендацій у звіті (розділ 16); за потреби переходимо до постексплуатації (розділ 9).

Кейс демонструє, що контрольована експлуатація підтверджує реальний ризик за мінімального впливу й завжди супроводжується захисними висновками: майстерність полягає в тому, щоб переконливо довести ризик, нічого не зламавши.

Висновки до розділу

Експлуатація підтверджує реальний ризик, перетворюючи теоретичну вразливість на доведений факт із конкретними наслідками, що й відрізняє тестування на проникнення від оцінювання вразливостей. Її мета — довести, а не нашкодити, тому достатньо мінімального доведення можливості. Інструментарій (фреймворки, бази експлойтів, ручне розроблення) прискорює роботу, але не замінює розуміння: відповідальність за наслідки лежить на фахівцеві. Контрольованість — наскрізна вимога: ризик шкоди (8.1) оцінюють і мінімізують, обираючи безпечні підходи, репліки, план відкату, а деструктивні дії — лише за окремою згодою. Експлуатація не завжди надійна й може порушити роботу, тому ненадійні експлойти не застосовують до робочих систем. Результат оформлюють як відтворюваний PoC, що підтверджує, але не є зброєю, і кожна експлуатація дає захисні висновки (табл. 8.2). Головний висновок: контрольована експлуатація доводить реальний ризик за мінімального впливу, спирається на розуміння, а не на інструмент, і завжди орієнтована на захисні висновки; майстерність фахівця — переконливо довести ризик, нічого не зламавши.

Питання для самоперевірки

1. Що таке експлуатація й що вона підтверджує? Чому це відрізняє тестування від оцінювання вразливостей?
2. Чому мета експлуатації — довести, а не нашкодити? Що означає принцип мінімального доведення?
3. Який інструментарій підтримує експлуатацію? Чому інструмент не замінює розуміння?

4. Чому публічні експлойти з ненадійних джерел застосовують обережно?
5. Що таке контрольованість? Які заходи забезпечують мінімізацію шкоди?
6. Поясніть формулу ризику шкоди (8.1). Як вона спрямовує вибір способу експлуатації?
7. Чому мінімізація шкоди є ознакою майстерності, а не її обмеженням?
8. Чому експлуатація не завжди надійна? Чим ризикує ненадійний експлойт на робочій системі?
9. Коли безпечне часткове доведення цінніше за повну експлуатацію?
10. Що таке демонстраційний сценарій (PoC)? Чому він має підтверджувати, але не бути зброєю?
11. Які захисні висновки дає експлуатація (табл. 8.2)? Чому звіт містить рекомендації з усунення й виявлення?
12. Опишіть контрольовану експлуатацію (кейс підрозділу 8.6). Як обирають спосіб за ризиком шкоди?
13. Чому відповідальність за наслідки експлуатації лежить на фахівцеві, а не на інструменті?
14. Дослідницьке: на навчальному полігоні порівняйте надійність і ризик шкоди (8.1) різних способів підтвердження однієї вразливості та обґрунтуйте вибір найбезпечнішого.
15. Дослідницьке: розробіть методику оформлення відтворюваних PoC, що підтверджують вразливість за мінімального деструктивного потенціалу, та перелік захисних висновків для типових класів вразливостей.

РОЗДІЛ 9

Постексплуатація та підвищення привілеїв

Постексплуатація — дії після отримання початкового доступу (розділ 8): оцінювання *реального впливу* компрометації. Вона відповідає на ключове для замовника питання: «що саме зможе зробити зловмисник, отримавши цей доступ?». Початкове проникнення само по собі часто дає обмежений доступ; його справжня небезпека розкривається в тому, до чого він веде — підвищення привілеїв, доступ до цінних даних, можливість поширення (розділ 10). Водночас постексплуатація — фаза підвищеної відповідальності: фахівець уже *всередині* системи, тому дисципліна мінімізації шкоди (розділ 2) й документування стають критичними. Розділ розглядає мету й принципи постексплуатації, ситуаційну обізнаність, підвищення привілеїв, доступ до облікових даних, питання закріплення в авторизованому тестуванні, прибирання й відновлення, і завершується кейсом. Усі дії — суворо в межах авторизації.

9.1 Мета та принципи

Мета постексплуатації — *оцінити вплив*, а не «пограбувати» систему. Фахівець визначає, що дає отриманий доступ: які дані досяжні, які привілеї можна здобути, які інші системи стають доступними. Це перетворює факт проникнення на оцінку *бізнес-ризику*: доступ до тестового вузла без цінних даних — це одне, доступ, що веде до контролю над критичними системами, — зовсім інше. Саме постексплуатація показує справжню вагу початкової вразливості [33, 86].

Принципи постексплуатації підпорядковані меті й етиці. *Оцінювання, а не привласнення*: мета — довести можливість доступу, а не заволодіти даними (мінімізація, розділ 2). *Документування*: кожну дію й досягнутий доступ ретельно фіксують для звіту й для можливості відкату. *Мінімізація впливу*: дії не мають порушувати роботу чи змінювати дані без потреби й згоди. *Відстежуваність*: усі зміни (створені облікові записи, завантажені інструменти) фіксують для подальшого прибирання (розділ 9.5). Порушення цих принципів перетворює авторизоване тестування на завдання шкоди.

9.2 Ситуаційна обізнаність

Перший крок після отримання доступу — **ситуаційна обізнаність**: з'ясування, *де* опинився фахівець і *що* навколо. Це постексплуатаційна розвідка (розділ 5) вже зсередини: який це вузол, яка ОС і її версія, які права

має поточний обліковий запис, які процеси й сервіси запущені, яка мережа навколо, які інші системи досяжні, де цінні дані. Ця інформація визначає подальші можливості — чи потрібне підвищення привілеїв, чи можливе поширення, що є цінною ціллю.

Ситуаційна обізнаність — основа обґрунтованих рішень у постексплуатації. Без неї дії стають випадковими й ризикованими: фахівець може ненавмисно вплинути на критичний процес чи пропустити важливий шлях. Тому, як і на зовнішній розвідці, діє принцип «розуміння перед дією»: спершу зрозуміти оточення, потім діяти. Водночас постексплуатаційна розвідка так само має бути обережною: надмірна активність усередині може спрацювати на внутрішніх засобах виявлення (що, втім, для звичайного тестування є корисним висновком про спроможність моніторингу).

9.3 Підвищення привілеїв

Підвищення привілеїв (privilege escalation) [98, 23] — отримання вищих прав, ніж надає початковий доступ. Розрізняють *вертикальне* (від звичайного користувача до адміністратора/системного рівня) і *горизонтальне* (доступ до ресурсів іншого користувача того самого рівня). Шляхи: вразливості ОС і сервісів, помилки конфігурації (надмірні права, незахищені облікові дані, небезпечні налаштування), слабкі механізми контролю доступу. Підвищення привілеїв часто є ключовим кроком, бо воно різко збільшує вплив: адміністративний доступ дає контроль над вузлом, а доменний — над усією мережею. Типові шляхи й контрзаходи наведено в табл. 9.1.

Таблиця 9.1 — Шляхи підвищення привілеїв та контрзаходи

Шлях	Причина	Контрзахід
Вразливості ОС/сервісів	незакриті дефекти	своєчасні оновлення
Помилки конфігурації	надмірні права, слабкі налаштування	гартування, аудит
Незахищені облікові дані	паролі у файлах, пам'яті	керування секретами
Слабкий контроль доступу	неналежне розмежування прав	найменші привілеї

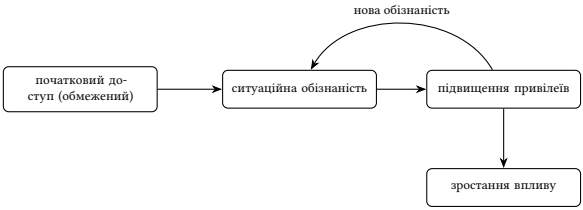


Рис. 9.1 — Цикл постексплуатації: обізнаність → підвищення привілеїв → зростання впливу

Зростання впливу з підвищенням привілеїв зручно виразити якісно: потенційний вплив зростає з рівнем здобутих прав і кількістю досяжних активів:

$$I = f(\text{рівень привілеїв}) \cdot N_{\text{досяжних активів}}, \tag{9.1}$$

де f — зростаюча функція рівня прав. Формула (9.1) пояснює, чому підвищення привілеїв критичне для оцінки ризику: воно множить і рівень контролю, і кількість досяжних активів. Для захисту це означає, що *обмеження* привілеїв (найменші привілеї) і сегментація (зменшення $N_{\text{досяжних активів}}$) — ключові заходи стримування: навіть за початкової компрометації вони різко обмежують I.

Ефект сегментації на стримування зручно виразити кількісно. Якщо без сегментації з одного вузла досяжні всі N активів, а сегментація обмежує досяжність часткою $\sigma \in (0; 1]$ активів у сегменті, то кількість досяжних із початкової точки активів

$$N_{\text{досяжних активів}} = \sigma \cdot N, \tag{9.2}$$

а отже й потенційний вплив (9.1) зменшується пропорційно σ. Формула (9.2) обґрунтовує, чому сегментація — один із найдієвіших заходів проти поширення (розділ 10): вона не запобігає початковій компрометації, але різко обмежує її наслідки, перетворюючи компрометацію одного вузла з

катастрофи на локалізований інцидент. Для тестувальника це означає, що оцінка впливу прямо залежить від того, наскільки добре сегментована мережа цілі, а це само є важливим висновком звіту.

9.4 Доступ до облікових даних та закріплення

Доступ до облікових даних [99, 58] — отримання паролів, ключів, токенів — особливо цінний для зловмисника, бо облікові дані дають *легітимний* доступ, який важко відрізнити від звичайного (а отже важко виявити) і який уможливлює поширення (розділ 10). Фахівець демонструє можливість доступу до облікових даних як критичний ризик, але поводиться з отриманим украй обережно (мінімізація, конфіденційність, розділ 2).

Питання **закріплення** (persistence) [97] в авторизованому тестуванні потребує особливої дисципліни. Зловмисник встановлює механізми для збереження доступу; фахівець може *продемонструвати* таку можливість, але будь-які створені механізми ретельно документує й *обов'язково* видаляє після завершення (розділ 9.5). Залишений бекдор чи незадокументований обліковий запис — серйозне порушення, що перетворює захисника на джерело ризику. Тому в авторизованому тестуванні закріплення — не мета, а демонстрація можливості під суворим контролем і з гарантованим прибиранням.

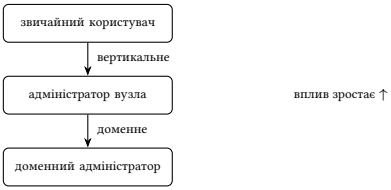


Рис. 9.2 — Сходи привілеїв: зростання контролю з кожним рівнем ескалації

9.5 Прибирання та відновлення

Прибирання (cleanup) [3] — відновлення стану систем після тестування — етична й договірна вимога (розділ 2). Усі внесені зміни (створені облікові записи, завантажені інструменти, механізми доступу, модифіковані налаштування) мають бути *повернуті* до початкового стану. Основа прибирання — ретельне *документування* кожної зміни під час робіт: не можна прибрати те, що не зафіксовано. Тому облік дій (розділ 2) — не лише доказ легітимності, а й передумова відновлення.

Таблиця 9.2 — Об'єкти прибирання після тестування

Об'єкт	Дія
Створені облікові записи	видалити
Завантажені інструменти	видалити
Механізми закріплення	видалити, перевірити відсутність
Змінені налаштування	повернути до початкових
Зібрані чутливі дані	захистити, згодом знищити

Прибирання має подвійну мету: *відновити* робочий і безпечний стан систем (не залишити нових ризиків) і *не перешкодити* подальшому розслідуванню (за потреби зберегти докази за погодженням). Фахівець не видаляє журнали й сліди власної активності без узгодження, бо це ускладнило б перевірку спроможності виявлення. Завершення тестування — це не лише звіт, а й підтверджене повернення систем у стан, не гірший за початковий, що є вимогою професійної відповідальності.

9.6 Кейс: постексплуатація та оцінка впливу

Розглянемо постексплуатацію після отриманого доступу (продовження наскрізного прикладу).

Крок 1. Ситуаційна обізнаність. Визначаємо, де опинилися: вузол, права, оточення, досяжні системи й дані — обережно, фіксуючи все (рис. 9.1).

Крок 2. Підвищення привілеїв. За наявності шляхів демонструємо підвищення привілеїв, оцінюючи зростання впливу (9.1), із мінімізацією впливу на систему.

Крок 3. Оцінка досяжного. Визначаємо, до яких цінних даних і систем веде доступ, доводячи вплив мінімальними прикладами (розділ 2), без привласнення даних.

Крок 4. Демонстрація ризиків. За потреби демонструємо можливість доступу до облікових даних і закріплення як критичні ризики, ретельно документуючи всі створені зміни.

Крок 5. Прибирання. Відновлюємо стан систем (табл. 9.2): видаляємо все створене, повертаємо налаштування, підтверджуємо відсутність залишків; захищаємо зібрані дані для подальшого знищення.

Кейс демонструє, що постексплуатація оцінює справжній вплив компрометації, перетворюючи факт проникнення на оцінку бізнес-ризику, і водночас є фазою найвищої відповідальності, де документування й прибирання критичні.

Висновки до розділу

Постексплуатація оцінює реальний вплив компрометації, відповідаючи на питання «що зможе зробити зловмисник із цим доступом», і перетворює факт проникнення на оцінку бізнес-ризику. Її принципи — оцінювання, а не привласнення; документування; мінімізація впливу; відстежуваність — підпорядковані меті та етиці. Ситуаційна обізнаність (розвідка зсередини) — основа обґрунтованих рішень за принципом «розуміння перед дією». Підвищення привілеїв (рис. 9.1) різко збільшує вплив (9.1), множачи рівень контролю й кількість досяжних активів, тому найменші привілеї й сегментація — ключові заходи стримування. Доступ до облікових даних особливо небезпечний, бо дає важковиявлюваний легітимний доступ, а закріплення в авторизованому тестуванні — лише демонстрація можливості під суворим контролем із гарантованим прибиранням. Прибирання (табл. 9.2) відновлює стан систем і спирається на ретельне документування. Головний висновок: постексплуатація розкриває справжню вагу вразливості через оцінку впливу, але є фазою найвищої відповідальності, де мінімізація шкоди, документування й повне прибирання є обов'язковими умовами професійної та етичної чистоти роботи.

Питання для самоперевірки

1. Що таке постексплуатація? На яке питання замовника вона відповідає?
2. Чому справжня небезпека початкового доступу розкривається саме в постексплуатації?
3. Назвіть принципи постексплуатації. Чому їх порушення перетворює тестування на завдання шкоди?
4. Що таке ситуаційна обізнаність? Чому діє принцип «розуміння перед дією»?
5. Що таке підвищення привілеїв? Розрізніть вертикальне й горизонтальне. Які шляхи існують?
6. Поясніть формулу впливу (9.1). Чому найменші привілеї й сегментація є ключовими заходами стримування?
7. Чому доступ до облікових даних особливо небезпечний? Як фахівець із ними поводиться?
8. Як питання закріплення вирішують в авторизованому тестуванні? Чому залишений бекдор — серйозне порушення?
9. Що таке прибирання? Чому документування є його передумовою?
10. Які об'єкти підлягають прибиранню (табл. 9.2)? Чому не видаляють журнали без узгодження?

11. Яку подвійну мету має прибирання?
12. Опишіть постексплуатацію та оцінку впливу (кейс підрозділу 9.6). Чому це фаза найвищої відповідальності?
13. Чому постексплуатація перетворює факт проникнення на оцінку бізнес-ризику?
14. Дослідницьке: на навчальному полігоні оцініть, як підвищення привілеїв змінює потенційний вплив (9.1), і дослідіть ефективність найменших привілеїв і сегментації як заходів стримування.
15. Дослідницьке: розробіть методику документування змін і прибирання після тестування (табл. 9.2), що гарантує повне відновлення стану систем, та перевірте її на модельному сценарії.

РОЗДІЛ 10

Бокове переміщення та закріплення в мережі

Бокове переміщення (lateral movement) — поширення доступу від початково скомпрометованого вузла до інших систем мережі — є фазою, що розкриває *справжній* масштаб ризику. Поодинока компрометація рідко є кінцевою метою; її небезпека в тому, наскільки далеко від неї може просунутися зловмисник. Тестування бокового переміщення показує замовнику, чи обмежиться компрометація одним вузлом, чи призведе до захоплення всієї мережі. Ця фаза особливо чутлива до якості *сегментації* й *керування доступом*, тому вона прямо перевіряє ключові захисні заходи (розділ 9). Розділ розглядає сутність і цілі бокового переміщення, його механізми, графи атак і аналіз шляхів, виявлення, захисні заходи (сегментація, нульова довіра), і завершується кейсом. Усі дії — у межах обсягу (розділ 4) та авторизації (розділ 2).

10.1 Сутність та цілі

Отримавши доступ до одного вузла (розділи 8–9), зловмисник прагне *розширити* його: дістатися цінних даних, критичних систем, доменного контролю. Бокове переміщення [100, 1] — це серія кроків «компрометація вузла → розвідка зсередини → здобуття доступу до наступного вузла», що повторюється, наближаючи до мети. Кожен крок спирається на здобуте раніше (облікові дані, довірчі відносини, досяжність) і розширює плацдарм.

Ключова особливість бокового переміщення — воно часто спирається на *легітимні* механізми: викрадені облікові дані (розділ 9), довірчі відносини між системами, адміністративні протоколи віддаленого доступу. Це робить його важковиявлюваним: дії зловмисника зовні схожі на звичайну адміністративну активність. Саме тому бокове переміщення — одна з найнебезпечніших фаз реальної атаки й одна з найцінніших для перевірки: воно показує, чи здатен захист відрізнити зловмисне поширення від легітимної активності.

10.2 Механізми переміщення

Бокове переміщення спирається на кілька типів механізмів (табл. 10.1): *повторне використання облікових даних* (здобуті на одному вузлі дані відкривають інші — особливо небезпечне за спільних чи надмірно привілейованих облікових записів); *довірчі відносини* (системи, що довіряють одна одній, дозволяють перехід); *віддалене виконання* (легітимні адміністративні

механізми запуску коду на інших вузлах); *поворотні точки* (pivoting [87] — використання скомпрометованого вузла як проміжного для доступу до недосяжних ззовні сегментів).

Таблиця 10.1 — Механізми бокового переміщення

Механізм	Основа
Повторне використання облікових даних	спільні/привілейовані облікові записи
Довірчі відносини	системи, що довіряють одна одній
Віддалене виконання	легітимні адміністративні протоколи
Поворотні точки (pivoting)	доступ до недосяжних ззовні сегментів

Спільна риса — опора на *наявні* відносини й механізми, а не на нові вразливості. Це означає, що проти бокового переміщення малоефективні заходи, націлені на зовнішній периметр: щойно зловмисник усередині, він користується тим самим, чим і легітимні адміністратори. Тому захист від бокового переміщення — це насамперед *внутрішня* гігієна: обмеження привілеїв, унікальність облікових даних, сегментація, контроль довірчих відносин. Тестування виявляє, наскільки ці заходи реально впроваджені.

Небезпеку бокового переміщення підсилює його *каскадний* характер. У погано сегментованій мережі кожен скомпрометований вузол відкриває доступ до кількох наступних, тож кількість досяжних вузлів зростає лавиноподібно з кроками. Якщо на кожному кроці вузол дає доступ у середньому до b наступних, то за k кроків потенційно досяжних

$$N_k \approx b^k, \tag{10.1}$$

що зростає експоненційно за $b > 1$. Формула (10.1) пояснює, чому пласка мережа з високим коефіцієнтом зв'язності b (надмірні права, спільні облікові дані) веде до швидкого повного захоплення: компрометація одного вузла лавиною поширюється на решту. Захисні заходи, по суті, зменшують b (сегментація, унікальні облікові дані обмежують, куди можна перейти з вузла), переводячи експоненційне зростання в кероване, і саме тому вони такі дієві.

10.3 Графи атак та аналіз шляхів

Можливості бокового переміщення зручно подати **графом атак** [60, 13]: вузли — системи й облікові записи, дуги — можливі переходи (хто куди може дістатися за наявних відносин і доступів). Аналіз такого графа (інструменти на кшталт BloodHound [126]) виявляє *шляхи* від початкової точки до цін-

них цілей (наприклад, до доменного адміністратора) — часто несподівано короткі через надмірні права й довірчі відносини.

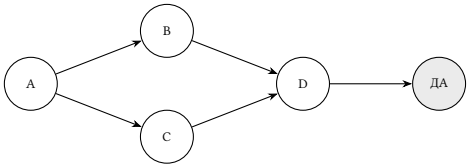


Рис. 10.1 — Граф атак: шляхи від початкової точки до цінної цілі

Граф атак — потужний інструмент і для атаки, і для захисту. Для тестувальника він виявляє найкоротший шлях до мети; для захисту — показує, які переходи треба розірвати, щоб подовжити чи перекрити шляхи. Довжину найкоротшого шляху до критичної цілі можна використати як метрику стійкості:

$$d_{\min} = \min_{p \in P} |p|, \tag{10.2}$$

де P — множина шляхів від початкової точки до цілі, $|p|$ — кількість кроків у шляху. Формула (10.2) дає захисну ціль: збільшення $d_{\min}$ (усунення коротких шляхів через зайві права й довірчі відносини) ускладнює боковий рух. Короткий $d_{\min}$ (наприклад, один-два кроки до доменного адміністратора) — критичний висновок тестування, що вказує на небезпечну концентрацію привілеїв.

10.4 Виявлення бокового переміщення

Оскільки бокове переміщення спирається на легітимні механізми, його *виявлення* [133] складне й спирається на *аномалії*: нетипові зв'язки між вузлами, незвичне використання облікових записів (вхід адміністратора туди, куди він ніколи не заходив), аномальні часи, нетипові послідовності дій. Засоби виявлення аналізують графи автентифікацій і з'єднань, шукаючи відхилення від норми.

Тестування бокового переміщення прямо перевіряє *спроможність виявлення*: чи помітить захист поширення, замасковане під легітимну активність. Це особливо цінно для оцінки зрілості моніторингу (розділ 3): багато організацій добре захищають периметр, але сліпі до внутрішнього руху. Фахівець у звіті (розділ 16) оцінює не лише *можливість* бокового переміщення, а й чи було його *виявлено*, — і невиявлення є критичним висновком про сліпу зону внутрішнього моніторингу, що подовжує час присутності зловмисника за реальної атаки.

10.5 Захисні заходи

Розуміння бокового переміщення дає прямі захисні висновки [38]. *Сегментація* мережі обмежує досяжність (9.2), перетворюючи компрометацію одного сегмента на локалізований інцидент. *Найменші привілеї* й унікальність облікових даних розривають шляхи повторного використання. *Контроль довірчих відносин* усуває зайві переходи. *Моніторинг внутрішньої активності* уможливлює виявлення. *Нульова довіра* [127] — парадигма, за якої жоден внутрішній перехід не довірений за замовчуванням, а кожен перевіряється, — системно ускладнює боковий рух.

Таблиця 10.2 — Захисні заходи проти бокового переміщення

Захід	Ефект
Сегментація	обмеження досяжності, локалізація
Найменші привілеї	розрив шляхів повторного використання
Унікальні облікові дані	запобігання каскаду компрометації
Контроль довірчих відносин	усунення зайвих переходів
Моніторинг внутрішній	виявлення аномального руху
Нульова довіра	перевірка кожного переходу

Ключовий висновок для захисту — припущення компрометації: периметр *буде* подолано, тому стійкість визначається здатністю *обмежити поширення* після початкового проникнення. Організація, що вклала все в периметр, але має пласку внутрішню мережу з надмірними привілеями, вразлива: одна компрометація веде до повного захоплення. Тестування бокового переміщення емпірично це демонструє, перетворюючи абстрактну пораду «сегментуйте мережу» на конкретний, підтверджений висновок із виміряним $d_{\min}$ (10.2).

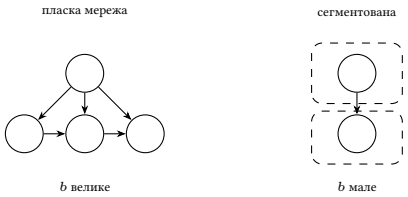


Рис. 10.2 — Сегментація зменшує зв’язність b, стримуючи каскадне поширення

10.6 Кейс: тестування бокового переміщення

Розглянемо тестування бокового переміщення (продовження наскрізного прикладу).

Крок 1. Розвідка зсередини. З початкового вузла (розділ 9) з'ясовуємо досяжні системи, довірчі відносини, доступні облікові дані.

Крок 2. Побудова графа атак. Моделюємо можливі переходи графом атак (рис. 10.1), виявляючи шляхи до цінних цілей і найкоротший шлях (10.2).

Крок 3. Контрольоване переміщення. У межах обсягу демонструємо переходи до наступних вузлів легітимними механізмами (табл. 10.1), з мінімізацією впливу й документуванням кожного кроку (розділ 9).

Крок 4. Оцінка спроможності виявлення. Фіксуємо, чи помітив захист боковий рух, оцінюючи зрілість внутрішнього моніторингу.

Крок 5. Захисні висновки. Для звіту (розділ 16) формуємо рекомендації (табл. 10.2): де потрібна сегментація, обмеження привілеїв, контроль довірчих відносин для подовження $d_{\min}$.

Кейс демонструє, що тестування бокового переміщення розкриває справжній масштаб ризику компрометації й прямо перевіряє внутрішні захисні заходи, даючи конкретні, підтверджені рекомендації щодо обмеження поширення.

Висновки до розділу

Бокове переміщення — поширення доступу мережею — розкриває справжній масштаб ризику компрометації, бо небезпека поодинокого проникнення в тому, наскільки далеко від нього можна просунутися. Воно спирається на легітимні механізми (табл. 10.1) — викрадені облікові дані, довірчі відносини, адміністративні протоколи, — що робить його важковиявлюваним і малочутливим до периметрового захисту. Можливості переміщення подають графом атак (рис. 10.1), аналіз якого виявляє шляхи до цінних цілей, а найкоротший шлях (10.2) слугує метрикою стійкості. Виявлення спирається на аномалії, а тестування прямо перевіряє спроможність внутрішнього моніторингу, невиявлення яким є критичним висновком. Захисні заходи (табл. 10.2) — сегментація (9.2), найменші привілеї, унікальні облікові дані, контроль довірчих відносин, нульова довіра — обмежують поширення за припущення компрометації. Головний висновок: тестування бокового переміщення емпірично демонструє, чи обмежиться компрометація одним вузлом, чи призведе до захоплення мережі, перетворюючи абстрактні поради на підтверджені висновки й наголошуючи, що стійкість визначається здатністю обмежити поширення, а не лише захистити периметр.

Питання для самоперевірки

1. Що таке бокове переміщення? Чому воно розкриває справжній масштаб ризику компрометації?
2. Чому бокове переміщення спирається на легітимні механізми й що це означає для його виявлення?
3. Назвіть механізми бокового переміщення (табл. 10.1). Що є їх спільною рисою?
4. Чому проти бокового переміщення малоефективні заходи зовнішнього периметра?
5. Що таке граф атак (рис. 10.1)? Як він корисний і для атаки, і для захисту?
6. Поясніть метрику найкоротшого шляху (10.2). Чому короткий шлях до доменного адміністратора — критичний висновок?
7. Як виявляють бокове переміщення? Чому воно спирається на аномалії?
8. Чому тестування бокового переміщення цінне для оцінки зрілості моніторингу?
9. Назвіть захисні заходи проти бокового переміщення (табл. 10.2) та ефект кожного.
10. Як сегментація (9.2) обмежує поширення? Що таке нульова довіра?
11. Поясніть принцип припущення компрометації. Чому пласка мережа з надмірними привілеями вразлива?
12. Опишіть тестування бокового переміщення (кейс підрозділу 10.6). Як граф атак спрямовує роботу?
13. Чому невиявлення бокового руху є критичним висновком про внутрішній моніторинг?
14. Дослідницьке: побудуйте граф атак для навчальної мережі, виявіть найкоротші шляхи (10.2) до критичних цілей і запропонуйте зміни, що їх подовжують.
15. Дослідницьке: оцініть ефективність сегментації (9.2) та найменших привілеїв у обмеженні бокового переміщення на модельній мережі й порівняйте спроможність виявлення до і після заходів.

РОЗДІЛ 11

Тестування захищеності вебзастосунків

Вебзастосунки — одна з найпоширеніших і найбільш атакованих категорій цілей: вони доступні ззовні, обробляють недовірений ввід і часто мають доступ до цінних даних. Тестування їх захищеності — окрема, зріла дисципліна з детальними методологіями (OWASP WSTG [115]) і класифікаціями ризиків (OWASP Top 10 [111]). Воно спирається на загальну методологію (розділ 3) й етапи (розділи 5–8), але має специфіку, зумовлену природою вебтехнологій. Розділ розглядає специфіку вебзастосунків як цілі, класифікацію ризиків, ін'єкційні вразливості, вади автентифікації й контролю доступу, вади бізнес-логіки, тестування API, і завершується кейсом. Усі дії — у межах авторизації (розділ 2) та обсягу (розділ 4); практику відпрацьовують на навчальних застосунках.

11.1 Специфіка вебзастосунків як цілі

Вебзастосунок — розподілена система з клієнтською частиною (браузер), серверною логікою, сховищем даних і програмними інтерфейсами. Ця архітектура визначає поверхню атаки: кожна точка приймання вводу (параметри запитів, форми, заголовки, API) — потенційний вектор. Специфіка вебу: ввід повністю контролює клієнт (а отже потенційний зловмисник), тому серверна довіра до будь-яких клієнтських даних небезпечна; складність сучасних застосунків (фреймворки, API, інтеграції) розширює поверхню; доступність ззовні робить їх постійною ціллю.

Тестування вебзастосунків поєднує *автоматизоване* сканування (швидке виявлення типових вразливостей) і *ручне* дослідження (логіка, контекст, складні вразливості). Інструменти — перехоплювальні проксі (ZAP [112], Burp Suite [119]), що дозволяють аналізувати й модифікувати запити між клієнтом і сервером. Як і в загальному аналізі (розділ 7), автоматизація дає широту, а експертиза — глибину; вади бізнес-логіки принципово потребують ручного аналізу, бо автомат не розуміє призначення застосунку.

11.2 Класифікація ризиків

OWASP Top 10 [111, 22] — визнана класифікація найкритичніших ризиків вебзастосунків, що періодично оновлюється за реальними даними. Вона охоплює (узагальнено, табл. 11.1): порушення контролю доступу, криптографічні недоліки, ін'єкції, небезпечний дизайн, помилки конфігурації, вразливі компоненти, вади автентифікації, порушення цілісності, недоста-

тнє журналювання, підробку запитів на боці сервера. Ця класифікація — спільна мова й основа для систематичного покриття під час тестування.

Таблиця 11.1 — Категорії ризиків OWASP Top 10 (узагальнено)

Категорія	Суть
Порушення контролю доступу	доступ поза дозволеним
Криптографічні недоліки	слабкий чи відсутній захист даних
Ін'єкції	недовірений ввід як код/запит
Небезпечний дизайн	вади на рівні задуму
Помилки конфігурації	небезпечні налаштування
Вади автентифікації	слабка перевірка особи

OWASP Top 10 — не вичерпний перелік, а пріоритетні *категорії*; у межах кожної існує багато конкретних вразливостей, детально описаних у WSTG [115]. Повноту тестування зручно оцінити покриттям категорій і перевірок WSTG:

$$\mathrm{Cov}_{\mathrm{web}} = \frac{|W_{\text{перевірено}}|}{|W_{\text{застосовні}}|} \in [0;1], \tag{11.1}$$

де $W_{\text{застосовні}}$ — застосовні до цілі перевірки WSTG, $W_{\text{перевірено}}$ — виконані. Формула (11.1) робить повноту вебтестування вимірюваною й спрямовує систематичність, запобігаючи пропуску цілих класів перевірок.

11.3 Ін'єкційні вразливості

Ін'єкції [73, 7] — класичний і досі поширений клас: недовірений ввід інтерпретується як код чи команда. **SQL-ін'єкція** (SQLi) — ввід, що змінює структуру запиту до бази даних (доступ до чужих даних, обхід автентифікації). **Міжсайтове скриптування** (XSS) [71] — ввід, що виконується як скрипт у браузері іншого користувача (крадіжка сесій, дії від імені жертви). Інші — ін'єкції команд ОС, шаблонів, тощо. Першопричина спільна — *змішування* недовірених даних і коду без належного розмежування. Типові ін'єкційні вразливості зведено в табл. 11.2.

Таблиця 11.2 — Типові ін’єкційні вразливості

Тип	Де виконується	Наслідок
SQL-ін’єкція	база даних	доступ/зміна даних, обхід авт.
XSS	браузер жертви	крадіжка сесій, дії від імені
Ін’єкція команд	ОС сервера	виконання команд
Ін’єкція шаблонів	рушій шаблонів	виконання коду

Тестування ін’єкцій перевіряє, чи коректно застосунок розмежовує дані й код на кожній точці вводу. Захисні висновки прямі: радикальне рішення — *структурне* розділення (параметризовані запити замість конкатенації, контекстне кодування виводу), а не фільтрація «поганих» символів, що ненадійна. Фахівець у звіті (розділ 16) не лише демонструє ін’єкцію, а й рекомендує структурний захист. Демонстрацію проводять із мінімізацією шкоди (розділ 2): доводять можливість, не викачуючи даних і не впливаючи на інших користувачів.

11.4 Автентифікація, сесії та контроль доступу

Великий клас вразливостей стосується *керування доступом*. **Вади автентифікації**: слабкі паролі, відсутність захисту від перебору, небезпечне відновлення доступу, вади багатофакторності. **Вади сесій**: передбачувані чи незахищені ідентифікатори сесій, відсутність належного завершення. **Порушення контролю доступу**: доступ до чужих ресурсів зміною ідентифікаторів (небезпечні прямі посилання на об’єкти), доступ до адміністративних функцій без прав, обхід перевірок. Порушення контролю доступу — одна з найпоширеніших і найсерйозніших категорій, бо дає прямий доступ до чужих даних і функцій.

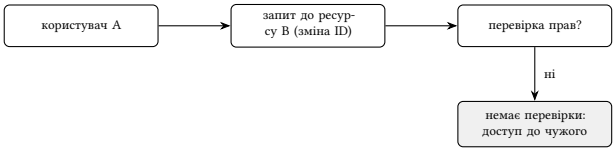


Рис. 11.1 — Порушення контролю доступу: доступ до чужого ресурсу за відсутності перевірки прав

Тестування контролю доступу перевіряє кожен ресурс і функцію на предмет належної перевірки прав *на сервері* (клієнтські перевірки оманливі, бо клієнт контролює зловмисник). Типовий тест — спроба доступу до ресурсу іншого користувача чи до привілейованої функції з-під звичайного облікового запису. Захисний висновок — перевірка прав має бути *повною* (кожен доступ, повне посередництво) і *серверною*. Ці вади часто не виявляє автоматика, бо вимагають розуміння ролей і призначення ресурсів, тому ручне тестування тут незамінне.

Обсяг перевірки контролю доступу зручно оцінити комбінаторно. Якщо застосунок має R ролей і O захищуваних об'єктів/функцій, то повна перевірка матриці доступу вимагає

$$N_{\text{перевірок}} = R \cdot O, \tag{11.2}$$

перевірок «чи має роль r належний доступ до об'єкта o». Формула (11.2) показує, чому контроль доступу так часто вразливий: кількість комбінацій велика, і розробники легко пропускають перевірку для окремих поєднань (особливо для нових об'єктів, доданих пізніше). Для тестувальника вона задає систематичний план: перевіряти не лише очевидні, а *всі* релевантні поєднання ролей і об'єктів, бо саме пропущена комбінація стає вразливістю. Повне покриття матриці — ідеал, на практиці пріоритезований за критичністю об'єктів.

11.5 Бізнес-логіка та API

Вади бізнес-логіки [113] — найтонший клас: застосунок працює технічно коректно, але логіка дозволяє зловживання (обхід етапів процесу, маніпуляція цінами чи кількостями, повторне використання одноразового, перевищення лімітів). Їх принципово не виявляє автоматика, бо вона не розуміє *призначення* застосунку — що є легітимним, а що зловживанням. Виявлення вад логіки — вершина майстерності вебтестувальника, що потребує глибокого розуміння предметної області застосунку.

Тестування API [109, 30] набуло окремого значення з поширенням програмних інтерфейсів. API мають власну класифікацію ризиків (OWASP API Security Top 10): порушення авторизації на рівні об'єктів і функцій, надмірне розкриття даних, відсутність обмеження швидкості. API часто менш захищені за вебінтерфейс (бо спроєктовані для «довірених» клієнтів), але так само доступні зловмиснику, тому їх тестування критичне. Специфіка — відсутність браузерного контексту, машинна взаємодія, що потребує інших підходів, ніж тестування вебсторінок.

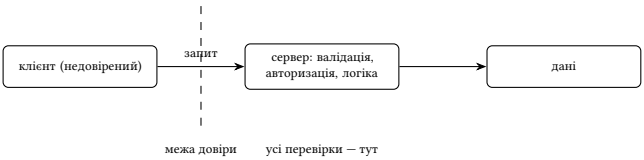


Рис. 11.2 — Межа довіри вебзастосунку: клієнтський ввід недовірений, перевірки — на сервері

11.6 Кейс: тестування вебзастосунку

Розглянемо тестування захищеності вебзастосунку (продовження наскрізного прикладу).

Крок 1. Картографування. Досліджуємо застосунок: точки вводу, функції, ролі, API, технології — будуючи карту поверхні атаки (розділ 5) вже на рівні застосунку.

Крок 2. Автоматизоване сканування. Проганяємо вебсканер (ZAP/Burp [112, 119]) для широкого виявлення типових вразливостей, отримуючи кандидатів для валідації (розділ 7).

Крок 3. Систематичні перевірки WSTG. Виконуємо перевірки за категоріями OWASP (табл. 11.1), оцінюючи покриття (11.1): ін'єкції, автентифікація, сесії, контроль доступу (рис. 11.1).

Крок 4. Ручне дослідження логіки й API. Досліджуємо вади бізнес-логіки та захищеність API, що потребують розуміння призначення й недосяжні автоматиці.

Крок 5. Валідація й захисні висновки. Валідуємо знахідки з мінімізацією шкоди, формуємо рекомендації (структурний захист від ін'єкцій, серверний контроль доступу) для звіту (розділ 16).

Кейс демонструє, що тестування вебзастосунків поєднує систематичне покриття категорій, автоматизацію й ручне дослідження логіки, причому саме останнє — виявлення вад логіки й контролю доступу — дає найцінніші, недосяжні автоматиці результати.

Висновки до розділу

Вебзастосунки — поширена й атакована категорія цілей через доступність ззовні, оброблення недовіреного вводу й доступ до цінних даних. Їх тестування — зріла дисципліна з детальними методологіями (WSTG) і класифікаціями ризиків (OWASP Top 10; табл. 11.1), що поєднує автоматизоване сканування (широта) й ручне дослідження (глибина, логіка). Повноту оцінюють покриттям перевірок (11.1). Ін'єкції (SQLi, XSS) — класичний клас зі спільною першопричиною (змішування даних і коду), радикально усувний структурним розділенням, а не фільтрацією. Вади керування доступом

(автентифікація, сесії, контроль доступу; рис. 11.1) — одні з найсерйозніших, і їх перевіряють на серверну повноту, бо клієнтські перевірки оманливі. Вади бізнес-логіки й захищеність API принципово потребують ручного аналізу, бо автомат не розуміє призначення застосунку. Головний висновок: тестування вебзастосунків поєднує систематичне покриття, автоматизацію й експертне дослідження, причому найцінніші результати — вади логіки й контролю доступу — дає саме людина, що розуміє призначення застосунку, а захисні висновки орієнтують на структурні, серверні рішення.

Питання для самоперевірки

1. Чому вебзастосунки — одна з найбільш атакованих категорій? Яка їх архітектурна специфіка як цілі?
2. Чому серверна довіра до клієнтських даних небезпечна?
3. Як поєднують автоматизоване й ручне тестування вебзастосунків? Чому вади логіки потребують ручного аналізу?
4. Що таке OWASP Top 10 (табл. 11.1)? Чому це категорії, а не вичерпний перелік?
5. Поясніть покриття вебтестування (11.1). Навіщо його вимірювати?
6. Що таке ін'єкції (SQLi, XSS)? Яка їх спільна першопричина?
7. Чому структурне розділення даних і коду надійніше за фільтрацію? Як це відображають у рекомендаціях?
8. Опишіть вади керування доступом (автентифікація, сесії, контроль доступу; рис. 11.1).
9. Чому контроль доступу перевіряють на сервері? Чому клієнтські перевірки оманливі?
10. Що таке вади бізнес-логіки? Чому їх принципово не виявляє автоматика?
11. Чому тестування API критичне? У чому його специфіка порівняно з вебсторінками?
12. Опишіть тестування вебзастосунку (кейс підрозділу 11.6). Які результати дає саме ручне дослідження?
13. Чому виявлення вад логіки — вершина майстерності вебтестувальника?
14. Дослідницьке: на навчальному вразливому застосунку виконайте систематичні перевірки WSTG, оцініть покриття (11.1) та порівняйте результати автоматичного й ручного тестування.
15. Дослідницьке: дослідіть клас вад бізнес-логіки на прикладі модельного застосунку й запропонуйте методику їх систематичного виявлення, якої бракує автоматиці.

РОЗДІЛ 12

Тестування безпроводових та мобільних систем

Безпроводові мережі й мобільні пристрої розширюють поверхню атаки за межі фізичного периметра: радіосигнал поширюється поза стінами, а мобільні пристрої переносять корпоративні дані назовні. Це створює специфічні вектори, яких немає в класичних провідних системах, і потребує окремих методів тестування. Розділ розглядає специфіку безпроводових мереж як цілі, тестування Wi-Fi, інші безпроводові технології, безпеку мобільних платформ, тестування мобільних застосунків, і завершується кейсом. Виклад зосереджено на методології та захисних висновках; усі дії — у межах авторизації (розділ 2) та обсягу (розділ 4), а практику відпрацьовують на власному обладнанні чи навчальних полігонах. Особливо наголосимо: перехоплення чужого радіотрафіку поза авторизацією є протиправним.

12.1 Специфіка безпроводового середовища

Принципова відмінність безпроводових мереж — *спільне середовище передавання*: радіосигнал доступний усім у зоні покриття, а не лише легітимним учасникам. Це знімає природний бар'єр фізичного доступу: зловмиснику не треба підключатися до кабелю — достатньо перебувати в радіусі сигналу, який часто виходить за межі будівлі. Звідси специфічні вектори: пасивне прослуховування (перехоплення трафіку), несанкціоновані точки доступу, атаки на механізми автентифікації й шифрування, глушіння.

Поширення сигналу й, отже, зону ризику визначає фізика: потужність сигналу спадає з відстанню. Спрощено прийнятий рівень сигналу

$$P_{\text{прийн}} = P_{\text{передав}} - 10\, n \log_{10} d, \tag{12.1}$$

де $P_{\text{передав}}$ — потужність передавача, d — відстань, n — коефіцієнт згасання середовища. Формула (12.1) пояснює, чому зона досяжності безпроводової мережі — не межа будівлі, а радіус, де сигнал ще прийнятний: зловмисник із чутливою антеною може перебувати значно далі, ніж розраховували проєктувальники. Це визначає захисний висновок — контроль потужності й розміщення точок доступу для обмеження «витоку» сигналу за периметр, хоч повністю усунути його неможливо.

12.2 Тестування Wi-Fi

Тестування Wi-Fi [79, 41] перевіряє захищеність безпроводової мережі за кількома напрямами (табл. 12.1): *механізм захисту* (застарілі протоколи

вразливі; WPA2 має відомі слабкості [140]; WPA3 [141] надійніший), *надійність автентифікації* (слабкі паролі вразливі до офлайн-перебору перехопленого рукостискання), *несанкціоновані точки доступу* (rogue AP — підроблені точки для перехоплення), *ізоляція клієнтів і сегментація* (чи ізольована гостьова мережа від корпоративної).

Таблиця 12.1 — Напрями тестування Wi-Fi

Напрям	Що перевіряє
Протокол захисту	застарілі/вразливі механізми шифрування
Автентифікація	стійкість паролів до офлайн-перебору
Несанкціоновані точки	підроблені AP, атаки «злий двійник»
Сегментація	ізоляція гостьової та корпоративної мереж
Фізичне покриття	витік сигналу за периметр

Поширений вектор — *офлайн-перебір*: зловмисник перехоплює рукостискання автентифікації й перебирає пароль офлайн (не взаємодіючи з мережею). Стійкість до нього визначає *складність* пароля. Час перебору зростає експоненційно з довжиною й різноманітністю пароля:

$$T_{\text{перебір}} = \frac{A^{L}}{r}, \tag{12.2}$$

де A — розмір алфавіту, L — довжина пароля, r — швидкість перебору. Формула (12.2) дає прямий захисний висновок: кожен додатковий символ множить час перебору в A разів, тому довгі випадкові паролі (парольні фрази) роблять офлайн-перебір непрактичним. Тестування демонструє вразливість слабких паролів, обґрунтовуючи вимогу складності.



Рис. 12.1 — Атака «злий двійник»: клієнт приєднується до підробленої точки з сильнішим сигналом

12.3 Інші безпроводові технології

Поза Wi-Fi існують інші безпроводові технології зі своїми ризиками: *Bluetooth* (перехоплення, несанкціоноване спарювання, вразливості реалізацій), *технології IoT* (часто слабко захищені, з типовими паролями й застарілими протоколами, розділ 13), *RFID/NFC* (клонування міток, перехо-

плення), *стільниковий зв'язок* і спеціалізовані радіопротоколи. Кожна має власну модель загроз і методи тестування.

Спільна риса — та сама відсутність фізичного бар'єра й часто *слабший* захист, ніж у Wi-Fi (особливо в IoT і застарілих протоколах, спроєктованих без урахування сучасних загроз). Тестування цих технологій потребує спеціалізованого обладнання (радіоприймачі, аналізатори) і знань протоколів. Захисні висновки типові: оновлення протоколів, сильна автентифікація, шифрування, сегментація безпроводових пристроїв у окремі мережі, моніторинг радіоефіру на несанкціоновані пристрої. Для багатьох спеціалізованих технологій саме слабкість захисту, а не його відсутність, є головним висновком тестування.

12.4 Безпека мобільних платформ

Мобільні платформи (Android, iOS) мають принципово іншу модель безпеки, ніж настільні [68]: **пісочниця застосунків** (ізоляція кожного застосунку), *дозвільна модель* (контроль доступу до ресурсів), централізовані магазини з перевіркою, регулярні оновлення платформи. Ця модель суттєво ускладнює атаки, але не усуває їх: вразливості існують у самих застосунках, у їх взаємодії, у конфігурації, а дозволи можна зловживати.

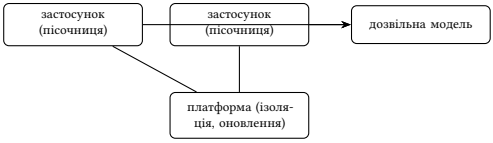


Рис. 12.2 — Модель безпеки мобільної платформи: пісочниці застосунків і дозвільна модель

Для тестувальника модель платформи визначає, *що* й *як* перевіряти: оскільки платформа ізолює застосунки, акцент зміщується на вразливості *всередині* застосунку та в його взаємодії із зовнішнім світом (мережа, сховище, міжпроцесна взаємодія), а не на обхід самої платформи (що потребує вразливостей рівня ОС). Специфіка мобільного тестування — поєднання аналізу застосунку (статичного й динамічного, розділ про методи в суміжних дисциплінах) із перевіркою серверної частини (API, розділ 11), бо мобільний застосунок зазвичай — клієнт до серверних сервісів.

12.5 Тестування мобільних застосунків

Тестування мобільних застосунків [110, 28] структурує методологія MASTG. Основні напрями (табл. 12.2): *зберігання даних* (чи захищені чутливі дані на пристрої, бо пристрій може бути втрачено чи викрадено), *мережева взаємодія* (чи захищений канал, чи перевіряється сертифікат), *криптографія* (пра-

вильність застосування), *автентифікація* (локальна й серверна), *якість коду* (вразливості реалізації), *взаємодія з платформою* (дозволи, міжпроцесна взаємодія, витік через журнали чи буфер обміну).

Таблиця 12.2 — Напрями тестування мобільних застосунків (MASTG)

Напрям	Ризик
Зберігання даних	чутливі дані на втраченому пристрої
Мережева взаємодія	перехоплення незахищеного каналу
Криптографія	неправильне застосування
Автентифікація	обхід локальної перевірки
Взаємодія з платформою	витік через дозволи, журнали, буфер

Специфічний ризик мобільних застосунків — *втрата контролю над пристроєм*: на відміну від сервера, пристрій фізично в руках користувача (або зловмисника за викрадення), тому локальні захисні механізми можна обійти за фізичного доступу. Звідси ключовий висновок: мобільний застосунок не має покладатися на *клієнтські* перевірки й зберігати чутливе *незахищеним* на пристрої; критичні перевірки й дані належать серверу. Дослідження безпеки Android [63] історично виявляли поширений витік даних навіть у легітимних застосунках, що підкреслює важливість такого тестування.

12.6 Кейс: тестування безпроводової та мобільної систем

Розглянемо тестування безпроводової мережі та мобільного застосунку (продовження наскрізного прикладу).

Крок 1. Безпроводова розвідка. У межах обсягу виявляємо безпроводові мережі цілі, їх протоколи захисту, оцінюємо зону покриття (12.1) (витік сигналу за периметр).

Крок 2. Тестування Wi-Fi. Перевіряємо напрями (табл. 12.1): протокол захисту, стійкість автентифікації (демонструємо ризик слабких паролів (12.2)), наявність несанкціонованих точок, сегментацію.

Крок 3. Аналіз мобільного застосунку. Досліджуємо застосунок за MASTG (табл. 12.2): зберігання даних, мережеву взаємодію, криптографію, взаємодію з платформою (рис. 12.2).

Крок 4. Серверна частина. Тестуємо серверні API застосунку (розділ 11), бо саме там зазвичай зосереджена критична логіка.

Крок 5. Захисні висновки. Формуємо рекомендації для звіту (розділ 16): сильна автентифікація й сучасні протоколи для Wi-Fi, серверні перевірки й захищене зберігання для мобільного застосунку.

Кейс демонструє, що тестування безпроводових і мобільних систем має власну специфіку (відсутність фізичного бар'єра, фізичний доступ до пристрою), але спирається на ті самі принципи: не довіряти середовищу й клієнту, переносити критичне на сервер.

Висновки до розділу

Безпроводові мережі й мобільні пристрої розширюють поверхню атаки за фізичний периметр, створюючи специфічні вектори. Принципова відмінність безпроводового середовища — спільне середовище передавання без фізичного бар'єра, а зона досяжності (12.1) виходить за межі будівлі. Тестування Wi-Fi (табл. 12.1) перевіряє протокол захисту, автентифікацію (стійкість до офлайн-перебору (12.2)), несанкціоновані точки й сегментацію. Інші безпроводові технології (Bluetooth, IoT, RFID) часто захищені слабше, і саме слабкість захисту — головний висновок. Мобільні платформи мають сильну вбудовану модель (пісочниці, дозволи; рис. 12.2), що зміщує акцент на вразливості всередині застосунку й серверної частини. Тестування мобільних застосунків (MASTG; табл. 12.2) враховує специфічний ризик фізичного доступу до пристрою, через що критичне належить серверу. Головний висновок: тестування безпроводових і мобільних систем має власну специфіку, але підпорядковане наскрізним принципам — не довіряти середовищу й клієнту, переносити критичні перевірки й дані на сервер, — а його захисні висновки орієнтують на сучасні протоколи, сильну автентифікацію й серверний контроль.

Питання для самоперевірки

1. Чому безпроводові мережі й мобільні пристрої розширюють поверхню атаки за фізичний периметр?
2. У чому принципова відмінність безпроводового середовища? Які специфічні вектори вона створює?
3. Поясніть формулу згасання сигналу (12.1). Чому зона ризику виходить за межі будівлі?
4. Назвіть напрями тестування Wi-Fi (табл. 12.1). Що перевіряє кожен?
5. Що таке офлайн-перебір? Поясніть формулу часу перебору (12.2) та її захисний висновок.
6. Які інші безпроводові технології тестують? Чому вони часто захищені слабше за Wi-Fi?
7. Опишіть модель безпеки мобільної платформи (рис. 12.2). Як вона визначає акцент тестування?

8. Чому для мобільних систем акцент зміщується на вразливості всередині застосунку та серверної частини?
9. Назвіть напрями тестування мобільних застосунків за MASTG (табл. 12.2).
10. Що таке специфічний ризик втрати контролю над пристроєм? Який висновок з нього випливає?
11. Чому мобільний застосунок не має покладатися на клієнтські перевірки й зберігати чутливе незахищеним?
12. Опишіть тестування безпроводової та мобільної систем (кейс підрозділу 12.6). Які наскрізні принципи воно ілюструє?
13. Чому перехоплення чужого радіотрафіку поза авторизацією є протиправним?
14. Дослідницьке: на власному обладнанні оцініть вплив довжини й складності пароля (12.2) на практичну стійкість Wi-Fi до офлайн-перебору.
15. Дослідницьке: проаналізуйте навчальний мобільний застосунок за MASTG (табл. 12.2) і визначте, які критичні перевірки доцільно перенести з клієнта на сервер.

РОЗДІЛ 13

Тестування мережевої інфраструктури та хмари

Мережева інфраструктура (маршрутизатори, комутатори, міжмережеві екрани, служби каталогів) і хмарні середовища — основа сучасних інформаційних систем, а отже й пріоритетні цілі. Їх тестування має специфіку: інфраструктура визначає *зв'язність* і *довірчі відносини* (а отже можливості бокового переміщення, розділ 10), а хмара змінює саму модель відповідальності й створює нові класи вразливостей (насамперед помилки конфігурації). Розділ розглядає тестування внутрішньої мережі й служб каталогів, мережеві пристрої, специфіку хмарних середовищ, помилки конфігурації як домінантний клас, спеціалізовані середовища (контейнери, IoT/OT), і завершується кейсом. Усі дії — у межах авторизації (розділ 2) та обсягу (розділ 4); для хмари часто потрібен окремий дозвіл провайдера.

13.1 Внутрішня мережа та служби каталогів

Внутрішнє тестування [42] моделює зловмисника, що вже всередині (скомпрометований вузол, інсайдер), і перевіряє, наскільки далеко він просунеться. Ключовий об'єкт у корпоративних мережах — **служби каталогів** (Active Directory та аналоги) [94], що централізовано керують автентифікацією, авторизацією й довірчими відносинами. Їх компрометація (особливо доменного адміністратора) дає контроль над усією мережею, тому вони — головна ціль бокового переміщення (розділ 10).

Тестування служб каталогів перевіряє: надмірні привілеї й хибні делегування, слабкі паролі службових облікових записів, небезпечні довірчі відносини, вразливі конфігурації автентифікації. Воно тісно пов'язане з аналізом графів атак (розділ 10): служба каталогів визначає ребра графа (хто куди має доступ), і її аналіз виявляє шляхи до повного захоплення. Захисні висновки — найменші привілеї, рівневу модель адміністрування, моніторинг аномальної автентифікації, — прямо випливають із виявлених шляхів.

13.2 Мережеві пристрої та периметр

Мережеві пристрої (маршрутизатори, комутатори, міжмережеві екрани, VPN-шлюзи) — критичні вузли, компрометація яких дає контроль над трафіком і доступ углиб мережі. Типові слабкості: типові чи слабкі облікові дані керування, застаріле мікропрограмне забезпечення з відомими вразливостями, небезпечні конфігурації (відкриті інтерфейси керування, слабкі протоколи), надмірно дозвільні правила фільтрації.

Особливу увагу приділяють *площині керування*: інтерфейси адміністрування пристроїв, доступні з недовірених мереж, — найкоротший шлях до компрометації в обхід усієї логіки фільтрації (розділ 5). Тестування перевіряє, чи обмежено доступ до керування довіреними мережами, чи сильна автентифікація, чи оновлене ПЗ. VPN-шлюзи — окремий пріоритет: вони є точкою входу ззовні, тому їх вразливості дають прямий зовнішній доступ усередину. Захисні висновки — ізоляція площини керування, сильна автентифікація, своєчасне оновлення, аудит правил фільтрації на надмірну дозвільність.



Рис. 13.1 — Розділення площин даних і керування: доступ до керування обмежують

13.3 Специфіка хмарних середовищ

Хмарні середовища [93, 29] змінюють модель тестування через **спільну відповідальність**: провайдер відповідає за безпеку *хмари* (інфраструктуру), клієнт — за безпеку *в хмарі* (конфігурацію, дані, доступ). Це визначає межі тестування: інфраструктуру провайдера тестувати *не можна* (вона належить і керується провайдером), а конфігурацію клієнта — можна й треба. Тому для хмарного тестування критично чітко розмежувати, що в обсязі (клієнтська конфігурація), а що поза ним (інфраструктура провайдера), і отримати потрібні дозволи.



Рис. 13.2 — Спільна відповідальність у хмарі визначає межі тестування

Нові класи вразливостей у хмарі зосереджені в *клієнтській* зоні: помилки конфігурації сховищ (відкритий доступ до даних), надмірні права в системі керування доступом (IAM [74]), небезпечні налаштування сервісів, скомпрометовані ключі доступу, незахищена керуюча площина. Більшість хмарних інцидентів спричинена не проломом захисту провайдера, а помилками клієнта, тому хмарне тестування зосереджується саме на конфігу-

рації й керуванні доступом, а не на «зломі» інфраструктури. Типові хмарні помилки конфігурації наведено в табл. 13.1.

Таблиця 13.1 — Типові помилки конфігурації в хмарі

Помилка	Наслідок
Відкрите сховище	публічний доступ до даних
Надмірні права IAM	розширення доступу за компрометації
Скомпрометовані ключі	прямий доступ до ресурсів
Незахищена керуюча площина	контроль над середовищем
Вимкнене журналювання	відсутність видимості й розслідування

13.4 Помилки конфігурації як домінантний клас

У сучасних інфраструктурах і хмарі **помилки конфігурації** [6] стали домінантним класом вразливостей — часто поширенішим і небезпечнішим за програмні дефекти. Причина: складність систем зросла, кількість налаштувань величезна, а безпечна конфігурація не завжди є типовою. Приклади: відкриті сховища даних, надмірні права, типові паролі, зайві відкриті сервіси, вимкнене журналювання, небезпечні довірчі відносини.

Домінування помилок конфігурації має кількісне пояснення. Якщо система має n незалежних налаштувань, кожне з яких має ймовірність q бути небезпечно сконфігурованим, то ймовірність *хоча б однієї* помилки конфігурації

$$P_{\text{помилка}} = 1 - (1 - q)^n, \tag{13.1}$$

швидко зростає з кількістю налаштувань n. Формула (13.1) пояснює, чому великі складні системи майже неминуче містять помилки конфігурації: навіть за малого q велике n робить $P_{\text{помилка}}$ близьким до одиниці. Захисні висновки — зменшення n (спрощення, мінімізація поверхні), зниження q (безпечні типові значення, автоматизована перевірка конфігурації, інфраструктура як код із контролем), регулярний аудит.

Автоматизована перевірка конфігурації особливо ефективна саме через природу (13.1). Якщо ручний аудит охоплює лише частину налаштувань, то автоматизована перевірка здатна покрити всі n налаштувань систематично. Залишкова ймовірність непоміченої помилки за автоматичної перевірки, що виявляє частку c помилок,

$$P_{\text{залиш}} = \big(1 - (1 - q)^n\big)(1 - c), \tag{13.2}$$

спадає зі зростанням покриття c. Формула (13.2) обґрунтовує, чому «інфраструктура як код» із автоматизованою перевіркою конфігурації — найдієвіший захід проти помилок конфігурації: вона наближає c до одиниці, систематично перевіряючи кожне налаштування проти еталону, тоді як ручний аудит масштабних систем залишає значну частину непокритою. Тестування виявляє поточні помилки, але стале їх запобігання дає саме автоматизація. Тестування систематично перевіряє конфігурацію на типові помилки.

13.5 Спеціалізовані середовища

Сучасна інфраструктура включає спеціалізовані середовища зі своєю специфікою (табл. 13.2). *Контейнери й оркестрація* [134]: ризики — небезпечні образи, надмірні привілеї контейнерів, незахищена керуюча площина оркестратора, слабка ізоляція. *IoT-пристрої* [49]: часто слабко захищені (типові паролі, застаріле ПЗ, відсутність оновлень), стали базою ботнетів. *Операційні технології* (ОТ/АСК ТП): критична інфраструктура з пріоритетом доступності, де тестування потребує особливої обережності (вплив на фізичні процеси).

Таблиця 13.2 — Спеціалізовані середовища та їх ризики

Середовище	Типові ризики	Особливість тестування
Контейнери	образи, привілеї, оркестрація	динамічність
IoT	типові паролі, застаріле ПЗ	масовість, слабкий захист
ОТ/АСК ТП	доступність, фізичні наслідки	максимальна обережність

Спільний принцип для спеціалізованих середовищ — *обережність* і врахування специфіки. Для ОТ особливо: активне тестування робочих систем може спричинити фізичні наслідки (зупинку процесу, аварію), тому його проводять із максимальною обережністю, часто на репліках чи в непродуктивному середовищі, за окремим узгодженням (розділ 2, принцип мінімізації шкоди). Для IoT і контейнерів тестування враховує масштаб і динамічність. У всіх випадках діє те саме правило: специфіка середовища визначає допустимі методи, а мінімізація шкоди — абсолютний пріоритет.

13.6 Кейс: тестування інфраструктури та хмари

Розглянемо тестування інфраструктури та хмарного середовища (продовження наскрізного прикладу).

Крок 1. Розмежування обсягу. Для хмари чітко розмежовуємо клієнтську зону (в обсязі) та інфраструктуру провайдера (поза обсягом, рис. 13.2), отримуємо потрібні дозволи.

Крок 2. Внутрішня мережа й каталоги. Тестуємо служби каталогів [94], будуємо граф атак (розділ 10), виявляємо шляхи до доменного адміністратора, перевіряємо мережеві пристрої й площину керування.

Крок 3. Конфігурація хмари. Перевіряємо клієнтську конфігурацію: сховища, IAM, налаштування сервісів, ключі доступу, керуючу площину — на типові помилки (13.1).

Крок 4. Спеціалізовані середовища. За наявності тестуємо контейнери, IoT із відповідною обережністю (табл. 13.2); для OT — лише за окремим узгодженням і з максимальною обережністю.

Крок 5. Захисні висновки. Формуємо рекомендації для звіту (розділ 16): найменші привілеї в каталогах, ізоляція площини керування, виправлення помилок конфігурації, автоматизований аудит налаштувань.

Кейс демонструє, що тестування інфраструктури й хмари зосереджується на зв'язності, довірчих відносинах і конфігурації — саме там, де в сучасних системах зосереджені найпоширеніші й найнебезпечніші слабкості.

Висновки до розділу

Мережева інфраструктура й хмара — основа сучасних систем і пріоритетні цілі з власною специфікою тестування. Внутрішнє тестування перевіряє зв'язність і довірчі відносини, а служби каталогів — головна ціль, бо визначають ребра графа атак і ведуть до повного захоплення мережі. Мережеві пристрої й особливо їх площина керування — критичні вузли, доступ до керування з недовірених мереж є найкоротшим шляхом до компрометації. Хмара змінює модель через спільну відповідальність (рис. 13.2): тестують клієнтську конфігурацію, а не інфраструктуру провайдера, і більшість інцидентів спричинена саме помилками клієнта. Помилки конфігурації стали домінантним класом (13.1), бо складність систем робить їх майже неминучими. Спеціалізовані середовища (контейнери, IoT, OT; табл. 13.2) потребують обережності й урахування специфіки, а для OT мінімізація шкоди — абсолютний пріоритет. Головний висновок: тестування інфраструктури й хмари зосереджується на зв'язності, довірчих відносинах і конфігурації, де в сучасних системах зосереджені найпоширеніші слабкості, а його захисні висновки орієнтують на найменші привілеї, ізоляцію керування, виправлення конфігурації й автоматизований аудит.

Питання для самоперевірки

1. Яку специфіку мають мережева інфраструктура й хмара як цілі тестування?

2. Що моделює внутрішнє тестування? Чому служби каталогів — головна ціль?
3. Що перевіряє тестування служб каталогів? Як воно пов'язане з графами атак (розділ 10)?
4. Чому мережеві пристрої — критичні вузли? Чому особливу увагу приділяють площині керування?
5. Що таке спільна відповідальність у хмарі (рис. 13.2)? Як вона визначає межі тестування?
6. Чому хмарне тестування зосереджується на конфігурації клієнта, а не на інфраструктурі провайдера?
7. Чому помилки конфігурації стали домінантним класом? Поясніть формулу (13.1).
8. Які захисні висновки випливають із домінування помилок конфігурації?
9. Назвіть спеціалізовані середовища та їх ризики (табл. 13.2).
10. Чому тестування ОТ потребує максимальної обережності? Як діє принцип мінімізації шкоди?
11. Чому для хмари часто потрібен окремий дозвіл провайдера?
12. Опишіть тестування інфраструктури та хмари (кейс підрозділу 13.6). На чому воно зосереджується?
13. Чому доступ до площини керування з недовірених мереж є найкоротшим шляхом до компрометації?
14. Дослідницьке: побудуйте граф атак служби каталогів навчальної мережі, виявіть шляхи до доменного адміністратора та запропонуйте заходи їх розриву.
15. Дослідницьке: дослідіть вплив кількості налаштувань (13.1) на ймовірність помилки конфігурації та оцініть ефективність автоматизованого аудиту конфігурації як контрзаходу.

РОЗДІЛ 14

Соціальна інженерія та фізичне тестування

Найдосконаліший технічний захист можна обійти, звернувшись не до системи, а до *людини*, яка нею керує. **Соціальна інженерія** — маніпулювання людьми з метою отримати доступ, інформацію чи дію — і **фізичне тестування** перевіряють нетехнічні вектори, якими реальні зловмисники користуються постійно й часто успішніше за технічні. Ця сфера особливо чутлива етично: об'єктом є *люди*, тому межі, згода й повага до гідності працівників стають першочерговими (розділ 2). Розділ розглядає людський чинник, принципи впливу, види соціальної інженерії, фізичне тестування, етичні межі саме цього виду тестування, захисні висновки (обізнаність), і завершується кейсом. Усі дії — виключно за явної авторизації, з особливими застереженнями щодо поводження з людьми.

14.1 Людський чинник

Людина — невіддільна частина будь-якої системи безпеки й часто її найвразливіша ланка [21]. Причина не в «дурості» користувачів, а в тому, що соціальна інженерія експлуатує *природні* людські властивості: схильність довіряти, допомагати, коритися авторитету, реагувати на терміновість. Ці властивості корисні в житті, але роблять людину вразливою до маніпуляції. Технічні заходи захищають систему, але людина лишається «інтерфейсом», через який можна обійти їх, переконавши когось відкрити доступ добровільно.

Значна частина реальних атак починається саме з людини: фішинговий лист, дзвінок від «служби підтримки», підроблений запит. Статистика інцидентів стабільно показує людський чинник як провідну причину компрометацій [44]. Тому тестування соціальної інженерії — не екзотика, а перевірка реалістичного й найпоширенішого вектора. Його мета — оцінити *обізнаність* персоналу й ефективність навчання, а не «зловити» конкретних працівників, що визначає особливу етику цього виду (розділ 14.5).

14.2 Принципи впливу

Соціальна інженерія спирається на психологічні **принципи впливу** [55, 72] (табл. 14.1): *авторитет* (люди коряться уявному начальству чи експертам), *терміновість/дефіцит* (тиск часу вимикає критичне мислення), *взаємність* (бажання віддячити), *соціальний доказ* (роблю, як інші), *симпатія* (довіра до приємних), *послідовність* (прагнення не суперечити попереднім ді-

ям). Маніпулятор комбінує їх, створюючи сценарій (претекст), що підштовхує жертву до потрібної дії.

Таблиця 14.1 — Принципи впливу в соціальній інженерії

Принцип	Як експлуатується
Авторитет	імітація начальства, служби підтримки
Терміновість	тиск часу, що вимикає перевірку
Взаємність	дрібна послуга в обмін на дію
Соціальний доказ	«усі так роблять»
Симпатія	приязнь, спільні інтереси
Страх	погроза наслідками за бездіяльність

Розуміння цих принципів — основа і *атаки*, і *захисту*. Для тестувальника вони пояснюють, чому сценарії працюють; для захисту — на що навчати персонал звертати увагу (нетипова терміновість, незвичні прохання від «авторитету», запити, що обходять процедури). Ключовий захисний висновок: оскільки експлуатуються природні властивості, захист спирається не на «заборону довіряти», а на *процедури* (перевірка особи за незалежним каналом, правила для чутливих дій) і *обізнаність* (розпізнавання ознак маніпуляції).

14.3 Види соціальної інженерії

Соціальна інженерія реалізується в різних формах [96, 39]: **фішинг** (масові оманливі повідомлення, зазвичай електронною поштою), **цільовий фішинг** (spear phishing — персоналізований під конкретну жертву, значно ефективніший), **вішинг** (телефоном), **претекстинг** (вигаданий сценарій для здобуття довіри), **приманка** (baiting — залишений носій чи принада). Спільне — створення правдоподібного контексту, що спонукає жертву до дії (клік, розкриття даних, надання доступу). Види соціальної інженерії зведено в табл. 14.2.

Таблиця 14.2 — Види соціальної інженерії

Вид	Канал/метод	Ефективність
Фішинг	масова пошта	низька на звернення
Цільовий фішинг	персоналізована пошта	висока
Вішинг	телефонний дзвінок	залежить від претексту
Претекстинг	вигаданий сценарій	основа решти
Приманка (baiting)	носій/принада	ситуативна

Ефективність соціальної інженерії зручно характеризувати часткою піддатливих. Якщо розіслано N звернень, а піддалися k, то рівень успіху

$$r_{\mathrm{SE}} = \frac{k}{N} \in [0;1], \tag{14.1}$$

є прямою метрикою вразливості персоналу. Формула (14.1) дає вимірюваний результат тестування: рівень успіху фішингу до й після навчання показує його ефективність. Важливо, що навіть низький r_{SE} небезпечний: зловмиснику достатньо *однієї* піддатливої людини (асиметрія, розділ 1), тому мета захисту — не лише знизити середній рівень, а й забезпечити, щоб навіть піддатливість окремого працівника не вела до компрометації (процедури, сегментація, найменші привілеї).

14.4 Фізичне тестування

Фізичне тестування [89] перевіряє фізичні заходи безпеки: контроль доступу до приміщень, захист обладнання, поводження з носіями й документами. Вектори: несанкціонований прохід (tailgating — прохід слідом за легітимною особою), доступ до незаблокованих робочих станцій, підглядання (shoulder surfing), доступ до викинутих документів і носіїв (dumpster diving), доступ до мережевих розеток і обладнання. Фізичний доступ часто зводить нанівець технічний захист: маючи фізичний доступ до пристрою, зловмисник обходить багато механізмів.

Фізичне тестування тісно переплітається із соціальною інженерією: прохід до приміщення зазвичай потребує переконати охорону чи працівників (авторитет, впевненість, претекст). Захисні висновки — контроль доступу (пропуски, шлюзи), політика «чистого столу», блокування станцій, безпечне знищення документів і носіїв, навчання персоналу не пропускати сторонніх. Як і в соціальній інженерії, фізичне тестування перевіряє *реалісти-*

чний вектор, яким користуються справжні зловмисники, і дає конкретні, часто прості й дешеві рекомендації.

14.5 Етичні межі цього виду тестування

Соціальна інженерія й фізичне тестування мають *особливі* етичні застереження, бо об'єктом є люди (розділ 2). Ключові принципи: тестують *процес і обізнаність*, а не конкретних осіб — результати знеособлюють, не використовують для покарання працівників; не завдають психологічної шкоди (уникають надмірно стресових сценаріїв, погроз, тем, що травмують); поважають гідність; суворо дотримуються погодженого обсягу (які сценарії дозволені, які теми заборонені); мають чітку авторизацію саме на цей вид (загальний дозвіл на технічне тестування не покриває маніпуляції людьми).



Рис. 14.1 — Етичні засади тестування соціальної інженерії

Особливо важливо: мета — *конструктивна*. Якщо тестування соціальної інженерії перетворюється на «виловлювання винних» чи їх покарання, воно шкодить: підриває довіру, формує культуру страху (а не повідомлення про інциденти, розділ 2), і зрештою знижує, а не підвищує захищеність. Правильне тестування знеособлює результати, подає їх як оцінку *системи* (процесів і навчання), а не провину людей, і веде до покращення навчання, а не до санкцій. Ця конструктивність — не м'якість, а умова ефективності: лише в культурі без звинувачень працівники повідомляють про підозрілі звернення, що й є головним захистом.

14.6 Захисні висновки: обізнаність та процедури

Головний захист від соціальної інженерії — *обізнаність* персоналу й *процедури* [51, 39]. Обізнаність: навчання розпізнавати ознаки маніпуляції (нетипова терміновість, незвичні прохання, обхід процедур), культура перевірки й повідомлення про підозріле. Проте саме лише навчання часто неефективне [51] — потрібні ще й *процедури*, що роблять безпечну поведінку типовою: перевірка особи за незалежним каналом для чутливих дій, правила підтвердження фінансових операцій, технічні заходи (фільтрація фішингу, багатофакторна автентифікація, що знижує цінність викрадених паролів).

Ключовий принцип — *глибокий захист*, що не покладається лише на бездоганність людини. Оскільки людину *завжди* можна обдурити (достатньо

однієї піддатливої особи (14.1)), захист проєктують так, щоб помилка однієї людини не вела до компрометації: багатофакторна автентифікація знижує цінність викраденого пароля, найменші привілеї обмежують наслідки, сегментація локалізує, моніторинг виявляє аномалії. Обізнаність зменшує ймовірність початкового успіху, а процедури й технічні заходи обмежують його наслідки — разом вони дають стійкість, якої не дає жоден захід окремо.



Рис. 14.2 — Глибокий захист від соціальної інженерії: обізнаність плюс процедури й технічні заходи

Ефект глибокого захисту зручно виразити кількісно. Якщо ймовірність початкового успіху маніпуляції — p (знижується обізнаністю), а технічні заходи й процедури обмежують імовірність того, що успіх переросте в компрометацію, коефіцієнтом m, то залишкова ймовірність компрометації

$$P_{\text{компр}} = p \cdot m, \tag{14.2}$$

де $m < 1$ за наявності багатофакторної автентифікації, найменших привілеїв, сегментації. Формула (14.2) пояснює, чому не можна покладатися лише на обізнаність (зниження p): навіть за доброго навчання p ніколи не дорівнює нулю, бо достатньо однієї піддатливої людини. Технічні заходи (зниження m) обмежують наслідки навіть успішної маніпуляції, тому саме їх поєднання з обізнаністю дає прийнятний $P_{\text{компр}}$. Це наскрізний принцип глибокого захисту, застосований до людського чинника.

14.7 Кейс: тестування соціальної інженерії

Розглянемо авторизоване тестування соціальної інженерії (продовження наскрізного прикладу).

Крок 1. Окрема авторизація й межі. Отримуємо явний дозвіл саме на цей вид (рис. 14.1), погоджуємо дозволені сценарії, заборонені теми, знеособлення результатів, конструктивну мету (навчання).

Крок 2. Розвідка. У межах обсягу збираємо OSINT (розділ 5) для правдоподібних сценаріїв (структура організації, ролі) — без втручання в приватне життя.

Крок 3. Проведення. Проводимо погоджені сценарії (наприклад, навчальний фішинг), фіксуючи знеособлену статистику реакцій (14.1), не завдаючи шкоди й не принижуючи.

Крок 4. Фізичний складник. За погодженням перевіряємо фізичні вектори (контроль доступу, політика чистого столу) з тими самими застереженнями.

Крок 5. Захисні висновки. Подаємо знеособлені результати як оцінку обізнаності й процедур, рекомендуємо навчання, процедури перевірки, технічні заходи (розділ 16) — без жодних санкцій до працівників.

Кейс демонструє, що тестування соціальної інженерії перевіряє найпоширеніший реальний вектор, але потребує особливої етики: конструктивної мети, знеособлення й поваги до людей, бо його цінність — у покращенні захисту, а не у викритті осіб.

Висновки до розділу

Найдосконаліший технічний захист можна обійти через людину, тому соціальна інженерія й фізичне тестування перевіряють нетехнічні вектори, якими реальні зловмисники користуються постійно й часто успішніше за технічні. Людський чинник — найвразливіша ланка не через «дурість», а тому, що соціальна інженерія експлуатує природні властивості (довіру, коритливість авторитету, реакцію на терміновість). Принципи впливу (табл. 14.1) — основа і атаки, і захисту. Види (фішинг, цільовий фішинг, вішинг, претекстинг) об'єднує створення правдоподібного контексту, а рівень успіху (14.1) — вимірювана метрика вразливості, причому достатньо однієї піддатливої людини. Фізичне тестування перевіряє контроль доступу й переплітається із соціальною інженерією. Цей вид має особливі етичні межі (рис. 14.1): оцінювати процес, а не осіб; без шкоди й покарань; конструктивна мета навчання. Головний захист — обізнаність і процедури, а глибокий захист забезпечує, щоб помилка однієї людини не вела до компрометації. Головний висновок: соціальна інженерія й фізичне тестування перевіряють найпоширеніший реальний вектор, але підпорядковані особливій етиці поваги до людей і конструктивній меті, а їх захисні висновки поєднують обізнаність, процедури й глибокий технічний захист.

Питання для самоперевірки

1. Чому людина часто є найвразливішою ланкою? Які природні властивості експлуатує соціальна інженерія?
2. Чому тестування соціальної інженерії — не екзотика, а перевірка реалістичного вектора?

3. Назвіть принципи впливу (табл. 14.1). Як розуміння їх служить і атаці, і захисту?
4. Чому захист спирається не на «заборону довіряти», а на процедури й обізнаність?
5. Назвіть види соціальної інженерії. Чому цільовий фішинг ефективніший за масовий?
6. Поясніть рівень успіху (14.1). Чому навіть низький рівень небезпечний?
7. Що перевіряє фізичне тестування? Як воно переплітається із соціальною інженерією?
8. Які особливі етичні застереження має цей вид тестування (рис. 14.1)? Чому об'єкт — люди — їх зумовлює?
9. Чому мета має бути конструктивною? Чим шкідливе «виловлювання винних»?
10. Чому потрібна окрема авторизація саме на соціальну інженерію?
11. Які захисні заходи ефективні? Чому саме лише навчання недостатнє?
12. Поясніть принцип глибокого захисту стосовно людського чинника. Як забезпечують, щоб помилка однієї людини не вела до компрометації?
13. Опишіть тестування соціальної інженерії (кейс підрозділу 14.7). Як дотримують етичних меж?
14. Дослідницьке: розробіть етичну методику навчального фішингу зі знеособленням результатів (14.1) та оцініть вплив навчання на рівень успіху до і після.
15. Дослідницьке: проаналізуйте ефективність поєднання обізнаності, процедур і технічних заходів (багатофакторна автентифікація) у зниженні наслідків успішної соціальної інженерії.

РОЗДІЛ 15

Red teaming, purple teaming та емуляція супротивника

Класичне тестування на проникнення оцінює *захищеність* об'єкта — знаходить якомога більше вразливостей у визначеному обсязі. Проте організацію цікавить і інше питання: чи здатен її захист *виявити* й *зупинити* реального, цілеспрямованого супротивника? На це відповідає **емуляція супротивника** (adversary emulation) та **red teaming** — прихована імітація конкретного актора з його реальними тактиками, що перевіряє не лише наявність вразливостей, а й спроможність оборони. **Purple teaming** поєднує атакувальну й захисну команди для спільного вдосконалення. Розділ розглядає відмінність red teaming від тестування, емуляцію супротивника на основі ATT&CK, прихованість (OPSEC), purple teaming, метрики спроможності виявлення, і завершується кейсом. Усі дії — у межах авторизації (розділ 2) та правил взаємодії (розділ 4).

15.1 Red teaming проти тестування на проникнення

Red teaming [50, 9] принципово відрізняється від тестування на проникнення метою й методом (табл. 15.1). Тестування на проникнення має на меті знайти *якомога більше* вразливостей у визначеному обсязі за відведений час — це перевірка *захищеності*. Red teaming має на меті досягти конкретної цілі (наприклад, доступ до критичних даних), діючи *приховано*, як реальний супротивник, — це перевірка *спроможності оборони* виявити й відреагувати. Red team не прагне знайти всі вразливості; йому достатньо *одного* шляху до мети, яким він пройде непомітно.

Таблиця 15.1 — Тестування на проникнення та red teaming

Ознака	Тестування на проникнення	Red teaming
Мета	багато вразливостей	досягти цілі
Прихованість	зазвичай відкрите	приховане
Перевіряє	захищеність	виявлення й реагування
Обсяг	визначений перелік	широкий, за ціллю
Обізнаність захисту	зазвичай знає	зазвичай не знає

Відмінність визначає й *обізнаність* сторони захисту: тестування зазвичай проводять із відома захисту (мета — знайти вразливості), red teaming — приховано від нього (мета — перевірити реакцію). Тому red teaming дорожчий, триваліший і потребує вищої кваліфікації, але відповідає на питання, яке тестування не покриває: чи готова оборона до реального цілеспрямова-

ного супротивника. Обидва підходи цінні й відповідають на різні питання, тому не конкурують, а доповнюють один одного в зрілій програмі безпеки (розділ 17).

Важливо розуміти *передумови* зрілості для red teaming. Воно має сенс лише тоді, коли організація вже має базовий рівень захисту й спроможність виявлення — інакше red team просто пройде скрізь без опору, і перевірка нічого не додасть до висновку «базовий захист відсутній», який дешевше дає звичайне тестування. Тому red teaming — інструмент *зрілих* організацій, що вже закрили очевидні вразливості (класичним тестуванням) і хочуть перевірити готовність до витонченого супротивника. Застосування red teaming до незрілої організації — марна трата ресурсів: спершу потрібні гігієна й базове виявлення, а вже потім перевірка їх проти цілеспрямованої емуляції. Це визначає послідовність у програмі безпеки: тестування на проникнення й усунення вразливостей передують red teaming, а не навпаки.

15.2 Емуляція супротивника на основі ATT&CK

Емуляція супротивника — відтворення тактик, технік і процедур (TTP) *конкретного* реального угруповання, релевантного для організації. На відміну від довільного «зламу», вона спирається на розвідку загроз: які угруповання ймовірно атакуватимуть цю організацію, якими TTP вони користуються. Основа — матриця MITRE ATT&CK [137, 16], що каталогізує реальні TTP; інструменти (CALDERA [136], Atomic Red Team [124]) допомагають відтворювати техніки систематично. Для фінансового сектору — рамка TIBER-EU [65] (розвідувально-кероване red teaming).

Цінність емуляції — у *релевантності й вимірюваності*. Відтворюючи саме ті TTP, що їх застосовують релевантні угруповання, тестування перевіряє готовність до *реальних*, а не абстрактних загроз. Покриття технік ATT&CK дає вимірюваний результат:

$$\mathrm{Cov}_{\text{вияв}} = \frac{|T_{\text{виявлено}}|}{|T_{\text{застосовано}}|} \in [0;1], \tag{15.1}$$

де $T_{\text{застосовано}}$ — техніки, що їх застосував red team, $T_{\text{виявлено}}$ — виявлені стороною захисту. Формула (15.1) прямо вимірює спроможність виявлення: вона показує, яку частку реальних технік захист здатен помітити, і виявляє *сліпі зони* — техніки, що пройшли непоміченими. Це перетворює абстрактне «наш моніторинг добрий» на конкретну, виміряну оцінку готовності.

15.3 Прихованість та OPSEC

Оскільки red teaming перевіряє *виявлення*, **прихованість** (OPSEC — operational security) є центральною: якщо захист одразу помітить red team, перевірка втратить сенс (окрім позитивного висновку про виявлення). Red

team мінімізує сліди, діє повільно й обережно, імітує легітимну активність, уникає «гучних» технік, що спрацьовують на моніторингу. Це дзеркально до керування помітністю на етапах розвідки й сканування (розділи 5, 6), але застосоване наскрізно до всієї операції.

Прихованість створює природне *напруження* з безпекою й контролем: приховані дії складніше контролювати й зупиняти. Тому red teaming потребує особливо ретельних правил взаємодії (розділ 4): довіреного контакту з боку замовника (зазвичай вузьке коло, що знає про операцію), чітких меж, механізму негайної зупинки, порядку дій за реального інциденту (щоб дії red team не сплутали з реальною атакою й навпаки). Баланс між реалістичністю (прихованість) і контрольованістю (безпека) — ключовий виклик планування red teaming.

15.4 Purple teaming

Purple teaming [105, 123] — не окрема команда, а *режим взаємодії* атакувальної (red) та захисної (blue) команд. Замість суто змагального сценарію (red проти blue наосліп) вони працюють *спільно*: red застосовує техніку, blue одразу перевіряє, чи виявив її, і якщо ні — спільно вдосконалюють виявлення, після чого повторюють. Це перетворює одноразову перевірку на *ітеративне вдосконалення* спроможності виявлення.

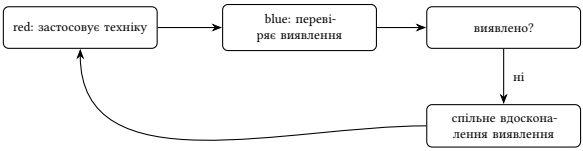


Рис. 15.1 — Цикл purple teaming: ітеративне вдосконалення виявлення

Перевага purple teaming — *ефективність навчання*. Суто red teaming дає оцінку («ось що ми пройшли непомітно»), але blue вчиться повільно (постфактум зі звіту). Purple teaming дає негайний зворотний зв'язок: blue бачить техніку в момент застосування й одразу налаштовує виявлення, перевіряючи результат. Це прямо живить інженерію виявлення (створення правил під кожну техніку), систематично закриваючи сліпі зони (15.1). Тому purple teaming — ефективний спосіб *підвищувати* спроможність виявлення, а не лише *вимірювати* її.

15.5 Метрики спроможності виявлення

Red і purple teaming дають метрики, яких не дає класичне тестування (табл. 15.2): *покриття виявлення* (15.1) (яку частку технік помічено), *час до виявлення* (як швидко), *час до реагування* (як швидко стримано), *час присутності* (dwell time [91] — як довго red team діяв непомітно). Ці метрики оцінюють не захищеність об'єкта, а *зрілість оборони* — її здатність помічати й реагувати.

Таблиця 15.2 — Метрики спроможності виявлення

Метрика	Що оцінює
Покриття виявлення	частку технік, що їх помічено
Час до виявлення	швидкість помічання
Час до реагування	швидкість стримування
Час присутності (dwell)	як довго супротивник діяв непомітно

Час присутності — особливо показова метрика: що довше red team діяв непоміченим, то довше діяв би реальний супротивник, завдаючи шкоди. Скорочення dwell time — стратегічна мета оборони, і red/purple teaming прямо його вимірює й допомагає скорочувати. Час присутності складається з часу до виявлення й часу до стримування:

$$T_{\text{dwell}} = T_{\text{виявл}} + T_{\text{реаг}}, \tag{15.2}$$

де $T_{\text{виявл}}$ — від компрометації до виявлення, $T_{\text{реаг}}$ — від виявлення до стримування. Формула (15.2) показує, що скоротити dwell time можна з двох боків: кращим виявленням (менше $T_{\text{виявл}}$, що дає покриття (15.1)) і швидшим реагуванням (менше $T_{\text{реаг}}$). Red teaming вимірює обидві складові, а purple teaming допомагає скорочувати першу, систематично закриваючи сліпі зони виявлення.

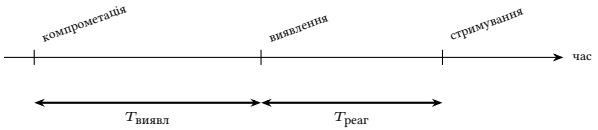


Рис. 15.2 — Складові часу присутності: час до виявлення й час до реагування

Ці метрики перетворюють абстрактну готовність на вимірювані показники, що їх можна відстежувати в часі, демонструючи прогрес зрілості оборони, — що особливо цінно для управління безпекою (розділ 17).

15.6 Кейс: емуляція супротивника

Розглянемо емуляцію супротивника для перевірки спроможності оборони (продовження наскрізного прикладу).

Крок 1. Розвідка загроз і план. Визначаємо релевантне угруповання та його TTP за ATT&CK, формулюємо ціль операції й план емуляції [136].

Крок 2. Правила взаємодії. Погоджуємо приховане проведення, довірений контакт, межі, механізм зупинки, порядок за реального інциденту (розділ 4).

Крок 3. Прихована операція. Відтворюємо TTP угруповання, діючи приховано (OPSEC), прагнучи цілі й фіксуючи застосовані техніки.

Крок 4. Оцінка виявлення. Зіставляємо застосовані техніки з виявленими стороною захисту (15.1), вимірюємо час до виявлення й реагування, час присутності (табл. 15.2).

Крок 5. Purple-режим і вдосконалення. Переходимо в purple-режим (рис. 15.1): спільно з blue закриваємо виявлені сліпі зони, створюючи правила виявлення, і повторно перевіряємо.

Кейс демонструє, що емуляція супротивника відповідає на питання, якого не покриває класичне тестування — чи готова оборона до реального супротивника, — і через purple-режим не лише вимірює, а й підвищує спроможність виявлення.

Висновки до розділу

Red teaming принципово відрізняється від тестування на проникнення (табл. 15.1): воно перевіряє не захищеність об'єкта, а спроможність оборони виявити й зупинити цілеспрямованого супротивника, діючи приховано й прагнучи цілі, а не переліку вразливостей. Емуляція супротивника відтворює TTP конкретного релевантного угруповання за ATT&CK, що дає релевантність і вимірюване покриття виявлення (15.1), виявляючи сліпі зони. Прихованість (OPSEC) центральна, бо перевіряється виявлення, і створює напруження з контролем, що потребує ретельних правил взаємодії. Purple teaming (рис. 15.1) поєднує red і blue для ітеративного вдосконалення виявлення з негайним зворотним зв'язком, не лише вимірюючи, а й підвищуючи спроможність. Метрики (табл. 15.2) — покриття виявлення, час до виявлення й реагування, час присутності — оцінюють зрілість оборони. Головний висновок: red і purple teaming відповідають на питання готовності оборони до реального супротивника, якого не покриває класичне тестування; емуляція на основі ATT&CK робить перевірку релевантною й вимірюваною, а purple-режим перетворює її на інструмент систематичного підвищення спроможності виявлення.

Питання для самоперевірки

1. Чим red teaming принципово відрізняється від тестування на проникнення (табл. 15.1)?
2. Чому red team достатньо одного шляху до мети, а не всіх вразливостей?
3. Чому відрізняється обізнаність сторони захисту в тестуванні й red teaming? Чому обидва підходи доповнюють один одного?
4. Що таке емуляція супротивника? Чому вона спирається на розвідку загроз і ATT&CK?
5. Поясніть покриття виявлення (15.1). Як воно виявляє сліпі зони?
6. Чому прихованість (OPSEC) центральна для red teaming? Як вона дзеркальна до керування помітністю?
7. Яке напруження створює прихованість? Які правила взаємодії його розв'язують?
8. Що таке purple teaming (рис. 15.1)? Чим воно ефективніше за суто red teaming для навчання?
9. Як purple teaming живить інженерію виявлення й закриває сліпі зони?
10. Назвіть метрики спроможності виявлення (табл. 15.2). Чому час присутності особливо показовий?
11. Чому ці метрики цінні для управління безпекою?
12. Опишіть емуляцію супротивника (кейс підрозділу 15.6). Як поєднують red- і purple-режими?
13. Чому red teaming дорожчий і потребує вищої кваліфікації, ніж тестування?
14. Дослідницьке: сплануйте емуляцію обраного угруповання за ATT&CK, визначте застосовні техніки й оцініть покриття виявлення (15.1) на навчальному середовищі.
15. Дослідницьке: проведіть цикл purple teaming (рис. 15.1) для набору технік і виміряйте приріст покриття виявлення до і після спільного вдосконалення.

РОЗДІЛ 16

Звітування, документування та комунікація результатів

Технічна майстерність тестування втрачає цінність, якщо результати не донесено до тих, хто має діяти. **Звіт** — головний продукт тестування (розділ 1): саме він перетворює знайдені вразливості на *дії* з посилення захисту. Найкраще проведене тестування, оформлене незрозумілим чи непридатним до дії звітом, не досягає мети. Тому звітування й комунікація — не формальність наприкінці, а визначальна складова професії, що потребує окремих навичок. Розділ розглядає роль і призначення звіту, його структуру й аудиторії, опис знахідок і доказів, оцінювання й пріоритезацію, рекомендації, комунікацію й повторне тестування, і завершується кейсом. Матеріал завершує процес тестування, перетворюючи результати попередніх етапів на цінність для замовника.

16.1 Роль і призначення звіту

Звіт — не протокол дій тестувальника, а *інструмент прийняття рішень* замовником [122, 4]. Його мета — дати організації чітке розуміння: які ризики виявлено, наскільки вони серйозні, що з ними робити й у якому порядку. Звіт має бути *зрозумілим* (для різних аудиторій), *достовірним* (підтверджені, валідовані знахідки, розділ 7), *придатним до дії* (конкретні рекомендації), *пріоритезованим* (що найважливіше). Кінцевий критерій якості звіту — чи привів він до реального посилення захисту.

Поширена помилка — оцінювати тестування за технічною складністю знайдених вразливостей, а не за якістю звіту. Насправді замовник не бачить самого процесу — він бачить *звіт*, і саме звіт визначає, чи буде користь. Тому професіонал приділяє звітуванню не менше уваги, ніж технічній роботі: блискуче проникнення, погано задокументоване, марне, а скромна знахідка, чітко описана з придатною рекомендацією, дає реальну цінність. Це зміщення фокуса з «що я зламав» на «що замовник з цим зробить» — ознака професійної зрілості.

16.2 Структура та аудиторії

Звіт адресований *різним аудиторіям* з різними потребами (табл. 16.1), тому має кілька рівнів. **Резюме для керівництва** (executive summary) — стислий, нетехнічний виклад загального стану, ключових ризиків і рекомендацій для осіб, що ухвалюють рішення й виділяють ресурси. **Технічна частина** — детальний опис знахідок із доказами й рекомендаціями для фахівців, що

усуватимуть. **Методологія й обсяг** — що, як і в яких межах тестувалося (для контексту й повторюваності).

Таблиця 16.1 — Аудиторії звіту та їх потреби

Аудиторія	Потреба	Частина звіту
Керівництво	загальний ризик, рішення	резюме
Технічні фахівці	деталі й усунення	технічна частина
Аудитори/регулятори	відповідність, обсяг	методологія

Критична навичка — *адаптація до аудиторії* [19]. Керівництву не потрібні технічні деталі — йому потрібен бізнес-ризик і рішення; фахівцю не досить «є вразливість» — потрібні кроки відтворення й усунення. Одна й та сама знахідка подається по-різному для різних читачів. Нездатність говорити мовою аудиторії — поширена причина, чому хороше технічне тестування не веде до дій: керівництво не зрозуміло ризику, тому не виділило ресурсів. Тому резюме для керівництва пишуть мовою бізнесу (вплив, ризик, вартість), а не техніки.

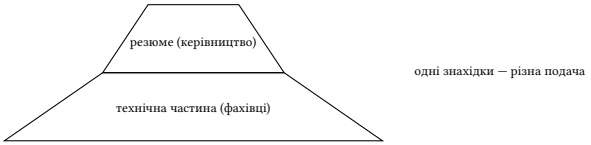


Рис. 16.1 — Рівні звіту: резюме для керівництва над детальною технічною частиною

16.3 Опис знахідок і доказів

Кожну знахідку описують структуровано: *назва й опис* (що це), *розташування* (де), *вплив* (що дає зловмиснику), *серйозність/ризик* (наскільки критично), *доказ* (підтвердження, PoC, розділ 8), *кроки відтворення* (щоб замовник перевірив і згодом підтвердив усунення), *рекомендація* (як усунути). Доказ критичний: він підтверджує реальність (а не припущення) і дозволяє замовнику переконатися й відтворити. Докази подають із мінімізацією — без надмірного розкриття чутливих даних (розділ 2). Структуру опису знахідки зведено в табл. 16.2.

Таблиця 16.2 — Структура опису знахідки

Елемент	Призначення
Назва й опис	що це за вразливість
Розташування	де в системі
Вплив	що дає зловмиснику
Серйозність/ризик	наскільки критично
Доказ (PoC)	підтвердження реальності
Кроки відтворення	перевірка й підтвердження усунення
Рекомендація	як усунути

Якість опису знахідки визначає, чи буде її усунено. Нечіткий опис («знайдено SQL-ін'єкцію») без розташування, доказу й кроків лишає фахівця без змоги діяти. Якісний опис дає все потрібне для розуміння, підтвердження й усунення. Корисна дисципліна — писати знахідку так, щоб фахівець, який не брав участі в тестуванні, міг самостійно її відтворити й усунути. Це вимагає ретельного документування *під час* робіт (розділ 9): звіт лише настільки добрий, наскільки повні нотатки, зроблені в процесі.

16.4 Оцінювання та пріоритезація

Знахідки *оцінюють* за серйозністю й пріоритезують за ризиком (розділ 7). Для єдиної, зрозумілої оцінки застосовують шкали (CVSS [66] для серйозності) з урахуванням контексту (ризик (16.1) для пріоритету). Ключова мета — дати замовнику *порядок дій*: що усувати першим. Звіт без пріоритезації (простий перелік) малокорисний; звіт із чітким ранжуванням за ризиком спрямовує обмежені ресурси на найважливіше.

Пріоритет знахідки визначає ризик — добуток імовірності й впливу з урахуванням контексту:

$$R = P_{\text{експл}} \cdot I_{\text{бізнес}}, \tag{16.1}$$

де $P_{\text{експл}}$ — імовірність експлуатації (підтверджена тестуванням, а отже висока для доведених знахідок), $I_{\text{бізнес}}$ — вплив на бізнес. Формула (16.1) підкреслює: пріоритезують за *бізнес-впливом*, а не лише за технічною серйозністю. Вразливість, що дає доступ до критичних даних, пріоритетніша за технічно «гучну», але малозначущу в контексті. Переклад технічних знахідок на мову бізнес-ризику — ключова навичка, що робить звіт корисним для рішень керівництва.

16.5 Рекомендації, комунікація та повторне тестування

Рекомендації — серце практичної цінності звіту. Для кожної знахідки дають конкретну, здійсненну пораду з усунення (не «зробіть безпечніше», а

«застосуйте параметризовані запити»). Корисно розрізняти *тактичні* рекомендації (усунути конкретну знахідку) і *стратегічні* (усунути *клас* проблем, першопричину): якщо знайдено багато схожих вразливостей, цінніше вказати системну причину (брак практики безпечної розробки, розділ 1), а не лише кожен випадок.

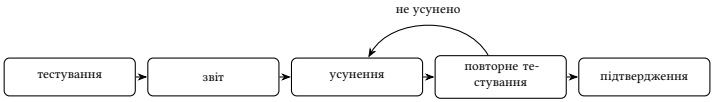


Рис. 16.2 — Цикл від тестування через звіт і усунення до повторного тестування

Комунікація — не лише письмовий звіт, а й презентація результатів, обговорення, відповіді на запитання. *Повторне тестування* (retest [114]) — перевірка, що знахідки справді усунено, — замикає цикл (рис. 16.2): без нього невідомо, чи дало тестування реальний ефект. Повторне тестування перетворює звіт із переліку проблем на підтверджене покращення й часто є частиною послуги. Саме цей замкнутий цикл — від знахідки через усунення до підтвердження — реалізує кінцеву мету тестування: не знайти вразливості, а домогтися їх усунення.

Реальний ефект тестування вимірюється не кількістю знахідок, а *часткою усунених*. Якщо виявлено V знахідок, а через узгоджений час усунено (підтверджено повторним тестуванням) $V_{\text{усун}}$, то коефіцієнт усунення

$$\mathrm{Rem} = \frac{V_{\text{усун}}}{V} \in [0;1], \tag{16.2}$$

є кінцевою метрикою успіху всієї роботи. Формула (16.2) зміщує фокус із виявлення на результат: тестування, що виявило багато вразливостей, жодну з яких не усунено ($\mathrm{Rem} = 0$), не підвищило захищеності. Високий коефіцієнт усунення залежить не лише від замовника, а й від якості звіту: зрозумілі, пріоритезовані, придатні до дії рекомендації безпосередньо підвищують Rem. Тому фахівець, зацікавлений у реальному результаті, пише звіт так, щоб усунення було *максимально легким*, — і саме це, а не кількість знахідок, є мірою його професійного успіху.

16.6 Кейс: звітування за результатами тестування

Розглянемо підготовку звіту (продовження наскрізного прикладу).

Крок 1. Структура для аудиторій. Готуємо резюме для керівництва (бізнес-ризик, рішення), технічну частину (деталі, усунення), опис методології й обсягу (табл. 16.1).

Крок 2. Опис знахідок. Для кожної знахідки описуємо розташування, вплив, доказ (PoC), кроки відтворення й рекомендацію, спираючись на нотатки, зроблені під час робіт (розділ 9).

Крок 3. Пріоритезація. Оцінюємо серйозність (CVSS) і пріоритезуємо за бізнес-ризиком (16.1), даючи чіткий порядок усунення.

Крок 4. Рекомендації. Формуємо тактичні (кожна знахідка) і стратегічні (класи проблем, першопричини) рекомендації, конкретні й здійсненні.

Крок 5. Комунікація й повторне тестування. Презентуємо результати, адаптуючи до аудиторії; погоджуємо повторне тестування для підтвердження усунення (рис. 16.2).

Кейс демонструє, що звіт перетворює технічну роботу на цінність для замовника: адаптований до аудиторій, достовірний, пріоритезований і придатний до дії, він веде до реального усунення вразливостей, що й є кінцевою метою тестування.

Висновки до розділу

Звіт — головний продукт тестування, що перетворює знайдені вразливості на дії з посилення захисту; найкраще тестування з поганим звітом не досягає мети. Звіт — інструмент прийняття рішень, що має бути зрозумілим, достовірним, придатним до дії й пріоритезованим, а його якість вимірюється реальним посиленням захисту. Звіт адресований різним аудиторіям (табл. 16.1) і потребує адаптації: резюме для керівництва мовою бізнесу, технічна частина для фахівців. Кожну знахідку описують структуровано з доказом і кроками відтворення, спираючись на ретельні нотатки з процесу. Знахідки пріоритезують за бізнес-ризиком (16.1), а не лише технічною серйозністю. Рекомендації мають бути конкретними, тактичними й стратегічними (першопричини), а повторне тестування замикає цикл (рис. 16.2), підтверджуючи усунення. Головний висновок: звітування й комунікація — визначальна складова професії, що перетворює технічну роботу на цінність; кінцева мета — не знайти вразливості, а через зрозумілий, пріоритезований, придатний до дії звіт і підтверджене усунення домогтися реального посилення захисту.

Питання для самоперевірки

1. Чому звіт — головний продукт тестування? Яка його кінцева мета?
2. Чому звіт — інструмент прийняття рішень, а не протокол дій? Яким він має бути?
3. Чому помилково оцінювати тестування за складністю знахідок, а не за якістю звіту?

4. Які аудиторії має звіт (табл. 16.1)? Чому потрібна адаптація до аудиторії?
5. Чому резюме для керівництва пишуть мовою бізнесу? Що стається, коли цього не роблять?
6. Як структуровано описують знахідку? Чому доказ і кроки відтворення критичні?
7. Чому звіт лише настільки добрий, наскільки повні нотатки з процесу?
8. Чому пріоритезація критична? Поясніть пріоритезацію за бізнес-ризиком (16.1).
9. Чому пріоритезують за бізнес-впливом, а не лише технічною серйозністю?
10. Розрізніть тактичні та стратегічні рекомендації. Коли цінніші стратегічні?
11. Що таке повторне тестування? Чому воно замикає цикл (рис. 16.2)?
12. Опишіть підготовку звіту (кейс підрозділу 16.6). Як звіт перетворює роботу на цінність?
13. Чому кінцева мета — не знайти вразливості, а домогтися їх усунення?
14. Дослідницьке: підготуйте звіт за результатами навчального тестування з резюме для керівництва й технічною частиною та оцініть його придатність до дії для різних аудиторій.
15. Дослідницьке: дослідіть, як формулювання рекомендацій (тактичні проти стратегічних) впливає на усунення класів вразливостей, на модельному наборі знахідок.

РОЗДІЛ 17

Професійний розвиток та управління програмою тестування

Тестування на проникнення — не разова дія, а *професія* й організаційна *функція*, що потребують постійного розвитку. Ландшафт загроз, технології й методи змінюються швидше за будь-яку разову підготовку, тому компетентність підтримують безперервно, а поодинокі тести перетворюють на зрілу **програму** регулярного оцінювання захищеності. Цей завершальний розділ піднімається з рівня окремого тестування на рівень кар'єри й організації, синтезуючи весь посібник. Розділ розглядає професійні компетентності, сертифікацію й навчання, кар'єрні шляхи й етичну зрілість, побудову програми тестування, її зрілість і місце в управлінні безпекою, національний вимір для України, і завершується кейсом побудови програми. Матеріал узагальнює етику (розділ 2), методологію (розділ 3) і весь цикл тестування в цілісну професійну й організаційну перспективу.

17.1 Професійні компетентності

Фахівець із тестування потребує широкого спектра компетентностей (табл. 17.1): *технічні* (мережі, ОС, застосунки, протоколи, програмування), *методологічні* (розділ 3), *аналітичні* (мислення атакувальника, виявлення ланцюгів), *комунікаційні* (звітування, розділ 16), *етико-правові* (розділ 2). Особливість професії — поєднання *глибини* (експертиза в конкретних галузях) і *широти* (розуміння всієї поверхні атаки), а також *технічних* і *нетехнічних* навичок водночас.

Таблиця 17.1 — Компетентності фахівця з тестування

Група	Зміст
Технічні	мережі, ОС, застосунки, програмування
Методологічні	стандарти, процес, повнота
Аналітичні	мислення атакувальника, ланцюги
Комунікаційні	звітування, презентація, адаптація
Етико-правові	авторизація, межі, відповідальність

Поширена помилка — зводити професію до технічних навичок. Насправді цінність фахівця визначає *поєднання*: технічна майстерність без комунікації не доносить результату (розділ 16), без етики — небезпечна (розділ 2), без методології — несистематична (розділ 3), без аналітичного мислення — поверхнева. Саме баланс усіх груп робить фахівця цінним, тому розвиток

не можна зводити до опанування інструментів — він охоплює всі компетентності.

17.2 Сертифікація та навчання

Сертифікація [107, 61, 129, 35] підтверджує компетентність і структурує навчання. Практичні сертифікації (на кшталт OSCP [107]) перевіряють реальні навички в контрольованому середовищі; інші (CEH [61], GPEN [129]) охоплюють знання методологій і технік. Сертифікація цінна подвійно: як орієнтир навчання (структурований шлях) і як сигнал кваліфікації для замовників. Проте вона — не самоціль і не заміна реального досвіду: сертифікат підтверджує базовий рівень, а майстерність формується практикою. Типи сертифікацій зіставлено в табл. 17.2.

Таблиця 17.2 — Типи сертифікацій (узагальнено)

Тип	Що перевіряє
Практичні (напр., OSCP)	реальні навички в контрольованому середовищі
Знаннєві (напр., CEH)	знання методологій і технік
Спеціалізовані	навички у вузькій галузі (веб, red team)
Управлінські	організацію й управління безпекою

Ключова особливість професії — потреба в *безперервному* навчанні [35]. Загрози, технології, техніки постійно еволюціонують, тому знання швидко застарівають. Фахівець підтримує актуальність постійно: вивчає нові техніки й захисти, практикується на полігонах і в CTF (у легальному середовищі, розділ 2), стежить за дослідженнями, бере участь у спільноті. Практику *завжди* відпрацьовують у дозволених середовищах — на власних системах, навчальних полігонах, лабораторіях, CTF — ніколи на чужих системах без авторизації. Ця дисципліна навчання — частина професійної етики.

17.3 Кар'єрні шляхи та етична зрілість

Професія пропонує різні *шляхи*: від універсального тестувальника до спеціалізації (веб, мережі, безпроводове, red teaming), від виконавця до керівника програми чи консультанта, від зовнішнього підрядника до внутрішньої команди. Поза технічним зростанням критичним є розвиток *етичної зрілості* (розділи 2, 14): здатність діяти правильно в сірих зонах, зберігати довіру, ставити відповідальність вище технічного результату. Професійні кодекси етики [46] задають орієнтири, але зрілість формується досвідом і рефлексією.

Етична зрілість — не додаток до професії, а її *серцевина.* Фахівець із тестування має доступ до потужних технік і чутливої інформації; довіра до

нього — головний капітал, а її втрата незворотна (розділ 2). Спокуса застосувати навички поза межами (цікавість, вигода, тиск) супроводжує професію, і здатність їй протистояти визначає, чи лишається фахівець *етичним*. Тому професійний розвиток у цій сфері нерозривно поєднує зростання технічне й етичне: без другого перше стає небезпечним. Саме це робить підготовку фахівців із тестування особливо відповідальною — вона формує не лише вміння, а й характер.

17.4 Побудова програми тестування

На рівні організації поодинокі тести перетворюють на **програму** [31] — регулярне, систематичне оцінювання захищеності, інтегроване в управління безпекою. Ключові рішення: *внутрішня команда чи зовнішні підрядники* (внутрішня — глибше знання контексту, безперервність; зовнішня — свіжий погляд, незалежність, спеціалізація; часто поєднують), *регулярність* (одноразове тестування дає миттєвий зріз, регулярне — відстежує динаміку), *обсяг програми* (що й як часто тестувати за ризиком), *інтеграція* з розробкою, моніторингом, управлінням ризиками.



Рис. 17.1 — Програма тестування як безперервний цикл, а не разова дія

Цінність програми (на відміну від поодиноких тестів) — у *динаміці* й *системності*. Регулярне тестування відстежує, чи зростає захищеність у часі, чи усуваються знахідки (коефіцієнт усунення (16.2)), чи не з'являються нові проблеми. Воно інтегрується в цикл безпеки (розділ 1): результати живлять усунення, навчання, покращення процесів розробки. Програма перетворює тестування з епізодичної перевірки на постійний механізм підтримання й підвищення захищеності, що є ознакою зрілого управління безпекою.

Ефект регулярності зручно осмислити через динаміку залишкового ризику. Якщо кожен цикл тестування й усунення знижує залишковий ризик із коефіцієнтом $(1-\rho)$, де ρ — частка ризику, усунена за цикл, то після k циклів залишковий ризик

$$R_k = R_0(1-\rho)^k + R_{\text{нов}}, \tag{17.1}$$

де R_0 — початковий ризик, а $R_{\text{нов}}$ — ризик, що *додається* між циклами (нові системи, нові загрози). Формула (17.1) пояснює дві речі: регулярне

тестування систематично знижує накопичений ризик (член $R_0(1-\rho)^k$ спадає), але через постійний приплив нового ризику $R_{\text{нов}}$ одноразове тестування недостатнє — потрібна саме *програма*, що компенсує новий ризик. Це математичне обґрунтування переходу від поодиноких тестів до регулярної програми: без неї усунене з часом заміщується новим.

17.5 Зрілість програми та національний вимір

Програму тестування характеризують *зрілістю* [95]: від епізодичних реактивних тестів до систематичної, вимірюваної, інтегрованої програми з відстеженням динаміки й постійним вдосконаленням. Інтегральну зрілість зручно подати зваженою оцінкою за вимірами (регулярність, покриття, інтеграція, усунення):

$$M = \sum_{i} w_i \, m_i, \qquad \sum_{i} w_i = 1, \; m_i \in [0;1], \tag{17.2}$$

де m_i — оцінка i-го виміру, w_i — його вага. Формула (17.2) дозволяє відстежувати прогрес і планувати вдосконалення, а моделі зрілості (BSIMM) дають конкретні виміри. Як і раніше, метрики служать вдосконаленню, а не формальності: висока зрілість — не самоціль, а засіб реального підвищення захищеності.



Рис. 17.2 — Рівні зрілості програми тестування

Національний вимір для України має стратегічне значення. Стратегія кібербезпеки України [36] визначає розвиток спроможностей оцінювання захищеності як складову національної кіберстійкості, а безпрецедентна інтенсивність кібератак робить підготовку кваліфікованих, етичних фахівців із тестування питанням національної безпеки. Попит на таких фахівців значно перевищує пропозицію, тому їх підготовка — зокрема через освітньо-наукові програми, що їх обслуговує цей посібник, — є внеском у захищеність держави. Етичність і професіоналізм цих фахівців критичні: вони володіють потужними навичками, які мають служити виключно захисту.

17.6 Кейс: побудова програми тестування

Завершимо наскрізний приклад побудовою програми тестування для організації.

Крок 1. Контекст і цілі. Визначаємо модель загроз (розділ 4), критичні активи, регуляторні вимоги, апетит до ризику — основу для планування програми.

Крок 2. Модель виконання. Обираємо поєднання внутрішньої команди (контекст, безперервність) і зовнішніх підрядників (незалежність, спеціалізація) за потребами й зрілістю.

Крок 3. План за ризиком. Визначаємо, що й як часто тестувати (рис. 17.1): критичні системи — регулярно, нові — перед релізом, уся інфраструктура — періодично; додаємо red teaming для зрілих компонентів (розділ 15).

Крок 4. Інтеграція й усунення. Інтегруємо результати в усунення, навчання, розробку; відстежуємо коефіцієнт усунення (16.2) й динаміку захищеності.

Крок 5. Зрілість і розвиток. Оцінюємо зрілість програми (17.2), плануємо вдосконалення, підтримуємо безперервний розвиток компетентностей команди (табл. 17.1).

Кейс синтезує весь посібник: від етичних і правових засад через методологію й етапи тестування до звітування й управління програмою — показуючи, як окремі тести складаються в зрілу функцію, що постійно підтримує й підвищує захищеність організації легітимними, професійними засобами.

Висновки до розділу

Тестування на проникнення — професія й організаційна функція, що потребують постійного розвитку, бо ландшафт загроз змінюється швидше за будь-яку разову підготовку. Фахівець потребує поєднання компетентностей — технічних, методологічних, аналітичних, комунікаційних, етико-правових (табл. 17.1), — і зведення професії до технічних навичок є помилкою. Сертифікація структурує навчання й сигналізує кваліфікацію, але не замінює досвіду, а безперервне навчання (на полігонах і CTF, завжди в дозволених середовищах) є обов'язковим. Етична зрілість — серцевина професії, бо фахівець володіє потужними техніками, а довіра до нього незворотна; професійний розвиток нерозривно поєднує технічне й етичне зростання. На рівні організації поодинокі тести перетворюють на програму (рис. 17.1), цінність якої — у динаміці, системності й інтеграції, а зрілість (17.2) відстежують і вдосконалюють. Для України підготовка етичних фахівців із тестування — питання національної безпеки. Головний і завершальний висновок: ефективне тестування на проникнення — це не набір технік, а зріла професія й організаційна функція, що поєднують технічну майстерність, методологічну дисципліну, комунікацію й непохитну етику задля єдиної мети — легітимного підвищення захищеності.

Питання для самоперевірки

1. Чому тестування на проникнення — професія й функція, що потребують постійного розвитку?
2. Назвіть групи компетентностей фахівця (табл. 17.1). Чому зведення професії до технічних навичок є помилкою?
3. Яку подвійну цінність має сертифікація? Чому вона не замінює досвіду?
4. Чому безперервне навчання обов'язкове? Де допустимо відпрацьовувати практику?
5. Які кар'єрні шляхи пропонує професія? Чому етична зрілість є її серцевиною?
6. Чому професійний розвиток нерозривно поєднує технічне й етичне зростання?
7. Що таке програма тестування? Які ключові рішення її визначають?
8. Порівняйте внутрішню команду й зовнішніх підрядників. Чому їх часто поєднують?
9. У чому цінність програми порівняно з поодинокими тестами (рис. 17.1)?
10. Що таке зрілість програми? Поясніть інтегральну оцінку (17.2).
11. У чому національний вимір підготовки фахівців із тестування для України?
12. Опишіть побудову програми тестування (кейс підрозділу 17.6). Як вона синтезує посібник?
13. Чому підготовка фахівців із тестування є особливо відповідальною?
14. Дослідницьке: розробіть план професійного розвитку фахівця з тестування з переліком компетентностей (табл. 17.1), сертифікацій і безперервного навчання.
15. Дослідницьке: спроєктуйте програму тестування для модельної організації, оцініть її зрілість (17.2) й запропонуйте дорожню карту вдосконалення з інтеграцією в управління безпекою.

Список використаних джерел

[1] Бокове переміщення в мережі та методи його виявлення. *Кібербезпека: освіта, наука, техніка.* 2024. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1090.

[2] Визначення обсягу та планування робіт з тестування на проникнення. *Кібербезпека: освіта, наука, техніка.* 2024. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1034.

[3] Вимоги до відновлення стану систем після авторизованого тестування. *Сучасний захист інформації.* 2024. № 3.

[4] Вимоги до звітів за результатами тестування на проникнення. *Кібербезпека: освіта, наука, техніка.* 2024. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1156.

[5] Виявлення мережевого сканування засобами моніторингу безпеки. *Захист інформації.* 2023. Т. 25, № 2.

[6] Виявлення помилок конфігурації як поширеного класу вразливостей інформаційних систем. *Сучасний захист інформації.* 2024. № 2.

[7] Виявлення та запобігання ін'єкційним вразливостям у вебзастосунках. *Захист інформації.* 2023. Т. 25, № 3.

[8] Договірне оформлення послуг з оцінювання захищеності інформаційних систем. *Захист інформації.* 2023. Т. 25, № 2.

[9] Емуляція супротивника (red teaming) як метод перевірки спроможності виявлення та реагування. *Кібербезпека: освіта, наука, техніка.* 2024. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1145.

[10] Етичні та правові аспекти діяльності фахівців з оцінювання захищеності. *Захист інформації.* 2023. Т. 25, № 1.

[11] Закон України «Про інформацію» від 02.10.1992 № 2657-XII (зі змінами).

[12] Закон України «Про основні засади забезпечення кібербезпеки України» від 05.10.2017 № 2163-VIII.

[13] Застосування графів атак для аналізу шляхів компрометації в корпоративних мережах. *Сучасний захист інформації.* 2024. № 1.

[14] Застосування матриці MITRE ATT&CK для планування та оцінювання тестувань на проникнення. *Захист інформації.* 2023. Т. 25, № 3.

[15] Застосування системи CVSS для оцінювання критичності вразливостей інформаційних систем. *Захист інформації.* 2023. Т. 25, № 3.

[16] Застосування MITRE ATT&CK для оцінювання покриття виявлення. *Сучасний захист інформації.* 2024. № 2.

[17] Зменшення цифрового сліду організації як захід протидії розвідці. *Захист інформації*. 2023. Т. 25, № 1.

[18] Ідентифікація мережевих сервісів та операційних систем за непрямими ознаками. *Сучасний захист інформації*. 2023. № 3.

[19] Комунікація результатів оцінювання захищеності різним аудиторіям. *Захист інформації*. 2023. Т. 25, № 4.

[20] Кримінальний кодекс України. Розділ XVI «Кримінальні правопорушення у сфері використання електронно-обчислювальних машин (комп'ютерів), систем та комп'ютерних мереж і мереж електрозв'язку» (ст. 361–363-1).

[21] Людський чинник у забезпеченні інформаційної безпеки організації. *Сучасний захист інформації*. 2024. № 1.

[22] Методика тестування захищеності вебзастосунків за OWASP. *Кібербезпека: освіта, наука, техніка*. 2024. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1101.

[23] Методи підвищення привілеїв та заходи протидії їм. *Захист інформації*. 2023. Т. 25, № 1.

[24] Методи розвідки з відкритих джерел (OSINT) у задачах оцінювання захищеності. *Кібербезпека: освіта, наука, техніка*. 2024. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1045.

[25] Мінімізація ризику шкоди під час активного тестування інформаційних систем. *Захист інформації*. 2023. Т. 25, № 4.

[26] Місце тестування на проникнення в системі управління інформаційною безпекою організації. *Сучасний захист інформації*. 2023. № 2.

[27] Моделювання загроз як основа планування оцінювання захищеності. *Захист інформації*. 2023. Т. 25, № 4.

[28] Особливості оцінювання захищеності мобільних застосунків. *Захист інформації*. 2023. Т. 25, № 4.

[29] Особливості оцінювання захищеності хмарних середовищ. *Захист інформації*. 2023. Т. 25, № 1.

[30] Особливості тестування захищеності програмних інтерфейсів (API). *Сучасний захист інформації*. 2024. № 2.

[31] Побудова програми тестування на проникнення в організації. *Захист інформації*. 2023. Т. 25, № 1.

[32] Порівняльний аналіз методологій тестування на проникнення. *Кібербезпека: освіта, наука, техніка*. 2024. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1023.

[33] Постексплуатація та оцінювання впливу в процесі тестування на проникнення. *Кібербезпека: освіта, наука, техніка*. 2024. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1089.

[34] Проблема хибнопозитивних спрацювань у засобах автоматизованого сканування вразливостей. *Сучасний захист інформації*. 2024. № 1.

[35] Професійний розвиток та сертифікація фахівців з оцінювання захищеності. *Кібербезпека: освіта, наука, техніка.* 2024. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1167.

[36] Про рішення Ради національної безпеки і оборони України «Про Стратегію кібербезпеки України». Указ Президента України. Київ, 2021.

[37] Розроблення демонстраційних сценаріїв (proof-of-concept) для підтвердження вразливостей. *Сучасний захист інформації.* 2024. № 2.

[38] Сегментація мережі як захід протидії поширенню атаки. *Захист інформації.* 2023. Т. 25, № 2.

[39] Соціальна інженерія як вектор атак та методи протидії. *Кібербезпека: освіта, наука, техніка.* 2024. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1134.

[40] Стандартизація процесів оцінювання захищеності інформаційних систем в Україні. *Сучасний захист інформації.* 2024. № 1.

[41] Тестування захищеності безпроводових мереж стандарту IEEE 802.11. *Кібербезпека: освіта, наука, техніка.* 2024. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1112.

[42] Тестування захищеності мережевої інфраструктури підприємства. *Кібербезпека: освіта, наука, техніка.* 2024. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/1123.

[43] Управління ризиками проєкту тестування на проникнення. *Сучасний захист інформації.* 2023. № 4.

[44] Фішингові атаки та оцінювання обізнаності персоналу організацій. *Захист інформації.* 2023. Т. 25, № 2.

[45] Юридична відповідальність за несанкціоноване втручання в роботу інформаційних систем за законодавством України. *Інформація і право.* 2023. № 3.

[46] ACM. ACM Code of Ethics and Professional Conduct. Association for Computing Machinery, 2018.

[47] Anderson R. Security Engineering: A Guide to Building Dependable Distributed Systems. 3rd ed. Indianapolis: Wiley, 2020. 1232 p.

[48] Anley C., Heasman J., Lindner F., Richarte G. The Shellcoder's Handbook: Discovering and Exploiting Security Holes. 2nd ed. Indianapolis: Wiley, 2007. 744 p.

[49] Antonakakis M., April T., Bailey M., et al. Understanding the Mirai Botnet. *USENIX Security Symposium.* USENIX Association, 2017. P. 1093–1110.

[50] Applebaum A., Miller D., Strom B., et al. Intelligent, Automated Red Team Emulation. *Proceedings of the 32nd ACSAC.* ACM, 2016. P. 363–373.

[51] Bada M., Sasse A. M., Nurse J. R. C. Cyber Security Awareness Campaigns: Why Do They Fail to Change Behaviour? 2015.

[52] Bazzell M. Open Source Intelligence Techniques: Resources for Searching and Analyzing Online Information. 9th ed. 2022. 550 p.

[53] Bishop M. About Penetration Testing. *IEEE Security & Privacy*. 2007. Vol. 5, № 6. P. 84–87.

[54] Castiglione A., De Santis A., Soriente C. Taking Advantages of a Disadvantage: Digital Forensics and Steganography Using Document Metadata. *Journal of Systems and Software*. 2007. Vol. 80, № 5. P. 750–764.

[55] Cialdini R. B. Influence: The Psychology of Persuasion. Revised ed. New York: Harper Business, 2006. 320 p.

[56] Council of Europe. Convention on Cybercrime (Budapest Convention), ETS No. 185. Budapest, 2001.

[57] Cybersecurity and Infrastructure Security Agency (CISA). Known Exploited Vulnerabilities (KEV) Catalog. URL: https://www.cisa.gov/known-exploited-vulnerabilities-catalog.

[58] Delpy B. Mimikatz: Extraction of Credentials from Windows Memory — Technical Overview. 2014. (ілюстрація ризику облікових даних у пам'яті).

[59] Doupé A., Cova M., Vigna G. Why Johnny Can't Pentest: An Analysis of Black-Box Web Vulnerability Scanners. *DIMVA 2010*. LNCS Vol. 6201. Springer, 2010. P. 111–131.

[60] Dunagan J., Zheng A. X., Simon D. R. Heat-ray: Combating Identity Snowball Attacks Using Machine Learning, Combinatorial Optimization and Attack Graphs. *Proceedings of the ACM SOSP*. ACM, 2009. P. 305–320.

[61] EC-Council. Certified Ethical Hacker (CEH) — Certification Program. EC-Council, 2023.

[62] EC-Council. Code of Ethics for Certified Ethical Hackers. EC-Council, 2023.

[63] Enck W., Octeau D., McDaniel P., Chaudhuri S. A Study of Android Application Security. *USENIX Security Symposium*. USENIX Association, 2011. P. 21–36.

[64] European Central Bank. TIBER-EU Framework: How to Implement the European Framework for Threat Intelligence-Based Ethical Red Teaming. ECB, 2018.

[65] European Central Bank. TIBER-EU Framework: Threat Intelligence-Based Ethical Red Teaming. ECB, 2018.

[66] FIRST. Common Vulnerability Scoring System (CVSS) v3.1: Specification Document. Forum of Incident Response and Security Teams, 2019.

[67] Freund J., Jones J. Measuring and Managing Information Risk: A FAIR Approach. Waltham: Butterworth-Heinemann, 2014. 408 p.

[68] Google. Android Security Model and Application Sandbox — AOSP Documentation. 2024. URL: https://source.android.com/docs/security.

[69] Graham R. D. MASSCAN: Mass IP Port Scanner — Documentation. URL: https://github.com/robertdavidgraham/masscan.

[70] Greenbone. OpenVAS / Greenbone Vulnerability Management — Documentation. URL: https://www.greenbone.net/.

[71] Grossman J., Hansen R., Petkov P. D., Rager A., Fogie S. XSS Attacks: Cross Site Scripting Exploits and Defense. Burlington: Syngress, 2007. 480 p.

[72] Hadnagy C. Social Engineering: The Science of Human Hacking. 2nd ed. Indianapolis: Wiley, 2018. 320 p.

[73] Halfond W. G. J., Viegas J., Orso A. A Classification of SQL Injection Attacks and Countermeasures. *Proceedings of the International Symposium on Secure Software Engineering*. 2006.

[74] Hardt D. (ed.). The OAuth 2.0 Authorization Framework. RFC 6749. IETF, 2012.

[75] Herzog P. OSSTMM 3: The Open Source Security Testing Methodology Manual. ISECOM, 2010.

[76] Householder A. D., Wassermann G., Manion A., King C. The CERT Guide to Coordinated Vulnerability Disclosure. CMU/SEI, 2017. (про proof-of-concept та відповідальність).

[77] Howard M., Lipner S. The Security Development Lifecycle. Redmond: Microsoft Press, 2006. 352 p. (методика STRIDE).

[78] Hutchins E. M., Cloppert M. J., Amin R. M. Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains. *Leading Issues in Information Warfare & Security Research*. 2011. Vol. 1. P. 80–106.

[79] IEEE. IEEE Std 802.11: Wireless LAN Medium Access Control (MAC) and Physical Layer (PHY) Specifications. IEEE, 2020.

[80] International Organization for Standardization. ISO/IEC 27001: Information Security Management Systems — Requirements. Geneva: ISO, 2022.

[81] ISO/IEC 29147:2018. Information Technology — Security Techniques — Vulnerability Disclosure. Geneva: ISO/IEC, 2018.

[82] ISO/IEC 30111:2019. Information Technology — Security Techniques — Vulnerability Handling Processes. Geneva: ISO/IEC, 2019.

[83] Jacobs J., Romanosky S., Edwards B., Roytman M., Adjerid I. Exploit Prediction Scoring System (EPSS). *Digital Threats: Research and Practice*. 2021. Vol. 2, № 3.

[84] Jung J., Paxson V., Berger A. W., Balakrishnan H. Fast Portscan Detection Using Sequential Hypothesis Testing. *IEEE Symposium on Security and Privacy*. IEEE, 2004. P. 211–225.

[85] Kennedy D., O'Gorman J., Kearns D., Aharoni M. Metasploit: The Penetration Tester's Guide. San Francisco: No Starch Press, 2011. 328 p.

[86] Kim P. The Hacker Playbook 3: Practical Guide to Penetration Testing. Secure Planet, 2018. (розд. про постексплуатацію).

[87] Kim P. The Hacker Playbook 3: Practical Guide to Penetration Testing. Secure Planet, 2018. (розд. про поворотні точки й поширення).

[88] Lippmann R., Fried D., Piwowarski K., Streilein W. Passive Operating System Identification from TCP/IP Packet Headers. *Proceedings of the ICDM Workshop on Data Mining for Computer Security*. 2003.

[89] Long J. No Tech Hacking: A Guide to Social Engineering, Dumpster Diving, and Shoulder Surfing. Burlington: Syngress, 2008. 384 p.

[90] Lyon G. F. Nmap Network Scanning: The Official Nmap Project Guide to Network Discovery and Security Scanning. Sunnyvale: Insecure.Com LLC, 2009. 468 p.

[91] Mandiant. M-Trends: Annual Threat Report (показники dwell time та виявлення). Mandiant, 2023.

[92] Matherly J. Complete Guide to Shodan: Collect. Analyze. Visualize. Make Internet Intelligence Work for You. Leanpub, 2017.

[93] Mell P., Grance T. The NIST Definition of Cloud Computing. NIST Special Publication 800-145. Gaithersburg: NIST, 2011.

[94] Metcalf S. Active Directory Security — Attack and Defense Fundamentals. 2019. (огляд безпеки служб каталогів).

[95] Migues S., Steven J., Ware M. Building Security In Maturity Model (BSIMM). Synopsys, 2023.

[96] Mitnick K. D., Simon W. L. The Art of Deception: Controlling the Human Element of Security. Indianapolis: Wiley, 2002. 368 p.

[97] MITRE ATT&CK. Tactic TA0003: Persistence. The MITRE Corporation. URL: https://attack.mitre.org/tactics/TA0003/.

[98] MITRE ATT&CK. Tactic TA0004: Privilege Escalation. The MITRE Corporation. URL: https://attack.mitre.org/tactics/TA0004/.

[99] MITRE ATT&CK. Tactic TA0006: Credential Access. The MITRE Corporation. URL: https://attack.mitre.org/tactics/TA0006/.

[100] MITRE ATT&CK. Tactic TA0008: Lateral Movement. The MITRE Corporation. URL: https://attack.mitre.org/tactics/TA0008/.

[101] MITRE. Common Vulnerabilities and Exposures (CVE). The MITRE Corporation. URL: https://www.cve.org/.

[102] MITRE. Common Weakness Enumeration (CWE). The MITRE Corporation. URL: https://cwe.mitre.org/.

[103] Mockapetris P. Domain Names — Concepts and Facilities. RFC 1034. IETF, 1987.

[104] National Institute of Standards and Technology. National Vulnerability Database (NVD). URL: https://nvd.nist.gov/.

[105] Oakley J. G. Professional Red Teaming: Conducting Successful Cybersecurity Engagements. Berkeley: Apress, 2019. 213 p.

[106] OffSec. Exploit Database (Exploit-DB) — Archive of Public Exploits. URL: https://www.exploit-db.com/.

[107] OffSec. OSCP: Offensive Security Certified Professional — Certification Overview. Offensive Security, 2023.

[108] Open Information Systems Security Group (OISSG). Information Systems Security Assessment Framework (ISSAF). 2006.

[109] OWASP Foundation. OWASP API Security Top 10. 2023. URL: https://owasp.org/API-Security/.

[110] OWASP Foundation. OWASP Mobile Application Security Testing Guide (MASTG). URL: https://mas.owasp.org/.

[111] OWASP Foundation. OWASP Top 10: The Ten Most Critical Web Application Security Risks. 2021. URL: https://owasp.org/Top10/.

[112] OWASP Foundation. OWASP Zed Attack Proxy (ZAP) — Documentation. URL: https://www.zaproxy.org/.

[113] OWASP Foundation. Testing for Business Logic Flaws — Web Security Testing Guide. 2020.

[114] OWASP Foundation. Verification and Retesting — Web Security Testing Guide. 2020.

[115] OWASP Foundation. Web Security Testing Guide (WSTG). Version 4.2. 2020. URL: https://owasp.org/www-project-web-security-testing-guide/.

[116] Palmer C. C. Ethical Hacking. *IBM Systems Journal*. 2001. Vol. 40, № 3. P. 769–780.

[117] Paterva. Maltego: Open Source Intelligence and Graphical Link Analysis Tool — Documentation. URL: https://www.maltego.com/.

[118] PCI Security Standards Council. Payment Card Industry Data Security Standard (PCI DSS). Version 4.0. 2022.

[119] PortSwigger. Burp Suite and the Web Security Academy. URL: https://portswigger.net/web-security.

[120] Postel J. (ed.). Transmission Control Protocol. RFC 793. IETF, 1981.

[121] Project Management Institute. A Guide to the Project Management Body of Knowledge (PMBOK Guide). 7th ed. Newtown Square: PMI, 2021.

[122] PTES. Penetration Testing Execution Standard — Reporting. 2014. URL: http://www.pentest-standard.org/index.php/Reporting.

[123] Purple teaming: взаємодія атакувальної та захисної команд. *Захист інформації*. 2023. Т. 25, № 3.

[124] Red Canary. Atomic Red Team: Library of Tests Mapped to MITRE ATT&CK. URL: https://atomicredteam.io/.

[125] Regulation (EU) 2016/679 of the European Parliament and of the Council (General Data Protection Regulation). Official Journal of the EU, 2016.

[126] Robbins A., Vazarkar R., Schroeder W. BloodHound: Six Degrees of Domain Admin — Attack Path Analysis. 2016. URL: https://github.com/BloodHoundAD/BloodHound.

[127] Rose S., Borchert O., Mitchell S., Connelly S. Zero Trust Architecture. NIST Special Publication 800-207. Gaithersburg: NIST, 2020.

[128] SANS Institute. Rules of Engagement and Pre-Engagement Interactions for Penetration Testing. SANS Reading Room, 2018.

[129] SANS/GIAC. GIAC Penetration Tester (GPEN) and Related Certifications. SANS Institute, 2023.

[130] Scarfone K., Souppaya M., Cody A., Orebaugh A. Technical Guide to Information Security Testing and Assessment. NIST SP 800-115. Gaithersburg: NIST, 2008. (розд. про збір інформації).

[131] Schneier B. Attack Trees. *Dr. Dobb's Journal*. 1999. Vol. 24, № 12. P. 21–29.

[132] Shostack A. Threat Modeling: Designing for Security. Indianapolis: Wiley, 2014. 624 p.

[133] Smiliotopoulos C., Kambourakis G., Barbatsalou K. On the Detection of Lateral Movement through Supervised Machine Learning. *International Journal of Information Security*. 2023. Vol. 22. P. 1893–1919.

[134] Souppaya M., Morello J., Scarfone K. Application Container Security Guide. NIST SP 800-190. Gaithersburg: NIST, 2017.

[135] Szekeres L., Payer M., Wei T., Song D. SoK: Eternal War in Memory. *2013 IEEE Symposium on Security and Privacy*. IEEE, 2013. P. 48–62.

[136] The MITRE Corporation. CALDERA: Automated Adversary Emulation Platform. URL: https://caldera.mitre.org/.

[137] The MITRE Corporation. MITRE ATT&CK: Adversarial Tactics, Techniques, and Common Knowledge. URL: https://attack.mitre.org/.

[138] The Penetration Testing Execution Standard (PTES). 2014. URL: http://www.pentest-standard.org/.

[139] United States Code. Computer Fraud and Abuse Act (CFAA), 18 U.S.C. § 1030.

[140] Vanhoef M., Piessens F. Key Reinstallation Attacks: Forcing Nonce Reuse in WPA2. *Proceedings of the 2017 ACM CCS*. ACM, 2017. P. 1313–1328.

[141] Wi-Fi Alliance. WPA3 Specification. Version 3.0. Wi-Fi Alliance, 2020.

Додатки

Додаток А. Короткий словник ключових термінів

Тестування на проникнення. Авторизована контрольована імітація атаки для оцінювання захищеності.

Етичний хакінг. Застосування технік зловмисника з дозволу й з метою посилити захист.

Авторизація. Явний письмовий дозвіл власника на проведення тестування у визначених межах.

Обсяг (scope). Перелік систем, цілей і дій, дозволених у межах тестування.

Правила взаємодії (RoE). Погоджені умови й обмеження проведення тестування.

Розвідка (OSINT). Збір інформації про ціль, зокрема з відкритих джерел.

Поверхня атаки. Сукупність точок можливої взаємодії зловмисника із системою.

Вразливість. Слабкість, що може бути використана для порушення безпеки.

Експлуатація. Використання вразливості для отримання доступу чи впливу.

Постексплуатація. Дії після отримання доступу (оцінка впливу, збір доказів).

Підвищення привілеїв. Отримання вищих прав у системі.

Бокове переміщення. Поширення доступу від одного вузла до інших.

Red team. Прихована емуляція реального супротивника з перевіркою виявлення й реагування.

Purple team. Спільна робота атакувальної (red) та захисної (blue) команд.

Відповідальне розкриття. Скоординоване повідомлення про вразливість із часом на виправлення.

Додаток Б. Етапи тестування на проникнення

Етап	Зміст	Розділ
Планування	обсяг, правила, авторизація	4
Розвідка	збір інформації (OSINT)	5
Сканування	ідентифікація сервісів	6
Оцінювання	аналіз вразливостей	7
Експлуатація	контрольоване проникнення	8
Постексплуатація	оцінка впливу, доступ	9, 10
Звітування	документування, рекомендації	16

Додаток В. Чек-лист етичної та правової готовності

1. Отримано явну письмову авторизацію власника системи (розділ 2).
2. Чітко визначено обсяг, цілі й недопустимі дії (розділ 4).
3. Погоджено правила взаємодії, вікна проведення й канали екстреного зв'язку.
4. Узгоджено поводження з виявленими персональними й чутливими даними.
5. Передбачено заходи мінімізації ризику шкоди й плану відкату.
6. Дотримано вимог законодавства України (ст. 361–363-1 КК) та договірних зобов'язань.
7. Погоджено порядок відповідального розкриття й збереження конфіденційності (розділ 16).
8. Забезпечено захищене зберігання зібраних доказів і подальше їх знищення.
9. Визначено порядок дій за виявлення ознак стороннього втручання.
10. Узгоджено формат, адресатів і строки передачі звіту.